

1/110

☐

File No.: PS/00677/2022

TABLE OF CONTENTS

I.

BACKGROUND:

FIRST. – Agreement to initiate this sanctioning procedure

SECOND. – Submission of allegations to the initiation agreement and partial acknowledgment of responsibility.

THIRD. – Voluntary payment of three infractions.

FOURTH. – Acknowledgment of responsibility and waiver of any action or appeal in the administrative route regarding three infractions.

FIFTH. – Issuance of the resolution proposal. Transcription of the full text of the proposal with the following structure:

☐

Background: First to Eleventh.

☐

Proven Facts: First to Forty-sixth

☐

Legal Grounds: First to Tenth

☐

Resolution Proposal

SIXTH. – Submission of allegations to the resolution proposal

SEVENTH. – Voluntary payment of two infractions.

EIGHTH. – Waiver of any action or appeal in the administrative route regarding two infractions.

NINTH. – Proposal of measures.

I.

LEGAL GROUNDS

FIRST. – Competence.

SECOND. – Termination of the procedure due to voluntary payment.

THIRD. – Response to the allegations made regarding the resolution proposal.

FOURTH. – Imposition of measures.

DISPOSITIVE PART

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

2/110

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On January 11, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate a sanctioning procedure against BBVA in order to impose fines totaling 1,640,000 euros, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged commission of the following infractions:

Three related to the specific case reported by the complainant:

- For the alleged infringement of Article 6.1 of the GDPR classified under Article 83.5 of the GDPR, concerning the unauthorized contracting of products.
- For the alleged infringement of Article 32 of the GDPR classified under Article 83.4 of the same Regulation, due to the lack of security measures regarding the processes of communication, inclusion, and maintenance in credit information systems of personal data.
- For the alleged infringement of Article 6.1 of the GDPR classified under Article 83.5 of the same Regulation, concerning the incorporation of personal data into credit information systems.

And two related to the manner in which the procedures implemented by BBVA were established and revealed through the information provided by the financial entity during the investigation:

- For the alleged infringement of Article 25 of the GDPR classified under Article 83.4 of the same Regulation.
- For the alleged infringement of Article 32 of the GDPR classified under Article 83.4 of the same Regulation, due to the lack of security measures regarding the procedures for contracting financial products.

In the aforementioned initiation agreement, BBVA was informed that it had a period of ten days to submit allegations.

SECOND: On February 10, 2023, a letter from BBVA was received by this Agency, in due time and form, in which, on the one hand, allegations were made regarding the initiation agreement concerning the alleged infringement of Article 25 of the GDPR and the alleged infringement of Article 32 of the GDPR due to lack of security measures regarding the procedures for contracting financial products, and, on the other hand, responsibility was accepted for the commission of the following infractions included in the initiation agreement related to the specific case reported to the Agency that led to the investigation conducted:

- The infringement of Article 6.1 of the GDPR classified under Article 83.5 of the GDPR, concerning the unauthorized contracting of products.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

3/110

- The infringement of Article 32 of the GDPR as classified in Article 83.4 of the same Regulation, due to the lack of security measures concerning the communication, inclusion, and maintenance procedures in credit information systems of personal data,

- The infringement of Article 6.1 of the GDPR as classified in Article 83.5 of the same Regulation, concerning the incorporation of personal data into credit information systems.

THIRD: BBVA proceeded to pay the fines imposed for the infringements for which responsibility had been accepted, in the amount of 384,000 euros, making use of the two reductions provided for in the initiation agreement.

FOURTH: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the waiver of any action or administrative appeal against the sanction and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement regarding the infringements for which BBVA has accepted responsibility.

FIFTH: After analyzing the allegations submitted, on September 8, 2023, the following resolution proposal was issued:

<<

File No.: PS/00677/2022

PROPOSAL FOR RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the claimant) on October 12, 2021, filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against BANCO BILBAO VIZCAYA ARGENTARIA, S.A. with NIF A48265169 (hereinafter, the respondent or BBVA). The reasons on which the complaint is based are as follows:

On April 13, 2020, the claimant requested BBVA to block her card number ***TARJETA.1 upon realizing that it had been stolen.

The claimant states that: "On April 14, 2020, BBVA was notified by phone and email that, between April 10 and 13, Ms. A.A.A. was the victim of a handbag theft (including mobile phone, card, and other personal belongings) by a worker at the Residence (...), in Barcelona. Ms. A.A.A. was temporarily at that residence to receive oncological treatment. Immediate blocking of all banking products contracted

by Ms. A.A.A. and B.B.B. was requested from BBVA.

“BBVA ignored this request and allowed, in the following weeks, third parties to access the banking products of these ladies through identity theft, operate with them (emptying the accounts, charging invoices), contract new products (loan, card, Carrefour financing), make international transfers to Latin American countries from these accounts, etc.”

However, according to the claimant, unauthorized charges, transfers, and movements occurred in her account, generating a debt that does not belong to her, which BBVA claims through various collection companies.

She submits along with her complaint a report from EXPERIAN dated August 18 and September 8, 2020, regarding the inclusion of the claimant's data at the request of the respondent; a lawsuit filed with the court on September 3, 2020; a letter dated October 31, 2020, with claims from KRUK and EXPERIAN; and a letter dated September 21, 2021, with a claim from AXACTOR.

Along with the notification, a lawsuit filed by the claimant in Ordinary Court against the respondent, dated September 1, 2020, is included.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on December 10, 2021, as evidenced by the acknowledgment of receipt in the file. On January 28, 2022, this Agency received a response letter indicating the following: first, it includes a summary of the events that occurred from April 2020:

On April 13, 2020, the claimant requested BBVA to block her card number ***TARJETA.1 upon realizing that it had been stolen, as detailed in the lawsuit.

On that same day, BBVA proceeded to block the card immediately, exactly at 18:07, although this did not prevent an unidentified person from previously impersonating Ms. A.A.A. and carrying out different operations, purchases with the bank card, and transfers.

On May 6, 2020, the Customer Service Center received a communication from Ms. C.C.C. requesting the reversal of any banking operation carried out since April 10.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

5/110

2020 charged to the account, or to any other product, owned by their representatives, Ms. A.A.A. and Ms. B.B.B. at BBVA.

On 3/07/2020, the Customer Service Center received a second letter from Ms. C.C.C. requesting that access by third parties to any banking product owned by Ms. A.A.A. and Ms. B.B.B. be prevented, as well as the payment of the amounts and concepts previously claimed in May 2020.

On 09/09/2020, Ms. B.B.B. contacted the Customer Ombudsman's Office via email requesting the cancellation of various products owned by Ms. A.A.A., as well as the reimbursement of the amounts withdrawn and previously claimed from BBVA.

On 13/07/2020, BBVA requested Ms. A.A.A. to pay the debt arising from an overdraft on her account and the installments of a personal loan, warning that “the data of certain, due, enforceable, and unpaid debts with BBVA, whose payment has been previously requested, will be communicated to ASNEF, a credit information system in which our entity participates, accessible to any natural or legal person, all in accordance with the provisions established by Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights.”

This notification was made through the company SERVIFORM, S.A. (hereinafter, “Servinform”), a subcontracted company by BBVA that certifies that this communication was generated, printed, and enveloped without any incident that altered the final result of the sending. On 13/07/2020, communication reference number ***REFERENCIA.1 was made available to the postal service for

subsequent distribution, along with a total of 870 communications. The delivery receipt number ***ALBARÁN.1 is also attached.

Regarding the indicated requirement, the service provider for return control (a service that Servinform has subcontracted to EQUIFAX IBERICA S.L.) has certified on 20/12/2021 that “there is no record that the Certification Letter of Prior Payment Requirement with ref. ***REFERENCIA.1, generated in Equifax, on date 13/07/2020, processed by the service provider SERVIFORM S.A. (formerly MFASIS Billing & Marketing Services, S.L.) on date 13/07/2020, and made available to the postal service on date 13/07/2020, 15/07/2020; addressed to A.A.A., at the address ***DIRECCIÓN.1, in the locality of ***LOCALIDAD.1 with Postal Code (...) – TARRAGONA, has been returned for any reason to the designated post office box for that purpose.” Documents that are all grouped together in Document No. 8.

On 8/09/2020, BBVA transferred Ms. A.A.A.'s data to the Badexcug/Experian solvency file due to the aforementioned debts.

On 22/09/2020, the Court of First Instance No. 10 of Barcelona notified BBVA of the lawsuit filed by Ms. A.A.A. within the Ordinary Procedure ***PROCEDIMIENTO.1 where she requested, among other things.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

6/110

pronouncements, the payment of 6,090.14 euros for fraudulent charges and 7,000 euros for lost profits or immaterial damages.

BBVA, as evidenced, immediately proceeded to block all payment instruments associated with Ms. A.A.A. However, BBVA has not reversed the charges made previously since the transactions were validated with two-factor authentication.

The claiming party asserts that they did not provide consent for the transactions carried out between April 10 and 13, 2020. However, we cannot consider Article 31 of the Royal Decree-Law on Payment Services applicable, which states that “in the event that an unauthorized payment transaction is executed, the payment service provider of the payer shall immediately refund the amount of the unauthorized transaction and, where applicable, restore the payment account to the state that would have existed had the unauthorized payment transaction not been executed,” since the transactions were authenticated and accurately recorded and accounted for, and were not affected by a technical failure or any other deficiency.

Article 30 of the Payment Services Law establishes that “when a user of payment services denies having authorized a payment transaction that has already been executed or claims that it was executed incorrectly, it shall be the responsibility of their payment service provider to demonstrate that the payment transaction was authenticated, accurately recorded and accounted for, and that it was not affected by a technical failure or any other deficiency.”

For these purposes, within the framework of the judicial procedure processed by the Court of First Instance No. 10 of Barcelona (***PROCEDIMIENTO.1), the appropriateness of such a claim is being discussed, where, according to the evidence provided by the parties, it will be resolved whether there was a lack of diligence on the part of the claiming party in safeguarding the security mechanisms provided by the Bank. BBVA does not currently maintain the claiming party's data in solvency and credit files.

For all the above reasons, it is evident that BBVA's actions have been diligent and in accordance with data protection regulations, with a judicial resolution pending regarding the amounts involved, and not currently transferring data to solvency and credit files.

THIRD: On January 12, 2022, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claiming party was admitted for processing.

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in

Title VII, Chapter I, Section Two, of the LOPDGDD.

These actions aimed to investigate the facts reported in the claim and, as a consequence, also analyze the procedure that BBVA has established for the contracting of financial products and the guarantees that are established in those procedures to avoid situations like the one that occurred.

Through this investigation, the following points were noted:

Facts according to statements from the claiming party:

- Between April 10 and 13, 2020, the claiming party was a victim of the theft of their handbag, which contained, among other things, their mobile phone, national identity document, and credit card.
- On April 13, they notified the respondent of the theft and on the 14th requested the blocking of all banking products contracted by the claiming party and their daughter. They also informed that among the stolen documents were the credit card, ID, and mobile phone, among others.
- They express that the respondent did not proceed correctly with the requested blocking, which allowed third parties to impersonate the identities of the affected parties, accessing their banking products and operating with them.
- They indicate that the respondent has registered the claiming party in credit information systems and has transferred their data to collection companies (citing "KRUK, EXPERIAN, AXACTOR").

Relevant documentation provided by the claiming party:

- Ordinary lawsuit (hereinafter the lawsuit) against the respondent filed on September 1, 2020, which contains a description of the facts.
- Written expansion of the lawsuit (first expansion of the lawsuit) dated October 31, 2020 (presentation record on November 2, 2020) referencing "****PROCEDIMIENTO.1" in which they state that the respondent has continued to claim amounts corresponding to acts carried out by the criminals and has included the claiming party in a "delinquent file." Attached are several documents, including: an email sent on September 9, 2020, to the respondent, and a letter dated September 8, 2020, from Experian to the claiming party informing them of the inclusion of a debt arising from a personal loan by the respondent in the Badexcug file.
- Written expansion of the lawsuit dated September 21, 2021 (second expansion of the lawsuit) in which it is mentioned that the entity AXACTOR, on behalf of the respondent, has contacted the claiming party to manage an outstanding debt for collection. A copy of the letter is attached.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

8/110

On January 18, 2022, the claimant submitted the document with registration number (...) (expansion of the claim) providing the following additional documentation related to the reported facts:

- Letter addressed by the respondent to the claimant to inform them of the existence of two debts related to contracts ***CONTRACT.1 and ***CONTRACT.2 that have been communicated to the collections department. Furthermore, it informs that certain, overdue, enforceable, and unpaid debts for which payment has been requested may be reported to credit information systems.
- Letter from Equifax dated December 24, 2021, informing that the respondent, on December 23, 2021, requested the inclusion of two debts for the concepts of "personal loans" and "credit cards."
- Copy of a burofax dated January 5, 2022, addressed by the claimant to the respondent in which, regarding the payment request for certain debts received on December 15, 2021, it refers to the existence of a lawsuit ("****PROCEDURE.1") filed on September 1, 2020, requesting a judicial declaration for the closure and cancellation of bank accounts and cards and for the exemption from any debt arising from them since April 10, 2020, onwards. It states that this process is pending scheduling for trial. It also states that the debt is not attributable to the claimant and requests the cancellation of their personal data in all files to which it has been transferred (including delinquency files).
- Copy of a burofax dated January 5, 2022, addressed by the claimant to Equifax referencing the previous document. It refers to the existence of a lawsuit ("****PROCEDURE.1") filed on September 1, 2020, requesting a judicial declaration for the closure and cancellation of bank accounts and cards and for the exemption from any debt arising from them since April 10, 2020, onwards. It states that this

process is pending scheduling for trial. It also states that the debt is not attributable to the claimant and requests the deletion of the claimant's personal data from all Equifax files.

INTERVENERS

In addition to those mentioned above, during the present proceedings, the following have intervened:

- AXACTOR ESPAÑA PLATFORM, S.A. (hereinafter, Axactor).
- EQUIFAX IBÉRICA, S.L. (hereinafter, Equifax).
- EXPERIAN BUREAU DE CRÉDITO, S.A. (hereinafter, Experian).
- INTRUM SERVICING SPAIN, S.A.U. (hereinafter, Intrum)

RESULT OF THE INVESTIGATION PROCEEDINGS

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

9/110

On the scope of the investigation

The documentation provided by the interveners contains details about linked products not only related to the claimant but also to the claimant's daughter, her husband, and the company of the latter.

Additionally, some documents mention fraudulent actions committed by third parties against the respondent in relation to other entities (Sanitas, Iberia, El Corte Inglés, Movistar, Carrefour, etc.).

Furthermore, some individuals who allegedly committed the crime are cited, indicating that judicial proceedings are also being pursued against them. Since the claim before this agency has been filed on behalf of the claimant and against the respondent, the investigation is limited to the relationship between both parties and its impact on the right to the protection of their personal data.

Chronology of events

In the communications referred to below, the respondent has acted both through generic addresses associated with different departments (customer advocate, security department, customer service, etc.) and through specific employees (branch manager and their assistant to whom the claimant was assigned). In this chronology, the former type is cited as relevant or directed to the respondent (without specific department designation). In the case of the latter, reference is made to the branch manager or their assistant.

From the information obtained, the following chronology of events has been established:

- According to the claimant's statement in the lawsuit, at the beginning of April 2020, they entered a residence to receive medical treatment.
- The claimant adds in the lawsuit that, between April 10 and 13, 2020, a worker at the residence stole "their mobile phone, [...] credit card, [...] and other essential personal documentation (ID, driver's license, [...])."
- On April 13, 2020, the card number ***CARD.1 of the claimant was blocked. The respondent states that it proceeded to block it "immediately" after the claimant's request. It provides a screenshot showing the execution of a manual blocking operation of card ***CARD.1 on April 13, 2020, at 18:06 hours.
- On April 14, 2020, the claimant's daughter emailed the respondent - to the address of the assistant to the branch manager - to report the theft suffered by the claimant ("mobile phone, wallet, cards, etc."). In the email, she requests to cancel "all" of the claimant's cards and asks for a phone number to call.
- On the same day, April 14, 2020, the respondent (the assistant to the branch manager) replies to the previous email stating that the claimant has only one card (***CARD.1) which was blocked on April 13.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

10/110

Additionally, it inquires whether the blocking was carried out as a result of a prior call to the "contact center." It also informs that, prior to the blocking, a series of charges had been made "through online banking that I suppose she did not carry out" which it lists. It expresses that, if these are incorrect, they need a report to be filed with the security forces in order to process the fraud.

-

The respondent states that prior to notifying the bank of the theft, a third party had already impersonated the claimant's identity and carried out transactions. It adds, in relation to these, that it has not reversed the charges since they were validated with two-factor authentication. Specifically, it points out that "the transactions were authenticated and recorded accurately and accounted for, and were not affected by a technical failure or any other deficiency."

o

It includes a list of charges made with the card ***TARJETA.1 between April 11 and April 30, 2020, for a total of 5,559.88 euros, made after the report filed by the claimant with BBVA on April 13.

o

It includes details of transfer-type movements and "bizum" transactions that occurred on April 14 and April 24, 2020, in which the claimant is listed as the sender, made after the report filed by the claimant with BBVA on April 13.

-

The claimant in the complaint states that "they attempted to cancel the mobile line related to the stolen device, ***TELÉFONO.1, from the Telefónica website and by making countless calls to the same."

-

On April 16, 2020, the respondent (the branch manager) sends an email stating that a report to the security forces is necessary to carry out the investigation.

-

On April 17, 2020, the claimant's daughter sends an email to the respondent (the branch manager) expressing that she will send a copy of the report from the claimant's representative. On the same day, April 17, 2020, the claimant's representative sends an email to the branch manager introducing herself and stating that she is attaching the report.

Attached to the document is the report filed on April 16, 2020, with the Mossos d'Esquadra. The report is filed by D.D.D. on behalf of the claimant. It includes a document in which the claimant's daughter authorizes D.D.D. to file the report on behalf of the claimant and her daughter. The report is filed against the nursing home where the claimant was located when the theft of her belongings occurred. The report indicates that the credit card, mobile phone, and ID card, among other belongings, were stolen. In the report, it mentions that they contacted the respondent and that he informed them that money had been withdrawn with the card beforehand.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

11/110

- On April 20, 2020, the respondent (branch manager) sent an email to the representative of the claimant party informing her that he has forwarded the complaint to the security and fraud department. Furthermore, the complaint indicates that the branch manager had communicated to them that someone had requested the issuance of two cards in the name of the claimant party.

- On May 1, 2020, D.D.D. submitted an extension of the complaint on behalf of the claimant party to the Mossos d'Esquadra, stating that the branch manager of the respondent had informed them that someone had contacted, identifying themselves as the claimant party, requesting the registration of a phone number in the respondent's database as the contact number for the claimant party. He expresses that the bank has informed him that this process must be done in person.

Impacted products of the claimant party

The claimant party states that third parties conducted transactions after the theft on the following products that they had contracted with the respondent prior (expressing that they did not carry out any movements after April 11, 2020):

- Account number ***CUENTA.1, of which the respondent specifies that it is not canceled. They provide a copy of the pre-contractual information and the contract. The claimant party acknowledges in the complaint that they were the holder of the account prior to the theft.

The claimant party provides a list of transactions on this account made between April 17 and July 7, 2020, conducted after the complaint made by the claimant party to BBVA on April 13. Additionally, in the complaint, the claimant party states that "all transactions made from April 17 to May 5, 2020, were carried out by the criminals, and all transactions made from June 17 to July 7, 2020, were carried out by the Bank." Likewise, in the complaint, the claimant party states that the account "has been blocked by the Bank, we assume during the first week of June 2020."

The respondent provides a screenshot showing the execution of a block for charges on this account dated August 31, 2020. The observations include references to previous blocks made on May 4, 2020, and August 11, 2020.

- Account number (***)CUENTA.2) - acknowledged by the claimant party as being their property prior to the theft in the complaint. The claimant party provides a list of transactions on this account made between April 14 and June 17, 2020. According to what they express in the complaint, "the transactions made from April 13 to May 4, 2020, were carried out by the criminals" and "the transactions made from May 5 to June 17, 2020, were carried out by the Bank." Likewise, in the complaint, the claimant party states that the account is blocked ("we believe since mid-June 2020"). The respondent provides a screenshot showing the execution of a block for charges on this account dated May 4, 2020. They also provide a screenshot referring to the block of deposits made on June 25, 2020.

- Card number (***)TARJETA.1 linked to contract (***)CONTRATO.2, which was stolen as stated in the complaint.

o They provide a screenshot showing the execution of a manual block operation of card (***)TARJETA.1 on April 13, 2020, at 18:06 hours.

o They attach the document dated May 15, 2020, in which the claimant party informs the respondent, as the cardholder, of the theft and requests the refund of the amount of a set of transactions that they list. The list includes charges incurred between April 11 and April 30, 2020. In the complaint, they state that the bank "has acknowledged responsibility for the transactions made in relation to said card for an amount of 5,559.88 euros."

o In a document, the respondent states that "Information has been requested regarding the transactions made with the card after the date of the block, and regarding the changes in the block of the reference card."

Similarly, the claimant party states that third parties impersonated their identity by contracting new products with the bank. Namely:

- A loan of 4,000 euros subscribed on April 12, 2020, of which the respondent specifies that it is not canceled. They provide a copy of the contract, which includes the name, surname, address, and ID number of the claimant party. They state that it was electronically signed at the request of the claimant party through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 12, 2020.

- Card number (***)TARJETA.2 linked to contract (***)CONTRATO.3. Regarding this card, the claimant party indicates that it was requested from their mobile phone number and sent to their address. They also express that third parties subsequently used it to carry out transactions.

The respondent states that it was contracted on April 15, 2020, and provides a copy of the contract, which includes the name, surname, and ID number of the claimant party. They state that the request for the card was electronically signed through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 15, 2020.

13/110

The claimant attaches the document dated June 16, 2020, in which they notify the respondent, as the cardholder, of the theft and request the reimbursement of the amount for a set of transactions that are listed. The list includes charges made between April 17 and May 3, 2020. In the complaint, it states that the bank "has acknowledged responsibility for the transactions made in relation to said card, amounting to 404.84 euros."

The respondent provides a screenshot showing the incident with the reason "card theft" reported on June 16, 2020. In the comments, it states for June 16, 2020, the following: "Incident/fraud reported. We attach the filed complaint and block access keys, card, account, and deactivate the validated mobile."

Fraud department informed." They also provide a screenshot from their systems indicating July 6, 2020, as the date the card was blocked. Furthermore, the card is listed as lost and the contract is in a canceled state.

-

Account number ***CUENTA.3 (the claimant cites "an account ending in XX" in an email dated September 9, 2020) subscribed on April 27, 2020, which the respondent specifies is not canceled. They provide a copy of the contract, which includes the name, surname, address, and ID number of the claimant. They state that it was electronically signed at the request of the claimant through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 27, 2020. The respondent also notes other details of the contracting (IP address and validation in the respondent's "app" via fingerprint). In addition to the above, the respondent has referred to the following products contracted after April 10, 2020, which are canceled (in the complaint, the claimant also states that the bank issued two new bank cards at the request of the criminals):

-

Card number ***TARJETA.3 linked to contract ***CONTRATO.4 subscribed on April 15, 2020, which the respondent specifies is canceled. They provide a copy of the contract, which includes the name, surname, ID number of the claimant, and the email ***EMAIL.1. They state that it was electronically signed at the request of the claimant through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 15, 2020. The email address ***EMAIL.1, according to the document submitted to the court dated May 18, 2020, would be an account of the claimant that third parties would have had access to.

They also attach a screenshot from their systems indicating that the contract is canceled with reference to May 4, 2020, as the date of blocking.

-

Card number ***TARJETA.4 linked to contract ***CONTRATO.5 subscribed on April 15, 2020, which the respondent specifies is canceled. They provide a copy of the contract, which includes the name, C/ Jorge Juan, 6
www.aepd.es 28001 – Madrid
sedeagpd.gob.es
14/110

last names, ID number of the claiming party, and the email address ***EMAIL.1.

It states that it has been electronically signed at the request of the claiming party through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 15, 2020. The email address ***EMAIL.1, according to the document submitted to the court dated May 18, 2020, would be an account of the claiming party to which third parties would have had access.

It also attaches a screenshot from its systems indicating that the contract is canceled with reference to May 4, 2020, as the blocking date.

Judicial Procedure Status

The claiming party attaches the ordinary lawsuit against the defendant submitted on September 1, 2020, which contains the description of the facts.

The defendant states the following regarding the judicial procedure opened and its responsibility in the identity theft suffered by the claiming party:

"The claiming party argues that it did not give consent for the transactions carried out between April 10 and 13, 2020. However, we cannot consider Article 31 of the Royal Decree-Law on Payment Services applicable, which provides that 'in the event that an unauthorized payment transaction is executed, the payment service provider of the payer shall immediately refund the amount of the unauthorized transaction and, where appropriate, restore the payment account to the state that would have existed had the unauthorized payment transaction not been executed,' as the transactions were authenticated and accurately recorded and accounted for, and were not affected by a technical failure or any other deficiency.

Article 30 of the Payment Services Law establishes that 'when a user of payment services denies having authorized a payment transaction already executed or claims that it was executed incorrectly, it

shall be the responsibility of their payment service provider to demonstrate that the payment transaction was authenticated, accurately recorded, and accounted for, and that it was not affected by a technical failure or any other deficiency.

For these purposes, within the framework of the judicial procedure processed by the Court of First Instance No. 10 of Barcelona (***PROCEDIMIENTO.1), the appropriateness of such a claim is being discussed, where, according to the evidence provided by the parties, it will be resolved whether there was a lack of diligence on the part of the claiming party in the custody of the security mechanisms provided by the Bank."

The claiming party has indicated, regarding the status of the open judicial procedure, the following:

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

15/110

"1.- Criminal process: the instruction phase has recently concluded. The qualification writings have been requested.

2.- Civil process: trial scheduled for July 20, 2022."

Status in Credit Information Systems

The defendant states that the defaults that led to the inclusion of the claiming party's data in credit information systems stemmed from the loan contracts ***CONTRATO.1 and card ***CONTRATO.2 (card number ***TARJETA.1). To this end, it provides (EscritoReclamado#2) the following information:

- Screenshot from its systems showing that, for the loan, there is an unpaid balance of 4,466.27 euros with the first and last due dates being May 31, 2020, and December 9, 2021, respectively. It states that on September 6, 2020, it registered the debt in the BADEXCUG file (initial amount 937.37 euros) and on January 7, 2022, ordered its removal (removal amount 4,493.12 euros). It also indicates that on December 23, 2021, it registered the debt in the ASNEF file (initial amount 4,485.71 euros) and on January 7, 2022, ordered its removal (removal amount 4,485.71 euros).

- Screenshot from its systems showing that, for the card, there is an unpaid balance of 6,544.43 euros with the first and last due dates being May 5, 2020, and December 9, 2021, respectively. It states that on August 16, 2020, it registered the debt in the BADEXCUG file (initial amount 5,494.75 euros) and on January 7, 2022, ordered its removal (removal amount 6,607.46 euros). It also indicates that on December 23, 2021, it registered the debt in the ASNEF file (initial amount 6,590.06 euros) and on January 7, 2022, ordered its removal (removal amount 6,590.36 euros).

Regarding the reason why the claiming party's debts were included in credit information systems despite an ongoing judicial claim affecting them, the defendant states the following:

"Upon notification to BBVA of a lawsuit questioning the certainty of the debt, the attorney for the procedure has instructions to request: (i) the removal, as appropriate, temporary or definitive; (ii) request that the contract not be reported in credit information systems in the future. In this case, the removal or non-inclusion of the contracts is not requested due to a specific unintentional error."

It expresses, regarding the reason for the exclusion of the claiming party's data from the delinquency files, that it was requested "in the processing of the file that we are forwarded by the AEDP [sic]." The defendant provides a letter dated January 10, 2022, stating that on that date the claiming party's and her daughter's data are not ceded by BBVA to credit information systems.

According to the data provided by Equifax, as of June 14, 2022, there are no debts reported by the defendant concerning the claiming party in its files of

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

16/110

credit information. However, it does refer to the registration and subsequent removal of the following in ASNEF:

- Personal loan with operation code ***CONTRACT.1 with an unpaid balance of 4,485.71 euros. It

refers to 18 unpaid installments between May 2020 and December 2021. It specifies the registration and removal dates in ASNEF as December 23, 2021, and January 7, 2022, respectively. It records January 22, 2022, as the "viewing date."

- Credit card with operation code ***CONTRACT.2 with an unpaid balance of 6,590.06 euros. It refers to 7 unpaid installments between May 2020 and December 2021. It specifies the registration and removal dates in ASNEF as December 23, 2021, and January 7, 2022, respectively. It records January 22, 2022, as the "viewing date."

According to the data provided by Experian, there are no debts reported by the respondent in relation to the claimant in their credit information files. However, it does refer to the registration and subsequent removal of the following in BADEXCUG:

- Personal loan with operation code ***CONTRACT.1 with registration and removal dates in BADEXCUG on September 6, 2020, and January 7, 2022, respectively.

- Credit card with operation code ***CONTRACT.2 with registration and removal dates in BADEXCUG on August 16, 2020, and January 7, 2022, respectively.

Status of debt recovery procedures

According to the information provided by the respondent, the claimant's debt was assigned to Axactor for recovery on July 12, 2021. It also specifies that these were unassigned on November 16, 2021.

Axactor has confirmed the processing of the claimant's personal data on behalf of the respondent under the recovery services contract they have subscribed to. Regarding this, it provides the following information:

- It attaches the recovery services contract signed between the respondent and Axactor dated July 2, 2021. It includes the eighth general condition and annex 8.2 related to the processing of personal data. In this latter, it specifies that Axactor acts as the data processor for the respondent with access to customer data (name, surname, postal address, email, phone, and economic data) for the execution of the contract's provisions.

- It attaches the record of the categories of processing activities carried out by Axactor on behalf of the respondent, which includes information about the activity "Recovery of unpaid assets."

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

17/110

- It attaches the debt recovery files managed by Axactor for the respondent in which the claimant holds the position of debtor. They include the following:

- o File related to a personal loan of four thousand euros granted on April 12, 2020, with customer reference ***CONTRACT.1. It records the registration and removal dates of the file as July 15, 2021, and November 17, 2021, respectively. It contains the name, surname, address, and ID number of the claimant, as well as information related to the loan. It includes a single management entry dated September 10, 2021, titled "101 - Hello Letter. Request: (...). Address: ***ADDRESS.1. BarCode: (...).

- o File related to a credit card of 6,463.10 euros assigned with a debt start date of May 5, 2020, and customer reference ***CONTRACT.2. It records the registration and removal dates of the file as July 15, 2021, and November 17, 2021, respectively. It contains the name, surname, address, and ID number of the claimant, as well as information related to the debt. It does not include any management actions taken regarding this file.

- o File related to an overdraft of 74.23 euros assigned with a debt start date of May 4, 2020, and customer reference ***REFERENCE.1. It records the registration and removal dates of the file as July 15, 2021, and November 17, 2021, respectively. It contains the name, surname, address, and ID number of the claimant, as well as information related to the debt. It does not include any management actions taken regarding this file.

Among the information provided, it also states that Intrum would have accessed the claimant's data on behalf of the respondent. In this regard, it includes screenshots of the respondent's systems with the following information:

- File related to a debt amounting to 12,416.29 euros for the product "CREDIT CARDS" in a

"PROCESS COMPLETED" status as of November 18, 2021.

- On May 10, 2021, the first entry is recorded. The respondent states that on this date, "prejudicial procedure is initiated, and the card liquidation is attached."

- On November 18, 2021, the last entry is recorded. The respondent states that on this date, "the procedure is canceled due to the debt being less than 6,000 euros."

CONCLUSIONS

According to the information gathered, there are open judicial proceedings related to the facts investigated in these proceedings. One of the judicial proceedings was initiated following a lawsuit filed by the party.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

18/110

Claimant against the Respondent on September 1, 2020

(***PROCEDURE.1).

These preliminary investigation proceedings were initiated following a claim in which the claimant expresses that, after notifying the respondent that they were a victim of the theft of their handbag, the respondent did not act correctly, allowing third parties to impersonate their identity both by operating with their banking products and by contracting new products in their name. The claimant also states that, as a consequence of the operations carried out by the impersonators, the entity has demanded payment for certain debts through collection companies and has included their personal data in credit information systems. Among the information obtained, it is noted that the impersonators may have used both the claimant's phone line and their email address.

The claimant is a person who was a victim of theft while undergoing medical treatment at a nursing home facility. Communications with the respondent on behalf of the claimant to block their products and prevent identity theft were made, in addition to by the claimant themselves, by their daughter and by another person (their representative) on their behalf. This led to the various departments of the respondent (branch where they were a client, customer service department, etc.) proceeding in different ways when validating the representation capacity of these third parties of the claimant. The details of these issues have been included in a specific section of the inspection report.

The chronology of the events extracted from the documents submitted to this file has also been recorded in the corresponding section of the aforementioned inspection report. From it, the following relevant data is extracted to contextualize the facts:

- The "criminals," as observed, would have stolen belongings from the claimant that facilitated the identity theft: physical national identity document, mobile phone line, and credit card.

- The "criminals," as can be deduced from the information obtained, would have had access to the claimant's email inbox and online banking.

- On April 14, the claimant reported the theft to the referenced branch of the respondent, indicating that in addition to the card, their national identity document and phone had also been stolen, although they only requested the cancellation of their cards. The card that was operational was blocked on April 13 (someone communicated by phone beforehand). However, this card was subsequently unlocked, and the "criminals" were able to make transactions until April 30 (the respondent has not argued why the unlocking occurred).

Furthermore, the "criminals" would have operated with the claimant's products and contracted new products by impersonating their identity. The following are listed:

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

19/110

-

Loan subscribed on April 12, 2020 (prior to the communication of the theft to the respondent) for which a copy of the contract has been provided containing the personal data of the claiming party. The

respondent states that it was signed electronically at the request of the claiming party.

-

Card number ***TARJETA.1 of which the claiming party acknowledges they were the holder prior to the theft. A list is provided that includes charges incurred between April 11 and April 30, 2020. The respondent provides information indicating that a blocking operation was executed on April 13, 2020. It has not explained why charges occurred subsequently.

-

Account number ***CUENTA.1 of which the claiming party acknowledges they were the account holder prior to the theft. They state that the transactions made between April 17 and May 5, 2020, were carried out by impersonators. The respondent provides information indicating that a first blocking of the charges on this account occurred on May 4, 2020.

-

Account number ***CUENTA.2 of which the claiming party acknowledges they were the holder prior to the theft. They state that the transactions made between April 13 and May 4, 2020, were carried out by impersonators. The respondent provides information indicating that a first blocking of the charges on this account occurred on May 4, 2020.

-

Card number ***TARJETA.2 contracted on April 15, 2020 (on that date it is noted that the theft suffered was communicated to the branch, but the report to the security forces had not been provided) with the data of the claiming party and signed electronically at a distance. The respondent indicates that it was sent to the claiming party's address. A list is provided that includes charges incurred between April 17 and May 3, 2020. It is noted that the theft of the card was reported on June 16, 2020.

-

Card number ***TARJETA.3 contracted on April 15, 2020 (on that date it is noted that the theft suffered was communicated to the branch, but the report to the security forces had not been provided) with the data of the claiming party and signed electronically at a distance. The respondent provides information indicating that the contract is canceled with reference to May 4, 2020, as the blocking date.

-

Card number ***TARJETA.4 contracted on April 15, 2020 (on that date it is noted that the theft suffered was communicated to the branch, but the report to the security forces had not been provided) with the data of the claiming party and signed electronically at a distance. The respondent provides information indicating that the contract is canceled with reference to May 4, 2020, as the blocking date.

-

Account number ***CUENTA.3 (the claiming party cites "an account ending in XX" in an email dated September 9, 2020) subscribed on April 27, 2020.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

20/110

A copy of the contract containing the details of the claiming party is provided. It also states that it was signed remotely electronically.

The respondent has provided documentation outlining the procedures it follows in terms of fraud and scam prevention. This includes instructions for offices to register in the systems communications regarding theft or loss of clients' identification documents. It also includes the client's obligation to safeguard both the card and the "PIN" and to immediately report any incidents. It further indicates that in these cases, the immediate action is to block the card.

As a result of the actions previously described, some debts arose that the respondent recorded in credit information systems. The details of the registrations and subsequent exclusions can be consulted in the corresponding section of the inspection report. The exclusion, as stated by the respondent, was requested during the processing of the file transferred by the AEPD. Likewise, the respondent states that the procedure is to not include those debts whose certainty is questioned in a procedure, although in this case, there was "a specific unintentional error." It is also noted that the debts were assigned (and subsequently unassigned) to two recovery entities by the respondent.

FIFTH: On January 11, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against BBVA in order to impose fines totaling 1,640,000 euros, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged commission of the following infractions:

Three related to the specific case reported by the claimant:

- For the alleged infringement of Article 6.1 of the GDPR classified in Article 83.5 of the GDPR, in relation to the unauthorized contracting of products.

- For the alleged infringement of Article 32 of the GDPR classified in Article 83.4 of the same Regulation, for the lack of security measures regarding the communication, inclusion, and maintenance procedures in credit information systems of personal data.

- For the alleged infringement of Article 6.1 of the GDPR classified in Article 83.5 of the same Regulation, in relation to the incorporation of personal data into credit information systems.

And two related to the manner in which the procedures implemented by BBVA were established and revealed through the information provided by the financial entity during the investigation:

- For the alleged infringement of Article 25 of the GDPR classified in Article 83.4 of the same Regulation.

- For the alleged infringement of Article 32 of the GDPR classified in Article 83.4 of the same Regulation, for the lack of security measures regarding the procedures for contracting financial products.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

21/110

In the aforementioned initiation agreement, BBVA was informed that it had a period of ten days to submit allegations.

This initiation agreement, which was notified to BBVA in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on January 13, 2023, as evidenced by the acknowledgment of receipt in the file.

SIXTH: On January 13, 2023, BBVA submitted a document requesting an extension of the deadline to present allegations, a copy of the documents in the file, as well as clarification regarding the amount of the sanction.

SEVENTH: On January 26, 2023, the Director of this Agency issued a resolution correcting errors, by which the error detected on page 42 of the initiation agreement of the present procedure was corrected, granting BBVA a new period of ten working days to formulate allegations and propose any evidence it deems appropriate, and granting a new period of ten days for the voluntary payment of the sanction.

The aforementioned resolution was notified to BBVA on January 27, 2023, as evidenced by the acknowledgment of receipt in the file.

EIGHTH: On January 26, 2023, the secretary of the procedure issued an agreement to send BBVA a copy of the file.

The aforementioned agreement was notified to BBVA on January 30, 2023, as evidenced by the acknowledgment of receipt in the file.

NINTH: On February 10, 2023, a document from BBVA was received in this Agency, in due time and form, in which, on the one hand, allegations were made regarding the initiation agreement concerning the alleged infringement of Article 25 of the GDPR and the alleged infringement of Article 32 of the GDPR for lack of security measures regarding the procedures for contracting financial products, and, on the other hand, responsibility was accepted for the commission of the following infractions recorded in the initiation agreement related to the specific case claimed before the Agency that led to the investigation:

- The infringement of Article 6.1 of the GDPR classified in Article 83.5 of the GDPR, in relation to the unauthorized contracting of products.

- The infringement of Article 32 of the GDPR classified in Article 83.4 of the same Regulation, for the

lack of security measures regarding the communication, inclusion, and maintenance procedures in credit information systems of personal data.

- The infringement of Article 6.1 of the GDPR classified in Article 83.5 of the same Regulation, in relation to the incorporation of personal data into credit information systems.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

22/110

TENTH: On July 13, 2023, the instructing body of the procedure agreed to open a period for the practice of evidence, considering the claim filed by the claimant and its documentation, the documents obtained and generated during the admission phase of the claim, and the report of prior investigative actions that are part of the procedure AI/00068/2022 as incorporated for evidentiary purposes. Furthermore, the allegations to the initiation agreement of the referenced sanctioning procedure presented by BBVA were considered reproduced for evidentiary purposes, along with the accompanying documentation.

Finally, the judgment submitted by the claimant, issued by the Court of First Instance No. 10 of Barcelona dated ***DATE.1, with ***JUDGMENT.1, was also considered reproduced for evidentiary purposes.

On the same day, July 13, 2023, this Agency requested BBVA to submit the following information within ten business days:

1) The data protection impact assessment (hereinafter DPIA), dated and signed, regarding the processing of personal data of BBVA customers in relation to "REMOTE BANKING MOBILE PHONE/CARD," valid as of April 14, 2020, the date on which the claimant's daughter reported the theft suffered by the claimant ("mobile phone, wallet, cards, etc."), as well as all documentation prior to the DPIA that reflects the necessity of the decision to carry out the DPIA; it is also required to provide all documentation prepared in connection with the DPIA and justifying the results obtained in the DPIA and the measures adopted in this regard, including documentation related to the participation of BBVA's Data Protection Officer in its preparation.

In the event that it was deemed unnecessary to carry out a DPIA, the justifying documentation (dated and signed) outlining the reasons why BBVA considered it was not obliged to conduct the DPIA, including documentation related to the intervention of the Data Protection Officer where their opinion on this matter was expressed. In such a case, provide the supporting documentation of the risk analysis carried out, including all documentation prepared, justifying the results obtained and the measures adopted.

2) Dated and signed documentation regarding the technical and organizational measures that BBVA had planned as of April 14, 2020, to prevent fraud by identity theft, specifically in operations through "REMOTE BANKING MOBILE PHONE/CARD," when the identity document, mobile phone (where BBVA sends the authentication factor), or credit cards have been stolen, and this circumstance has been communicated by the customer.

3) Dated and signed documentation regarding the technical and organizational measures that BBVA had implemented as of April 14, 2020, so that communications made to the entity by its customers regarding the loss, misplacement, or theft of the identity document, mobile phone (where BBVA sends the authentication factor), or credit cards, would take effect across its various customer relationship channels related to the operations that the customer may carry out.

The aforementioned agreement was notified to BBVA on July 14, 2023, as recorded in the acknowledgment of receipt in the file.

Currently, there is no record in the AEPD that BBVA has submitted a written response to this Agency's request for information.

ELEVENTH: Attached as an annex is a list of documents in the procedure.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: At the beginning of April 2020, the claimant had two accounts open at BBVA, account No.

***ACCOUNT.1 and account No. ***ACCOUNT.2, in addition to a credit card, number ***CARD.1.

SECOND: According to judgment ***JUDGMENT.1 of ***DATE.1, issued by the Court of First Instance No. 10 of Barcelona, on April 10, 2020, while residing in the facility (...), the claimant was a victim of the theft of their handbag, which contained, among other things, the mobile phone, the national identity document, and credit card number ***CARD.1.

THIRD: On April 12, 2020, a loan with operation code ***CONTRACT.1 was contracted with BBVA for an amount of 4,000 euros. BBVA provides a copy of the contract, which includes the name, surname, address, and ID number of the claimant. It states that it was electronically signed at the request of the claimant through the "REMOTE BANKING MOBILE PHONE/CARD" channel on April 12, 2020.

FOURTH: On April 13, 2020, the claimant requested BBVA to block their card number ***CARD.1 upon realizing its theft, as detailed in the complaint. On the same day, BBVA proceeded to block the card immediately, exactly at 18:07.

FIFTH: On April 14, 2020, the following email exchange occurred between the claimant's daughter and BBVA:

- From the email address of the claimant's daughter ***EMAIL.2 (page 257 of the file), the following message was sent:

"Hello

I am writing to you from the USA

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

24/110

Yesterday my mother was robbed at the residence where she is receiving treatment for cancer; her mobile phone, wallet, and cards, etc. were taken. Please urgently cancel all her cards; I believe she has 2, but I do not have the numbers with me here.

Where can I call you???

Thank you

--

B.B.B." (the underlining is ours).

- From the email ***USUARIO.1@bbva.com, the following message was sent:

"Good morning B.B.B.

I have just seen your email.

She only has one card, and I see that yesterday, 04/13/2020 at 18:06, it was blocked. Did you call the BBVA contact center???

What I see is that there are various charges through online banking that I assume she did not make.

I am attaching the charges made for you to take a look... If they are not correct, we need a report from the Mossos to process the fraud claim.

I hope she is doing well.

Best regards,"

- From the email ***EMAIL.2, the following message was sent:

"Hello everyone,

I am sending this email to connect E.E.E. and F.F.F. from BBVA with G.G.G., Director of the residence (...) where my mother is, and D.D.D., a family member involved in my mother's care, as I am in the USA.

E.E.E., I am attaching all the contact information so that you can communicate directly, as I am in the USA with a 7-hour time difference.

To keep everyone informed, please know that G.G.G. is processing the report with the Mossos, and if all goes well, it can be finalized tomorrow.

There were documents that G.G.G. is obtaining.

The banking information sent by you E.E.E. has been forwarded to G.G.G. and the Mossos, so that the administrative process can be initiated properly.

Additionally, the residence needs to have the times when the card was used because we realized by looking at the statements that her card was stolen a few days before her mobile was stolen. This

means that the person who did this acted at two different times.

Therefore, I kindly ask you E.E.E. to log into the bank system tomorrow and look for more details on the VISA card transactions. This way, the residence can define more precisely the viewing of all the security cameras in the clinic, within the framework of the internal investigation they are conducting. It is very possible that the person who committed the theft is still working there at this time.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

25/110

I thank you all in advance for your cooperation, and I hope that direct communication, not through me, will be easier.

Best,

B.B.B.”

SIXTH: On April 14, 2020, the identity of the claimant was impersonated before BBVA in carrying out transactions on Account number ***CUENTA.2, an account whose ownership was recognized by the claimant prior to the theft.

SEVENTH: On April 15, 2020, the identity of the claimant was impersonated before BBVA, with the contracting of the following products:

- Card number ***TARJETA.2 linked to contract ***CONTRATO.3. BBVA provides a copy of the contract, which includes the name, surname, and ID number of the claimant, and states that the application for the card was electronically signed through the “REMOTE BANKING MOBILE PHONE/CARD” channel. This card was blocked on July 6, 2020. Furthermore, the card is listed as lost and the contract is in a canceled state.

- Card number ***TARJETA.3 linked to contract ***CONTRATO.4. BBVA provides a copy of the contract, which includes the name, surname, ID number of the claimant, and the email ***EMAIL.1. It states that it was electronically signed at the request of the claimant through the “REMOTE BANKING MOBILE PHONE/CARD” channel. BBVA provided a screenshot from its systems (page 439 of the file) indicating that the contract is canceled with reference to May 4, 2020, as the blocking date.

- Card number ***TARJETA.4 linked to contract ***CONTRATO.5. BBVA provides a copy of the contract, which includes the name, surname, ID number of the claimant, and the email ***EMAIL.1. It states that it was electronically signed at the request of the claimant through the “REMOTE BANKING MOBILE PHONE/CARD” channel. BBVA provided a screenshot from its systems (page 439 of the file) indicating that the contract is canceled with reference to May 4, 2020, as the blocking date.

EIGHTH: On April 16, 2020, from the email ***USUARIO.2@bbva.com, the following message was sent to the email ***EMAIL.2:

“Good morning B.B.B.,

I hope you are all well regarding the coronavirus situation in the USA, as I see it is spreading a lot everywhere.

I am very sorry for what happened to your mother; the first thing we need to do is file the report with the “Mossos d’esquadra” as urgently as possible. Who will file the report?? I understand that it will be filed by the Director of the Residence, right?? As soon as she has it, please send it to us.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

26/110

From here, an investigation will be opened to see what has happened. Regarding the transfers, we can do nothing but wait for the investigation. For any matter, please give my phone number ***TELÉFONO.2 to the director of the Residence so that she can contact me and we can process all of this correctly and as quickly as possible.

Best regards.” (the underlining is ours)

NINTH: On April 17, 2020, the representative of the claiming party, from the email ***EMAIL.3, sent a message (page 203 of the file) to the email of the director of the branch ***USUARIO.2@bbva.com in

which she introduces herself and states that she is attaching the complaint filed on April 16, 2020, with the Mossos d'Esquadra.

The complaint is filed by D.D.D. on behalf of the claiming party. She attaches a document in which (...) the claiming party authorizes D.D.D. to file the complaint on behalf of the claiming party and (...). The complaint is filed against the nursing home where the claiming party was located when the theft of her belongings occurred. In the complaint (page 532 and following of the file), the following is stated:

"...Mrs. A.A.A. states that she feels strange and that, moreover, her belongings have been stolen in the residence: + the mobile phone + a square zip wallet where she had her credit card, ID, driver's license, and health card..."

...In summary, the reported facts are as follows: in the time period between April 10, 2020, and April 13, 2020, someone from the residence has committed several thefts from Mrs. A.A.A., both of cash and of the card, withdrawing money from the account and from the line of credit, as well as other essential personal documentation, also from her mobile phone, with a known accumulated value as of today exceeding 13,500 Euros. Everything points to the fact that, during this weekend from April 11 to April 13, 2020, she was sedated or anesthetized, as she told me that, in the last two or three days, she felt strange, like dizzy, something she had never expressed before, despite the medication she was taking..."

In the complaint itself, it is mentioned that they contacted the respondent and that he informed them that money had been withdrawn with the card prior to the email notification of the theft to BBVA on April 14, 2020.

TENTH: On April 17, 2020, the identity of the claiming party was impersonated in carrying out operations on Account number ***CUENTA.1, which BBVA specifies is not canceled.

ELEVENTH: On April 20, 2020, from the email ***USUARIO.2@bbva.com, a message was sent to the email of the representative of the claiming party ***EMAIL.3, in which it is communicated that the complaint filed by the claiming party on April 16, 2020, has been forwarded to the security and fraud department.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

27/110

TWELFTH: On July 26, 2020, in response to the information request made by this Agency, BBVA provided a document dated April 27, 2020, regarding the contracting of Account number ***CUENTA.3, which BBVA specifies is not canceled. BBVA provided a copy of the contract, which includes the name, surname, address, and ID of the claiming party. It states that it was electronically signed at the request of the claiming party through the "REMOTE BANKING MOBILE PHONE/CARD" channel. Additionally, BBVA cites other details of the contracting (IP address and validation in the respondent's "app" via fingerprint).

THIRTEENTH: On April 30, 2020, from the email ***USUARIO.2@bbva.com, a message was sent (page 205 of the file) to the email of the representative of the claiming party ***EMAIL.4, with a copy to ***EMAIL.3 and ***EMAIL.2, with the following content (unofficial translation, original in Catalan):

"Good morning D.D.D.,

According to our phone conversation this morning at 12:22, we received a call from the phone ***TELÉFONO.1 pretending to be A.A.A., identifying herself with the corresponding ID number and requesting to register the mobile phone in the database to access Online Banking. Obviously, this operation cannot be done by phone, and we have communicated this to them, so that they can go to the BBVA office to carry out these procedures. And check what happens with the phone since it remains active.

Regards"

On May 1, 2020, D.D.D., on behalf of the claiming party, filed an extension of the complaint with the Mossos d'Esquadra (page 578 of the file) regarding the facts stated by the office director on April 30, 2020.

FOURTEENTH: On May 5, 2020, the claiming party submitted a document addressed to Telefónica de

España, S.A., requesting the cancellation of the claiming party's mobile number ***TELÉFONO.1. She states that they have attempted to do so unsuccessfully since April 14, following the date of the document.

FIFTEENTH: On May 6, 2020, the lawyer for the claiming party sent a document to BBVA (page 115 of the file) in which she requests that they immediately:

“1st).- Stop, annul, and reverse any banking operation that has been carried out or attempted to be carried out from the mobile line ***TELÉFONO.1 against any account or banking product of my clients at BBVA, since April 10, 2020.

2nd).- Stop, annul, and reverse any banking operation that is attempted in any way (in person, by phone, online, etc.) against any account or banking product of my clients at BBVA, since April 10, 2020.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

28/110

3º).- Freeze and do not process any banking operation attempted in any manner (in-person, by phone, online, etc.) against any account or banking product of the company linked to my clients (...). This is due to the fraudulent theft of credit card and mobile phone from Ms. A.A.A., which occurred between April 10 and April 13, 2020, at the residence (...) in Barcelona, duly reported to the police on April 16, 2020, and considering that all verbal and written requests directed since April 14, 2020, to the director of the BBVA Office at ***ADDRESS.2, ***CITY.1, have gone unanswered by BBVA, a fact that has allowed the criminals to continue operating from the stolen mobile phone and card.

We also inform you that we will hold BBVA responsible for all damages caused to my clients, since they were notified of the total freeze order on April 14, 2020, onwards, for all fraudulent operations that the offenders have carried out and continue to carry out against the assets of my clients, as such criminal operations could not have been consummated if BBVA had properly attended to our Total Freeze Order issued on April 14, 2020.” (the underlining is ours)

SIXTEENTH: On May 9, 2020, the representative of the claimant party sent a communication to BBVA (page 213 of the file) requesting the return of the amounts stolen from the claimant party and her daughter between April 13 and May 5, 2020.

SEVENTEENTH: On May 15, 2020, the claimant party signed a document (addressed to BBVA) in which, as the holder of the card ***CARD.1, she reports the incident (theft) and requests the return of the amount of a set of transactions that she lists. The list includes charges made between April 11 and April 30, 2020, and the following comment:

“Customer states that she is in a confined nursing home and that her bag with all her belongings inside, including the cards, has disappeared. Her identity has been impersonated several times this month, allowing access to online banking.” (the underlining is ours)

EIGHTEENTH: On May 20, 2020, BBVA responded (page 226 of the file) to the document sent by the representative of the claimant party dated May 6, 2020, requesting accreditation of the representation under “art. 12 of the Regulation for the Defense of the Customer in Spain of the BBVA Group, which requires the identification and signature of the holders, and where applicable, of the person representing them, duly accredited.” In that same document, it is stated that the accreditation of the representation can be carried out by sending a signed document containing the full name, NIF, complete address, and signature of both the representative and the represented.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

29/110

NINETEENTH: On May 21, 2020, the claimant requested from the Court of Instruction No. 33 of Barcelona (in the context of the Preliminary Proceedings (...)) the precautionary measure consisting of requesting the cancellation of the line ***PHONE.3. This (page 268 of the file) was due to the fact that “the investigated parties had changed the phone associated with Ms. A.A.A.'s policy to the new phone they were using to commit crimes, which BBVA had already confirmed to us.”

TWENTIETH: On May 29, 2020, the Court of Instruction No. 33 of Barcelona requested, in the context of the Preliminary Proceedings (...) (page 282 of the file) that BBVA block access through non-presential means to all products of the claimant, following a complaint filed by the claimant for the alleged commission of a crime of theft, fraud, and usurpation of civil status.

Additionally, it requests, in the context of the Preliminary Proceedings (page 283 of the file) referenced to Movistar, to block the phone numbers associated with the claimant ***PHONE.1 and ***PHONE.3. Furthermore, it requests the details of the person who registered the line ***PHONE.3.

TWENTY-FIRST: On June 4, 2020 (page 215 of the file), an email from ***EMAIL.5 was sent to the emails "servicioatencioncliente@grupobbva.com" and "defensordelcliente@grupobbva.com", stating the following:

"In relation to your communication dated May 20, 2020, received by regular mail, in which you request that I identify myself as the Lawyer of Ms. A.A.A. and Ms. B.B.B., I proceed to fulfill your request by sending you the following documentation: a notice of appearance, dated May 14, 2020, submitted electronically to the Court of Instruction No. 33 of Barcelona, in the Preliminary Proceedings No. (...), with a signature verification from all the individuals appearing therein, which certifies my clients' intention to appoint me as their lawyer in this procedure, for all purposes, as well as a subsequent document dated May 18, 2020.

Additionally, I am sending you correspondence maintained with the Director of the BBVA Office in ***LOCALITY.1, Mr. F.F.F., who has received both verbal and written instructions from Ms. B.B.B. to communicate with me in my capacity as the Lawyer for these ladies. Finally, I am copying Ms. B.B.B. and also Mr. F.F.F., Director of the indicated Office, who will confirm by email that I am acting as the Lawyer for Ms. B.B.B. and Ms. A.A.A. for all purposes, as evidenced since mid-April 2020."

Moreover, on the same day, June 4, 2020 (page 219 of the file), an email from ***EMAIL.2 was sent to "servicioatencioncliente@grupobbva.com" and "defensordelcliente@grupobbva.com", containing the message transcribed in the two previous paragraphs and stating, in relation to said email, the following:

"Hereby, we confirm the statements made below by our lawyer C.C.C.."

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

30/110

TWENTY-SECOND: On June 8, 2020, an email was sent from ***EMAIL.3 to BBVA (page 208 of the file), to the addresses ***USUARIO.2@bbva.com and ***USUARIO.3@bbva.com, requesting the reimbursement of charges made between April 11 and April 30 to the claiming party.

On June 16, 2020, another email was sent with the same request (page 209 of the file).

TWENTY-THIRD: On June 16, 2020, the claiming party signed a document (page 346 of the file) addressed to the respondent, in which, as the holder of the card ***TARJETA.2, they report the incident and request the refund of the amount for a set of transactions that they list. The list includes charges incurred between April 17 and May 3, 2020. It includes the comment:

"The client states that they are confined in a nursing home and that their bag containing all their belongings, including the cards, has gone missing. Their identity has been stolen several times this month, allowing access to online banking." (the underlining is ours)

TWENTY-FOURTH: On July 2, 2020, the representative of the claiming party sent an email to BBVA (page 326 of the file) summarizing the events that had occurred to date regarding the claiming party and their daughter. They mention the theft of money that occurred since April 12 and express that the criminals would have associated telephone lines with the products of the defrauded through identity theft. In the email, they also identify one of the criminals and request that "they prevent further access to the same by third-party criminals impersonating my two clients." They also require that "they refrain from registering any new banking or financial products associated with the personal and banking data of my clients, as it is not them but a gang of criminals who are requesting it." (the underlining is ours)

TWENTY-FIFTH: On July 2, 2020, the representative of the claiming party signed a document (page 127 of the file) which they sent via burofax to the respondent requesting protection against identity theft for their clients, that no new products be contracted in their name, and the payment of the

amounts claimed in the letter dated May 9.

BBVA stated that it received this burofax on July 3, 2020.

TWENTY-SIXTH: On July 13, 2020 (page 111 of the file), BBVA requested the claiming party to pay the debt arising from the overdraft of contracts ***CONTRATO.1 and ***CONTRATO.2, warning of the possibility of registration in credit information systems.

The claiming party has attached to the extension of the claim submitted to this Agency the letter from BBVA (pages 136 and 137 of the file) in which they communicate the existence of two debts related to contracts ***CONTRATO.1 and ***CONTRATO.2 that have been communicated to the collections area. Additionally, they inform of

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

31/110

that certain, due, enforceable, and unpaid debts whose payment has been requested may be communicated to credit information systems.

TWENTY-SEVENTH: On July 17, 2020, the representative of the claimant submitted a document (pages 356 to 359 of the file) to the Court of Instruction No. 33 of Barcelona (in the context of the Preliminary Proceedings (...)) in which a set of documents recovered by the security forces from third parties during an operation is provided to the Court. Among the recovered documents is personal information (ID number, address, phone number, bank accounts) of the claimant.

TWENTY-EIGHTH: On July 28, 2020 (page 200 of the file), the daughter of the claimant sent an email to BBVA (to the branch manager's address, ***USUARIO.2@bbva.com) requesting the unlocking of the claimant's account "ending in XX" in order to transfer the balance to another account, belonging to the daughter of the claimant, "ending in XXXX" so that "my mother can access her money to live." (page 322 of the file)

TWENTY-NINTH: On July 30, 2020 (page 210 of the file), the daughter of the claimant directed an email to BBVA (to the branch manager) requesting, among other matters, the closure of accounts ***CUENTA.1 and ***CUENTA.2 and the cancellation of cards ***TARJETA.1 and ***TARJETA.2 of the claimant.

THIRTIETH: On August 4, 2020, the Customer Service of BBVA responded via email to the representative of the claimant with a letter in response to the communication received on July 3 (page 128 of the file). In this, they again request the accreditation of the representation to act on behalf of the claimant. They indicate that this can be done by sending a signed document containing the full name, tax identification number, complete address, and signature of both the representative and the represented party.

THIRTY-FIRST: On August 4, 2020, the representative of the claimant directed an email to BBVA (page 374 of the file) in which she states that she attaches the powers granted in her favor. She also provides a simple copy of the power of attorney deed with special powers granted before a notary by the claimant and the daughter of the claimant in favor of the representative of the claimant.

THIRTY-SECOND: Between August 16 and September 6, 2020, the respondent registered two debts (corresponding to the loan contracts ***CONTRATO.1 and card ***CONTRATO.2 - card number ***TARJETA.1) associated with the claimant in the credit information file "Badexcug/Experian" (pages 403 and 404 of the file).

THIRTY-THIRD: On September 3, 2020, the claimant and her daughter filed a lawsuit for ordinary proceedings (page 6 of the file) against the respondent that contains the description of the facts.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

32/110

According to what is stated in the response to the information request made by this Agency (page 122 of the file), on September 22, 2020, the Court notified BBVA of the lawsuit ("Ordinary Procedure ***PROCEDIMIENTO.1").

THIRTY-FOURTH: On September 8, 2020, Experian sent a letter to the claimant informing them of the

inclusion of a debt arising from a personal loan by the respondent in the Badexcug file (page 397 of the file).

THIRTY-FIFTH: On September 9, 2020, the daughter of the claimant sent an email to the respondent (page 130 of the file) in response, as cited, to two previous communications. In said email, after requesting certain information, the following requests are reiterated:

"1. Immediate closure of the two bank accounts opened in my mother's name ***CUENTA.1 and ***CUENTA.2.

2. I also request the immediate cancellation of the two cards no. ***TARJETA.1 and no. ***TARJETA.2.

3. I request that you transfer to me, within the next 48 hours, the amount of 6,090.14 euros taken by the criminals, to the account opened in my name, whose IBAN number is the one I already indicated in a previous email, ending in XXXX.

4. Finally, I request that you confirm that your entity will assume all the debt generated in the past and that will be generated in the future, due to the acts committed by the criminals, using both my mother's banking products and my personal ones."

Additionally, she indicates to the financial entity that she finds it "incredible that BBVA places my mother in a delinquent file for a debt that you know perfectly well she did not generate, but rather that it was generated by the criminals and BBVA. I request that you contact your Legal Department to resolve this issue and remove my mother from the delinquent file immediately."

THIRTY-SIXTH: On September 21, 2021, the claimant submitted to the Court of First Instance No. 10 of Barcelona an extension of the lawsuit concerning "****PROCEDIMIENTO.1" (page 43 and following of the file) in which it is stated that the entity AXACTOR on behalf of the respondent has contacted the claimant to manage an outstanding debt and attaches a copy of the letter.

THIRTY-SEVENTH: On October 2, 2020 (page 132 of the file), BBVA responded via email to the daughter of the claimant attaching a letter dated September 29, 2020.

In the letter, they request proof of the representation of the claimant in order to act on the products in which she is listed as the sole holder.

Furthermore, regarding the products in the name of the daughter of the claimant, they request more specificity regarding the amount subject to fraud, as well as the police report made.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

33/110

THIRTY-EIGHTH: On November 2, 2020, the claimant submitted to the Court of First Instance No. 10 of Barcelona an extension of the claim regarding "****PROCEDIMIENTO.1" (page 27 and following of the file) in which it is stated that the respondent has continued to demand amounts corresponding to acts carried out by the criminals and has included the claimant in a "delinquent file."

THIRTY-NINTH: On December 24, 2021, Equifax sent a letter to the claimant (page 110 of the file) informing that BBVA, on December 23, 2021, requested the inclusion of two debts in the credit information file "ASNEF/Equifax" for the concepts of "personal loans" and "credit cards."

FORTIETH: On January 5, 2022, the claimant sent a communication to the respondent (page 108 of the file) in which, regarding the request for payment of the debts, it refers to the existence of a lawsuit ("****PROCEDIMIENTO.1") filed on September 1, 2020, requesting a judicial declaration for the closure and cancellation of bank accounts and credit cards and for the exemption from any debt for any concept arising from them since April 10, 2020, onwards. It states that this process is pending scheduling for trial. It also states that the debt is not attributable to the claimant and requests the cancellation of their personal data in all files to which they have been transferred (including delinquent files).

FORTY-FIRST: On January 5, 2022, the claimant sent a communication to Equifax (page 108 of the file) in which, regarding the inclusion of the debts in the ASNEF file, it indicates that there is a lawsuit ("****PROCEDIMIENTO.1") filed on September 1, 2020, requesting a judicial declaration for the closure and cancellation of bank accounts and credit cards and for the exemption from any debt for any concept arising from them since April 10, 2020, onwards. It states that this process is pending

scheduling for trial. It also states that the debt is not attributable to the claimant and requests the removal of the claimant's personal data from Equifax's files.

FORTY-SECOND: In the judgment ***SENTENCIA.1 of ***FECHA.1, issued by the Court of First Instance No. 10 of Barcelona, in the ordinary trial regarding the claim for amounts with No.

***PROCEDIMIENTO.1, filed at the request of DOÑA A.A.A. and DOÑA B.B.B. against BANCO BILBAO VIZCAYA ARGENTARIA, S.A., the following is indicated in its Fourth Legal Ground:

"FOURTH. Taking into account the applicable regulations, the chronological sequence presented, and also the testimony of Ms. D.D.D., it is inferred that Ms. A.A.A. had her wallet stolen with all documentation and credit cards on April 10, 2020, C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es

34/110

although they did not become aware of it until April 13 or 14, when the complaint was filed with the Mossos d'Esquadra by the Director of the Residence, along with the corresponding subsequent extensions that were made as they realized that those who had in their possession the personal and banking documentation of Ms. A.A.A. were impersonating her identity.

Therefore, it is established that as soon as knowledge of the theft of the cards was obtained, the entity BBVA was informed to proceed with blocking them. This is evident from the response given by BBVA on April 14, 2020, document 8 of the complaint when responding to Ms. B.B.B. "You only have one card and I see that yesterday 13/04/2020 at 18:06 it was blocked. Did you call the BBVA contact center??? What I see is that there are various charges through online banking that I suppose she did not make. I am attaching the charges made for you to take a look... If they are not correct, we need a complaint from the Mossos to process the fraud report." And this is evident from the documentation in the Preliminary Proceedings, where the Banking entity informs Ms. D.D.D. that "the online cancellation is on 16/04" and provides her with the updated data and the operations carried out, including an online loan on 12/04, for the amount of €4,000 and the issuance of a card on 15/04 (p. 34 of the testimony D.Previous (...)).

At least since April 14, 2020, BBVA was aware of the theft suffered by Ms. A.A.A.

Ms. A.A.A. fulfilled her obligation to immediately report the theft of her cards and her ID number, so all charges incurred with the cards whose cancellation was requested on April 14, 2020, must be refunded to Ms. A.A.A., as she fulfilled her obligations, and if the criminals used them with impunity, it must be attributed to a lack of diligence on the part of the banking entity, as it had been warned of the events, given that according to the emails sent by the Director of the branch in ***LOCALIDAD.1, it is evident that he was aware of the identity theft, and he warns Ms. D.D.D. and the attorney for the plaintiffs when sending the email on April 30, 2020, submitted as document 25.4 of the complaint, in which he states

"Good morning D.D.D.,

According to our telephone conversation this morning at 12:22, we received a call from phone ***TELÉFONO.1 impersonating A.A.A., identifying himself with the corresponding ID number and requesting to register the mobile phone in the database to access Online Banking. Obviously, this operation cannot be done over the phone, and we have communicated this to them, so they need to come to the BBVA office to carry out these procedures. And see what happens with the phone since it remains active.

Regards

From this email, it is evident not only that the banking entity, or at least the director of the branch in ***LOCALIDAD.1, where Ms. A.A.A. resides, who was in Barcelona for oncological treatment, was aware not only of the theft of the cards but also of the mobile phone of Ms. A.A.A. and the identity theft, which is why he contacted the daughter of Ms. A.A.A., the co-plaintiff, Ms. B.B.B., to warn her of the attempt to access Online Banking." (the underlining is ours)

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

35/110

Therefore, it is established, as indicated by the aforementioned judgment, that at least since April 14,

2020, the entity BBVA was aware of the theft suffered by Ms. A.A.A., that she had fulfilled her obligation to immediately report the theft of her cards and her D.N.I., and that there was a lack of diligence on the part of the banking entity, as, having been warned of the events, the criminals used them with impunity.

Not only was the financial entity aware of the theft of the cards, but also of the claimant's mobile phone, which allowed for the impersonation of her identity (according to the emails sent by the Director of the ***LOCALIDAD.1 branch).

FORTY-THIRD: On July 23, 2022, received in the AEPD registry on July 26, 2022, BBVA submitted a written response to the request for information and documentation made by the AEPD, to which it attached several documents, of which we highlight:

Document 1: This document consists of an email sent from the email address

***USUARIO.3@bbva.com (page 308 of the file). As described in this document, on April 13, 2020, at 18:06, the Entity blocked card number ***TARJETA.1 linked to contract number ***CONTRATO.2.

Despite the fact that on April 13, 2020, the bank card of the claimant was blocked, according to the respondent, after this blocking, the claimant provided a list that includes charges made between April 11 and April 30, 2020. In the complaint filed before the court, it states that the bank "has acknowledged responsibility for the transactions made in relation to said card for an amount of 5,559.88 euros."

Document 2: These are two copies of two burofaxes dated May 6, 2020, and May 9, 2020, respectively, through which the claimant communicated to the respondent that, despite having reported the theft of the cards and mobile terminal to the bank, several amounts of money had been withdrawn from the claimant's account after this communication, using her identity, and requested that any operation carried out with the claimant's mobile phone "or against any account or banking product of the claimant at BBVA before April 10, 2020, the date on which the theft occurred, be halted, canceled, and reversed."

Document 3: This document 3 is titled "PREVENTION OF FRAUD AND SCAM," dated June 1, 2015, and is the procedure used by the respondent for contracting cases. The summary of its content indicates that it refers to "Instructions for the prevention of fraud related to both general aspects and specific procedures according to the modality of the fraud. Security opinions on fraud cases and other considerations on fraud prevention issues." In this document, it states:

"One of the keys to the client-financial entity relationship is the trust that must be established.

Undoubtedly, from that point of view, attacks on the security of certain products or services can undermine this principle [...]

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

36/110

The defense of trust in processes, the preservation of the reputation of the entities themselves, given that fraud negatively affects their image, and the prevention of losses that, once incurred, are, in most cases, irrecoverable, make it necessary to enhance prevention in this field through the issuance of regulations and training actions [...]

This regulation aims to disseminate basic monitoring measures that can allow for the detection and prevention of the vast majority of frauds that occur, with minimal effort. This effectiveness is conditioned by an undeniable fact: the world of fraud is in constant change, and procedures are continually perfected by criminals, which means that information must be updated permanently.

If an adequate preventive level is achieved, the opinion within the criminal community will spread that the BBVA group adopts appropriate measures that hinder fraud, which, as a secondary but no less important effect, will tend to decrease attempts and risks of future attacks. [...]

2. Security

2.1. Introduction

2.1.1. Concepts

Below, we will outline some of the concepts that will be handled later in order to unify criteria in this matter: [...]

Identity Theft:

Linked to the precautions regarding identification, there is identity theft. In most cases, observing the recommendations given regarding identifying false or manipulated IDs and conducting some verification through questions only known to the holder or a call to the customer's phone number listed in our database will be sufficient to unmask the majority of attempts.

However, another aspect to consider is that, on some occasions, this action is carried out by abusing a hypothetical relationship of trust, for example, when a person presents themselves to carry out some operation with documentation belonging to another person without that person being present.

It should be noted that cases of scams against direct relatives, manipulation of accounts of deceased relatives (in some cases for tax reasons), or the improper manipulation of accounts due to inheritances, etc., are not uncommon. If the bank does not operate correctly, it may incur serious liability, so these practices should not be carried out. It is also worth mentioning the use of impersonation to obtain information (account numbers, balances, etc.) that is then used to commit fraud through, for example, fraudulent withdrawals. Therefore, precautions regarding identification must be heightened when providing certain data. [...]

Transactions without the physical presence of the card.- In these cases (internet purchases and mail/telephone sales), it is the merchant who contractually assumes responsibility, except in the case of secure commerce with authentication of the holder. This does not exempt us from paying attention to this type of fraud as it indirectly affects the reliability of this product and, consequently, its use and profitability. [...]

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

37/110

Identification Document (ID): This is the document that allows for the reliable verification of a person's identity, which includes some security measure to prevent alteration and/or manipulation and incorporates a photograph of the holder. It must be original (not a photocopy) and valid. Further specifications are provided below. [...]

Security Measures:

These are the elements that, incorporated into a document (identification, payment, ticket, etc.), allow it to be identified as genuine and, therefore, distinguish it from a false or manipulated one. [...]

2.2.2. How to Act

It should not be forgotten that fraudsters often try to pressure the employee, make them nervous, or demand all kinds of urgencies for various reasons that are not always clearly justified. They do this so that their victim makes a mistake, allowing them to seize their loot. One should never fall into their trap and should always act calmly. At the slightest doubt, and to feel more supported, one should consult with colleagues, the Security Delegate in the Territory, or Banking Security-Fraud Prevention.

As a general rule of great importance, in case of the slightest doubt, legible photocopies of the Identification Document (both front and back if it is an ID card or similar) must always be made, in addition to the cases specified later, in which the photocopy must necessarily be made. In the event that fraud is consummated and in cases determined as such, the corresponding complaint will be filed, formulated with the advice and support of the Security Delegate in the Territory. [...]

2.2.3. Identification Precautions

Correct identification of the client, whether an individual or a representative of a legal entity, is fundamental for the early prevention of fraud.

Identification Documents:

The only valid documents for correct identification are:

- * National Identity Document.

- * Passport.

- * Foreign Identification Number (NIE), with its various types of Cards (residence, asylum, student, etc.).

- * National identification document from a European Union country with a photograph.

Only originals will be valid, never photocopies, and only if they are valid. Expired documents will not be

accepted under any circumstances.

How to Identify:

Regarding the correct identification process, the first step is to determine if the person holding the document is the same as the one appearing in the photograph of the identification document, then we will verify that the presented document is valid.

Other Issues to Consider:

Theft/loss of ID/book/check/promissory note:

In the event that the client reports the theft or loss of their ID/book/check, for example, when informing about the loss or theft of a card or another document, it is mandatory to add that information into the Bank's applications, so that it serves as an alert for the Network.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

38/110

In these cases, it is advisable for the office to obtain from the client a written statement in which they communicate the loss of the documentation.

[...] Remote operations:

As a general principle, for proper identification, the physical presence of the person who will carry out the operation is essential, in addition to being necessary to obtain their consent and to ensure that all required documents are duly signed. Experience indicates that frauds frequently occur in which communications via telephone, email, or fax are used to give certain orders.

Poor identifications occur, whereby the fraudster poses as a client or even as an employee.

Orders via telephone communications:

As a general rule, they should NOT be accepted. If, in exceptional cases, they are accepted, they should be restricted to very well-known clients. In case of doubt, they should not be executed. It is advisable to ask verification questions to ensure the identity of the interlocutor or to request their details and call a phone number obtained from databases (BD), never the one provided by the communicator themselves. Information can also be verified through the BD. In these exceptional cases, the operations must be documented immediately.

Sending orders via email/fax:

The procedures for scanning documents, due to their simplicity and cost-effectiveness, have facilitated the increase of this type of fraud. For this reason, as a general rule, they should NOT be accepted.

They will be restricted to the maximum, being allowed only in exceptional cases (exclusively very well-known clients), and it is essential to comply with the procedure regulating the authorization for the processing of payment orders (National and International) received from clients via email/fax, which requires making a phone contact to verify the authenticity of the received order. [...]

It is very common for fraudsters, posing as clients, to call the offices (especially others than that of the actual holder) repeatedly to check that their order has been processed. It is not sufficient to receive those calls to consider the order valid.

[...]

2.2.5. The signature as an identifying element

Another key element in the proper identification of the client is the signature, to the extent that its analysis is an additional working tool in banking operations and, therefore, constitutes another instrument within the basic level of security. For these reasons, it is essential that all documents associated with the products are duly signed and that the client's signature is digitized. [...]

2.3.1. Fraud with Cards [...]

Some types of fraud are as follows:

* Use of stolen/lost cards. The client has the contractual obligation to properly safeguard both the card and the PIN and to immediately report any incidents. One way of breaching the obligation of safekeeping is for that number to be kept at any time alongside the card.

[...] * Thefts during the sending of the card. Another fundamental aspect is the sending of the cards. In this case, the instructions indicated in Standard 52.10.026 must be followed. [...]

It should always be kept in mind that what is sent is not just a simple piece of plastic, but a payment

document equivalent to cash worth the limit of the card.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

39/110

send disabled and once the receipt is confirmed by the customer, proceed to its activation.

* Operations without physical presence of the card. - In these cases (internet purchases and mail/telephone sales), it is the merchant who contractually assumes responsibility, except in the case of secure commerce with authentication of the cardholder. This does not exempt us from paying attention to this type of fraud as it indirectly affects the reliability of this product and, therefore, its use and profitability.

* Fraudulent acquisition of the personal identification number (PIN). - The methods used by fraudsters are varied (deception, use of force, etc.)

How to act in case of fraud:

In the event that fraud with a credit/debit card is detected by the various existing means, the immediate action is to block the card following the instructions of Standard 52.10.026. This is a very important preventive action, as it immediately prevents further fraud. If the customer is unsure which card was lost or stolen, all cards under their ownership will be blocked.

The process continues, in the case of confirmed fraud, by sending the complete file to Operations - Payment Methods. [...]

2.3.8. Consumer Credits

For fraud to exist, there must be a "sufficient deception" (see the concept of fraud, point 2.1.1.), such as the manipulation or forgery of the documentation presented. If there is no such deception, it will likely be a case of default. In cases of fraud, fraudsters usually act as follows:

* They open an account, in some cases with false documentation, operating it normally. They simulate periodic deposits as if they were a salary.

* After a few months, they request a consumer credit to, for example, purchase a vehicle. To request it, they present false or manipulated payslips, in some cases from real companies for which the applicants do not work at the time of the application, or, in other cases, from non-existent companies or those created for fraud. They may even manipulate Social Security certificates.

* Subsequently, they withdraw cash from the money or use the loan money, resell the asset, and disappear.

* In some cases, they are organized groups that, in addition to creating companies to issue fictitious payslips, even put a property in the applicant's name as apparent collateral, only to later, before disappearing, transfer it back to another person in the organization, so that the loan beneficiary appears insolvent. [...]

2.5. Other issues related to fraud prevention

2.5.1. Information Security

The vast majority of frauds begin with a thorough collection of information about the potential victim, so the first preventive measure is to ensure that access to the information is exclusively held by those who should have it.

This implies being vigilant against requests for data via telephone from unknown persons, even if they claim to be colleagues. In these cases, it is advisable to confirm through simple methods, such as verification questions or, in the case of received calls, by returning calls to existing numbers in C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

40/110

our databases that we know truly belong to the person who claimed to call (whether they are a client or an employee). It should not be forgotten that this confidentiality is also required by the Data Protection Law, which mandates treating personal data confidentially and not disclosing personal information to individuals who are not holders of products, except in response to a legal request. For more information on this matter, see Standard 62.30.012 (Protection of personal data) [...].

Documents No. 4, 5, and 6: In these documents, the responding entity provides several purchase operations, cash withdrawals, and transfers made with the ***CARD.1 associated with the contract ***CONTRACT.2. In particular, document 6 is a communication regarding incidents related to the bank card, indicating that the claimant informed the responding entity about the theft of the bank card and the phone, and that the financial entity proceeded with a provisional advance, pending the successful resolution of the claimed amounts. The banking entity has not provided any other document dated after the incident related to fraud prevention and scams.

FORTY-FOURTH: The responding entity submitted a written statement on February 10, 2023, acknowledging its responsibility for the commission of the following infractions related to the specific case presented to the Agency, which was the origin of the subsequent investigation:

- The infringement of Article 6.1 of the General Data Protection Regulation (GDPR) classified under Article 83.5 of the same Regulation, concerning the unauthorized contracting of products, regarding which the Agreement considers the possible imposition of a fine of 70,000 euros.
- The infringement of Article 32 of the GDPR classified under Article 83.4 of the same Regulation, concerning the procedures for communication, inclusion, and maintenance in credit information systems of personal data, regarding which the Agreement considers the possible imposition of a fine of 500,000 euros.
- The infringement of Article 6.1 of the GDPR classified under Article 83.5 of the same Regulation, concerning the incorporation of personal data into credit information systems, regarding which the Agreement considers the possible imposition of a fine of 70,000 euros.

Furthermore, the responding entity proceeded to pay the fines corresponding to the aforementioned infractions, after making the deductions established by Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations.

FORTY-FIFTH: In the previous written statement dated February 10, 2023, the responding party presents a written statement of allegations to the initiation agreement regarding the two alleged infractions of Articles 25 and 32 of the GDPR, for which it does not acknowledge responsibility nor make the prompt payment, and presents the following documentation:

Document No. 1: This document is titled "Assessment of Security and Privacy at BBVA," in which BBVA states that "BBVA has a Security By Design policy, created in September 2017 and last revised in July 2022. The aforementioned internal policy establishes that, when developing, designing, selecting, and using applications, services, and products based on the processing of personal data or that process personal data to fulfill their function, developers of products, services, and applications should be encouraged to consider the basic principles established in data protection regulations at the time of developing and designing these products, services, and applications...

Among the various risks considered as part of the analyses conducted during the design and development phases of the products are:

[...] Specifically, the Fraud team will issue a position on the initiatives analyzed by SeP with the aim of preventing:

1. Economic loss to both clients and BBVA
2. Creation of mule accounts that allow for fraud attacks
3. Money laundering
4. Financing of terrorism
5. Leakage of information enabling fraud"

BBVA has not provided the version of the document in effect at the time of the events being analyzed in this procedure.

Document No. 2: This document is titled "Security by Design Actions (BBVA)." The date of the document is July 13, 2022, thus it is a

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

42/110

version subsequent to that in force at the time of the events subject to this procedure. The document reproduces the AEPD guide on data protection by design and by default and includes the following: "With the aim of complying with the concept of Security by Design and by Default, BBVA applies the following regulations and best practices.

1. Secure Development and Privacy by Design Standard: Internal standard that incorporates the principles of Privacy by Design according to the Regulation aimed at privacy and data protection throughout the entire lifecycle of software product development.
2. Big Data Guide: Glossary of best practices and considerations from the Spanish Data Protection Agency regarding the processing of personal data in Big Data environments.
3. Anonymization Guide: This guide describes the different possibilities or techniques of anonymization considered by the Spanish Data Protection Agency and their purpose.
4. Information Classification Standard: Internal regulation regarding the classification of information that incorporates considerations of GDPR.
5. Security Measures Framework (version 3.0): Tool that performs a risk analysis based on GDPR parameters (data volume, geolocation and data processing, data types, etc.) and shows the necessary and recommended security measures to apply.
6. Security Annex for the contract with suppliers: Security measures focused on GDPR compliance for data processing by third parties.

None of the guides referred to in this document are attached to it.

Document No. 3: In the written allegations, it is referred to as: "Information Classification Standard Internal Regulation (BBVA)," in which "guidelines are provided to be followed in the Technology area for the implementation of security measures on the Information Systems owned by BBVA Spain, based on the classification of the information they handle, and appropriate to the risk assessment to which they are exposed." The document is dated November 5, 2019.

At the end of the text, three annexes are mentioned: ANNEX I - Protection and Monitoring Measures. ANNEX II - Special Information. ANNEX III - Exceptions. These annexes cannot be analyzed as their text is not included.

Document No. 4: This document is titled "Agile Risk Assessment" (unofficial translation, "Evaluación ágil de riesgos"), "Security Alerts for User Lockout." The version provided is from July 24, 2018.

According to the document itself: "The objective of this initiative is to generate proactive alerts directed at customers, informing them of the following situations in Mobile Banking:

- Before their user is permanently locked due to failed login attempts: alert marked by the new payment services directive, PSD2 (Payment Services Directive 2), under which the user must be informed before being permanently locked out.
- After their user is permanently locked. These alerts must be available on both legacy infrastructure (R1 / SLOD) and R2 (Granting Ticket), and must be communicated via email provided/validated. The subsequent process for unlocking the user is the same as currently exists. The geographical scope of the initiative is limited to Spain, Portugal, and External Network, for both Businesses and Individuals."

This document refers to the establishment of a security alert for user lockout before it occurs due to failed session attempts and after it occurs.

Document No. 5: This document is titled "Agile Risk Assessment" (unofficial translation, "Evaluación ágil de riesgos"), "Hard Fraud Lockout." The version provided (1.0) is from June 1, 2020. According to this document: "The objective of the initiative is to implement a series of modifications in the user lockout and unlock processes (BBVA clients) of soft and hard types [...].

[...]

2. Relevant ICT Risks Identified

The following relevant risk aspects associated with the analyzed initiative are identified, whose categorization is defined in Annex I: [...]

Security and Anti-Fraud Risks

- [RS.01] [Anti-Fraud] The analyzed functionality (new service in ATM that allows customers to invoke the hard lock of their own multichannel user) involves changes in processes susceptible to fraud, which could lead to economic losses and reputational impact for the Group.

Privacy and Data Integrity Risks

- No relevant risks have been identified in the area of Integrity and Privacy.”

Document No. 6: This document is titled: “Opinion on Technical Security Measures and Fraud Forgetting/Unlocking of multichannel user password without card,” and establishes the technical security measures and fraud prevention in

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

44/110

case of request for unlocking due to forgotten Multichannel user password. The version provided (1.0) is dated April 23, 2014.

According to the document itself, "The objective of this initiative is the implementation of a mechanism that allows the generation of a new access password to the channels of the individual segment, namely, bbva.es and .mobi, Mobile Banking and Wallet, Self-service and Telephone Banking, provided that they have an informed email and a second factor of authentication.

[...]

5 Active Risks

After analyzing the initiative, no active risks have been identified."

BBVA has not provided later versions.

Document No. 7: This document is titled "Fraud Limits for operations < 20 of Bizum without OTP." The version provided is dated February 1, 2017.

On page 3 of the document, it states the following:

"1. Description of the Initiative

In order to expedite the payment process with Bizum by eliminating the 2nd factor for operations of 20 euros or less, with a maximum of 3 operations of this type per day, this initiative only applies to BIZUM.

1.1. Current Situation

Currently, for this type of operations, a signature key is always required, regardless of the amount of the operation."

BBVA has not provided later versions.

Document No. 8: This is an excerpt from the audit report issued by Deloitte Advisory, S.L. on 01/12/2022, verifying BBVA's compliance with the aspects outlined in (EU) 2018/389 of the Commission, dated November 27, 2017, which complements Directive (EU) 2015/2366 of the European Parliament and of the Council regarding the technical regulatory standards for strong customer authentication and common and secure open communication standards.

Document No. 9: The written allegations refer to this document titled "Multichannel Contract," signed by the claimant on 04/07/2017.

This contract establishes the general conditions for all channels and services attached to those channels, specifically: Internet Banking, Mobile Phone, Self-service Channel: ATMs and Terminals in Offices, and finally, Telephone Banking. The version is dated November 27, 2016.

In clause 8.3. it states that "The Client is obliged to notify the Bank of the loss, theft, or improper use of the mobile phone terminal and/or its SIM Cards, or unauthorized access to any of them, as well as any other cause that prevents them from accessing the messages that have been sent to them, without undue delay as soon as they become aware of it."

FORTY-SIXTH: On July 13, 2023, the instructing body of the procedure agreed to open a period for the practice of evidence, in which this Agency required BBVA to submit the following information within ten working days:

"1) The data protection impact assessment (hereinafter DPIA), dated and signed, regarding the processing of personal data of BBVA customers in relation to 'REMOTE BANKING MOBILE PHONE/CARD,' valid as of 04/14/2020, the date on which the claimant's daughter reported to BBVA the theft suffered by the claimant ('mobile, wallet, cards, etc.'), as well as all documentation prior to the DPIA that reflects the need for the decision to carry out the DPIA; likewise, all documentation prepared in connection with the DPIA and justifying the results obtained in the DPIA and the measures adopted in this regard, including documentation related to the participation of BBVA's Data Protection Officer in

its preparation.

In the event that it was considered that a DPIA was not necessary, the justifying documentation (dated and signed) outlining the reasons why BBVA believed it was not obligated to conduct the DPIA, including documentation related to the intervention of the Data Protection Officer where they expressed their opinion on this matter. In such a case, provide the supporting documentation of the risk analysis carried out, including all documentation prepared, justifying the results obtained and the measures adopted.

2) Dated and signed documentation regarding the technical and organizational measures that BBVA had planned on 04/14/2020 to prevent fraud by identity theft, specifically in operations through 'REMOTE BANKING MOBILE PHONE/CARD,' when the identity document, mobile phone (where BBVA sends the authentication factor), or credit cards have been stolen, and this circumstance has been communicated by the client.

3) Dated and signed documentation regarding the technical and organizational measures that BBVA had implemented as of 04/14/2020, so that communications made to the entity by its clients regarding the loss, misplacement, or theft of the identity document, mobile phone (where BBVA sends the authentication factor), or credit cards, would take effect in its various customer relationship channels related to the operations that the client may carry out."

The aforementioned agreement was notified to BBVA on July 14, 2023, as evidenced by the acknowledgment of receipt in the file.

Currently, there is no record in the AEPD that BBVA has submitted a written response to the practice of evidence.

LEGAL GROUNDS

I

Competence and applicable regulations

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

46/110

In accordance with the provisions of Articles 58.2 and 60 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 and 68.2 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for the Protection of Data is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for the Protection of Data shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Relevant Background Facts.

1.

Regarding the communications between the claimant and the respondent.

In order to analyze the possible infringements committed, it is appropriate to summarize the relevant background facts in chronological order:

- The theft of the claimant's documentation is said to have occurred on a date prior to 04/13/2020 and according to judgment ***SENTENCIA.1 of ***FECHA.1, issued by the Court of First Instance No. 10 of Barcelona on 04/10/2020.

- On 04/13/2020, the claimant contacted the respondent to cancel a credit card of which she was the holder.

- On 04/14/2020, the claimant's daughter sent an email to the branch where she normally operated. In this email, the following is stated:

"Yesterday my mother was robbed (...) her mobile phone, wallet, and cards, etc. Please urgently cancel all her cards, I believe she has 2 but I do not have the numbers with me here."

- On the same date of 04/14/2020, the bank responded to the previous email as follows:
"She only has one card and I see that yesterday 04/13/2020 at 18:06 it was blocked. Did you call the BBVA contact center???"

What I see is that there are various charges through online banking that I assume she did not make.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

47/110

Attached are the charges made for you to take a look... If they are not correct, we need a report from the Mossos to process the fraud claim."

- On 04/17/2020, an email was sent from the claimant's lawyer to the respondent:

"I am now sending you the report that we filed yesterday against the residence. The process will continue its course and we estimate that in a few weeks it will enter the Court, where they will initiate a criminal case."

- On 04/20/2020, an email was sent from the respondent to the aforementioned lawyer:

"We have already sent the report to the corresponding department for processing. As for the transfers, I cannot tell you anything else because this has its natural process and the security and fraud department will have to evaluate the matter through the report and the requested information."

1.

Regarding the fraudulent contracting of various products

According to the findings of the Inspection of this Agency, the following products were contracted on the dates detailed (excluding the financial products of which the claimant was the holder prior to the events):

- A loan of 4,000 euros subscribed on April 12, 2020, of which the respondent specifies that it is not canceled. The respondent indicates that it was signed electronically at the request of the claimant through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 12, 2020.

- Card number ***TARJETA.2 linked to contract ***CONTRATO.3. Regarding this card, the claimant states that it was requested from her mobile phone number and sent to her address. She also expresses that third parties subsequently used it to carry out transactions. The respondent states that it was contracted on April 15, 2020, and refers that the application for the card was signed electronically through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 15, 2020.

- Account number ***CUENTA.3 (the claimant cites "an account ending in XX" in an email dated September 9, 2020) subscribed on April 27, 2020, of which the respondent specifies that it is not canceled. It is stated that it was signed electronically at the request of the claimant through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 27, 2020.

- Card number ***TARJETA.3 linked to contract ***CONTRATO.4 subscribed on April 15, 2020, of which the respondent specifies that it is canceled. It is stated that it was signed electronically at the request of the claimant.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

48/110

Claimant through the channel "REMOTE BANKING MOBILE PHONE/CARD" dated April 15, 2020.

-

Card number ***CARD.4 linked to contract ***CONTRACT.5 signed on April 15, 2020, of which the respondent specifies that it is canceled. It provides (document 12 attached to the Respondent's Written Statement #2) a copy of the contract, which includes the name, surname, ID number of the claimant, and the email ***EMAIL.1. It states that it has been electronically signed at the request of the claimant through the channel "REMOTE BANKING MOBILE PHONE/CARD" on April 15, 2020.

As can be observed, there was a second communication to the respondent on April 14, 2020, since the day before there was a first one for the blocking of a card, in which it was notified that the claimant had been the victim of a theft, including "the mobile phone, wallet, cards, etc." This notified the bank that

both the cards and the mobile phone had been stolen, with the possibility that identifying documents may have also been taken. The theft of the mobile phone, moreover, points to the possibility that the criminals could have access to the claimant's remote banking.

But not only that, in the email from the respondent, dated April 14, 2020, in response to the theft notification by the claimant, the bank states: "What I see is that there are various charges through online banking that I suppose she has not made. Attached are the charges made for you to take a look... If they are not correct, we need a report from the Mossos to process the fraud claim." This indicates knowledge of evidence of possible fraudulent charges.

Subsequently, on April 17, 2020, the bank received the report filed by the representative of the claimant dated April 16, 2020, as recorded in Proven Fact Ninth, in which the theft is reported: "Ms. A.A.A. states that she feels strange and that, in addition, she has been robbed at her residence:

- + the mobile phone

- + a square zip wallet where she had her credit card, ID, driver's license, and health card..."

Despite this, as detailed above, the fraudsters had the opportunity to continue contracting various products until a date as far away as April 27, 2020, from which they could operate, making transactions, carrying out transfers, and, in general, misappropriating the monetary assets that the claimant held.

III

Response to the allegations raised against the initiation agreement

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

49/110

In relation to the allegations made regarding the initiation agreement of the present sanctioning procedure, a response is provided to the same in the order presented by the responding party:

Regarding the allegations made concerning the initiation agreement of the present sanctioning procedure, a response is provided to the same in the order presented by BBVA:

1.- "PRELIMINARY. - ON THE RESPONSIBILITY ACCEPTED BY BBVA AND THE VOLUNTARY PAYMENT"

In this first allegation, BBVA attributes the facts subject to this procedure to "a series of errors that occurred in this case, largely deduced from the fact that the person who impersonated the identity (hereinafter, the "Usurper") of the individual who filed the complaint that initiated the present procedure (hereinafter, the "Claimant") was able to access information related to their electronic contracting keys as a result of the theft of their belongings, which included their National Identity Document, mobile phone, and credit card.

BBVA continues its reasoning by stating that "as a consequence of these errors, the successive blocks of the financial products contracted by the Claimant with my client, as well as the fund reimbursements made to their account, could have been subject to lifting..."

However, my client cannot acknowledge, and in fact categorically denies, that it has not applied the principles of privacy by design (hereinafter, referred to by its English acronym, "PbD") in the admission and contracting policy for its clients, as well as the appropriate technical and organizational measures aimed at guaranteeing and protecting the fundamental rights of its clients, particularly their fundamental right to the protection of personal data.

In this regard, my client believes that the AEPD intends to apply to what is nothing more than an unfortunate incident, which my represented party does not deny recognizing, a sort of general doctrine, according to which my client would not be generally preventing the possible identity theft of its clients as a consequence of the existence of a series of errors in the specific case being referenced in the present procedure. That is to say, the AEPD not only imputes to my client the specific facts that occurred and were proven, but also extends this imputation beyond the circumstances of the specific case, denying the establishment of measures that, unfortunately, have failed in the present instance, or that BBVA applies the principles of personal data protection in the development of its activity and in the relationships arising from its clients' activities with it."

In response to this allegation, it should be noted that the infringements attributed to BBVA are not

based on "a sort of general doctrine," but rather that the behaviors that motivated the present procedure stem from specific facts in which it has been demonstrated, on one hand, that in the document for incident management provided by BBVA titled "Fraud Prevention and...

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

50/110

"fraud," the principle of data protection by design and by default does not apply in the processing of personal data of its clients, that is, regarding this principle, BBVA does not have appropriate technical and organizational measures to prevent incidents such as those that occurred in the contracting of financial products or in the execution of operations, especially through the channel "REMOTE BANKING MOBILE PHONE/CARD," once the client has repeatedly communicated through various channels to BBVA the loss or theft of their ID, mobile phone, or credit card.

Indeed, as will be developed further, it has been established that BBVA had not analyzed the risk that arises, from the perspective of the fundamental right to the protection of personal data, in cases of loss or theft of identifying documentation or devices or terminals (mobile phones, credit cards) that can lead to the use of personal data with the aim of causing financial harm to their owner and illicit enrichment to the fraudsters. This has led to the absence of technical or organizational measures that should have been implemented following the aforementioned risk analysis, which would have prevented, once the documentation was stolen from a client, the impersonators from continuing, for weeks, to contract financial products in the name of the client, resulting in financial harm to them.

BBVA argues that these events occurred due to a "series of errors." One can only disagree with this view of the facts. The theft of the identification means (ID) or authentication (mobile phone) of BBVA clients cannot be considered an error, but rather a certain risk for which BBVA clients may suffer a loss of control over their personal data. This risk must be anticipated by the data controller. From the moment the client communicates to BBVA the theft of the identification or authentication means, caution must prevail in the banking entity, as it may not be the client who is actually carrying out the operations. From the reading of the Established Facts in this document, it is evident that the continuous requests made by the claiming party for their personal data to cease being processed illegally have been ignored by BBVA. In this case, BBVA accepts the operations as valid solely because of the use of two-factor authentication, when this occurs through a means (the mobile phone) whose theft has been communicated by the BBVA client, leading to numerous continuous, concatenated errors that reveal an absolute lack of procedure to prevent the illegal processing of personal data. This entity has acknowledged that the contracting of banking products has occurred, but, far from being an isolated incident, we find that systematically the right to data protection of the claiming party has been violated. From the documentation provided by BBVA, as recorded in the Established Facts Forty-Third and Forty-Fifth, which will be analyzed later in this response to the allegations, the absence of procedures regarding the prevention of fraud in online operations is confirmed, especially in cases of theft or loss of information that can be used to commit fraud and, in general, of procedures for incident management related to fraud, with outdated guidelines, not adapted to the GDPR, and not focused on the risks to the rights and freedoms of clients.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

51/110

As a result, BBVA must, first, design its personal data processing in accordance with the principle of data protection by design and by default, taking into account the risks to the rights and freedoms of individuals, and, second, it must implement measures that ensure the security of the data in question and the rights and freedoms of individuals, especially when a customer repeatedly reports the theft of such elements through the various channels of communication with its customers that BBVA has, knowing that the stolen data must be used for online banking.

2.- "FIRST. - ON THE ALLEGED VIOLATION BY BBVA OF THE PRINCIPLE OF DATA PROTECTION BY DESIGN, INFRINGED IN ARTICLE 25 OF THE GDPR."

This allegation is further divided into the following subsections:

“1. On the content of the Initiation Agreement and the scope of the infringement that is intended to be imposed on my client.”

According to BBVA, the initiation agreement presents an “apparent argument” since it does not demonstrate at any point whether BBVA has actually complied with the obligations derived from the aforementioned provision, but rather the cited legal basis consists solely of a description of what, in the opinion of the AEPD, should be considered to imply the principle of data protection by design.

First of all, we must emphasize that the initiation agreement of a sanctioning procedure is regulated in Article 64 of the LPACAP, which stipulates that it must contain at least, among other issues, “2. b) The facts that motivate the initiation of the procedure, its possible qualification, and the sanctions that may correspond, without prejudice to what results from the instruction.” Therefore, it is not the administrative act in which it must be demonstrated whether an administrative infringement has been committed, as the responding party intends, but rather in which the facts that motivate the initiation of the procedure, its possible qualification, and the sanctions that may correspond are recorded, as has been done, without prejudice to what results from the instruction.

Secondly, and addressing the substance of the matter, in response to the argument put forth by BBVA, it should be noted that compliance with the principle of proactive responsibility, and in particular with data protection by design and by default (hereinafter “DPDD”), materializes both at the moment of determining the means of processing and at the moment of the processing itself, through the adoption of appropriate technical and organizational measures of all kinds, designed to effectively apply the principles of data protection and integrate the necessary guarantees in the processing, in order to meet the requirements of the Regulation and protect the rights of the data subjects.

As was established in Legal Basis V of the initiation agreement regarding the infringement of Article 25 of the GDPR, first, compliance with the DPDD entails that “the data controller shall carry out an exercise of analysis and detection of risks throughout the entire data processing cycle,

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

52/110

with the primary and ultimate purpose of protecting the rights and freedoms of the interested parties, and not only when the processing actually takes place,” in accordance with what is expressly established in Article 25.1 of the GDPR: “Taking into account... the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons...”.

It was also indicated that “Upon examining the document, it is observed that it has an eminently business or ‘commercial’ approach. Its purpose is to try to avoid fraudulent practices that may result in harm to the entity. Indirectly, this may prevent financial harm to the user, but it does not protect their Fundamental Right to Personal Data Protection; it does not protect their rights and freedoms, which is the ultimate purpose pursued by the GDPR through data protection by design. Therefore, it is not a document conceived for compliance with the principle of proactive responsibility (Article 5.2 GDPR), as it should have started from the aforementioned risk analysis that would lead to the adoption of measures for the protection of rights and freedoms, always based on the design of the processing. (...) Thus, upon examining the procedure established by the banking entity regarding the management of incidents related to fraud, it is observed that it is completely outdated, not adapted to the GDPR, and not focused on the risks to the rights and freedoms of customers, which shows that the obligation set forth in Article 25 of the GDPR regarding the design and integration of data protection into the organization’s fraud detection system has not been fulfilled.”

Well, in accordance with the literal wording of the document, as provided in the Proven Fact Forty-Third (document 3), this document has a focus on the risks to the entity and not on protecting the rights and freedoms of the clients of the defendant in matters of data protection, as advocated by the GDPR.

Thus, it can be verified from the content of the aforementioned document that states: “One of the keys to the client-financial entity relationship is the trust that must be established. Undoubtedly, from that point of view, attacks on the security of certain products or services can undermine this principle.

...

The defense of trust in processes, preserving the reputation of the entities themselves, given that fraud negatively affects their image, and avoiding losses that, once incurred, are, in most cases, irrecoverable, make it necessary to enhance prevention in this field through the issuance of regulations and training actions.

...

If the bank does not operate correctly, it may incur serious liability, so these practices should not be carried out.” (the underlining is ours)

In the same way, we can see that focus on the risks in the banking entity in the assets that are protected, such as the receipt of counterfeit bills, or regarding the subject of the

53/110

fraud, the banking entity, as occurs in what is stated in the document related to consumer credits.

Upon examining the aforementioned document, the risks to the rights and freedoms of the interested parties are not identified, nor are they assessed, nor are technical and organizational measures determined to guarantee the Fundamental Right to the Protection of Personal Data.

Furthermore, in 2015, when this document from the claimant was drafted, the Organic Law 15/1999, of December 13, on the Protection of Personal Data was in force, which did not contain any provisions regarding the design of the processing, focusing on the rights and freedoms of the interested parties, or the implementation of technical and organizational measures of all types and appropriate to guarantee such rights and freedoms. It merely mentioned security measures, which now constitute part of the totality of technical and organizational measures of all types set forth in Article 25 of the GDPR that the data controller must implement. This is a document that does not include a procedure to prevent fraud, scams, and identity theft in online operations, nor does it foresee the risks of impersonation in these operations. It also does not contain procedures for detecting fraudulent operations. It is noteworthy that the document predates Royal Decree-Law 19/2018, of November 23, on payment services and other urgent financial measures that partially transposed Directive (EU) 2015/2366 of the European Parliament and of the Council of November 25, 2015, on payment services.

Curiously, from 2015 to 2023, through the applicability of the GDPR in May 2018 (and having passed five years since then), this document has not been adapted to the premises of the GDPR, nor have any of its aspects changed in relation to either the risk approach or the risks themselves.

For all these reasons, the risk approach set forth in a document drafted in 2015, prior to the very existence of the GDPR and, consequently, of the PDDD as an obligation of the data controller derived from proactive responsibility, cannot be deemed valid, without taking into account, furthermore, the very evolution of technology and the risks that may arise or change merely due to the passage of time. Not a single mention in the document that “aims to disseminate those basic monitoring measures that may allow detecting and aborting the vast majority of frauds that occur, with minimal effort” to the online operations between clients and the entity that is now widespread. Not a single mention of online fraud.

Only a mention of distance purchases with a card (via the internet, mail, or phone) and, again, to refer to the risks that the entity may or may not bear and none for the client:

“* Operations without the physical presence of the card.- In these cases (purchases via INTERNET and sales by mail/phone), it is the merchant who contractually assumes responsibility, except in the case of secure commerce with authentication of the holder. This does not exempt us from paying attention to this type of...”

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

54/110

fraud as it indirectly affects the reliability of this product and, therefore, its use and profitability.”

We would add that the aforementioned document is based solely on the security of information (which may or may not contain personal data) as the first and only premise that underpins its formation.

Furthermore, all of this is not an “apparent argument,” but a well-founded argument regarding the

infringement attributable to BBVA, as the responsible party for the processing in question. Secondly, BBVA does not explain to what extent the content of each document provided in its allegations is related to compliance with the PDDD regarding the processing of personal data subject to this procedure; it merely lists a series of documents without justifying how they contribute to compliance with the PDDD.

From the reading of these documents, it cannot be said that either the document “Fraud and Scam Prevention,” prepared in 2015 as previously mentioned, provided by BBVA in response to the information request made by this Agency, or the documents submitted during the allegations phase referred to in the Proven Fact Forty-Fifth, comply with the PDDD for the following reasons:

- Document No. 1: This document contains an internal regulation of “security by design,” which is described as a process in which developers of products, services, and applications are “encouraged” to take into account the basic principles established in data protection regulations at the time of developing and designing these products, services, and applications.

A series of risks, mainly technological, are categorized, and a process is established by which they claim to consider the necessary technical and/or organizational measures to ensure the security and privacy of the data. The Data Security area intervenes in this process; nothing is mentioned about the Data Protection Officer in terms of performing their advisory and informational functions regarding compliance with the GDPR. Subsequently, the “Anti-fraud Strategy” is discussed, where the mechanisms for authentication and signing of operations are related.

In this document, reference is made to technological risks (see the table included in Document 1 of Proven Fact Forty-Fifth); the focus is not on the risks to the rights and freedoms of the data subjects, such as the risk of financial loss. The measures referred to are technological security measures that are not aimed at preventing or minimizing risks to the rights and freedoms of individuals. Thus, on page 3, they determine the objectives, some of which are not risks to the rights and freedoms of the data subjects but rather organizational risks.

According to the document itself, the regulation referred to as “Security By Design” was generated in September 2017 and the last revision was made in July 2022, after the events.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

55/110

- Document No. 2: Titled “Security by Design Actions,” it should first be noted that this document is subsequent to the events being analyzed. The claim is from October 2021, the theft occurred on 04/10/2020, and on 04/14/2020 there is evidence in the file that the financial entity was aware of the events.

Second, this document outlines a series of principles for compliance with Article 25 of the GDPR, and a series of “rules and guidelines for good practices” in security that essentially replicate the AEPD guide on privacy by design, without further specifications. Furthermore, when the document discusses security measures by design at BBVA, it merely intersperses a series of links to other documents.

- Document No. 3: Titled “Internal Regulatory Information Classification Standard (BBVA),” the document is dated November 5, 2019.

This “standard” provides guidelines to be followed in the area of Technology for the implementation of security measures on the Information Systems owned by BBVA. It establishes guidelines regarding risk assessment (without carrying out such assessment), classification of information, proper use of assets, management of removable media, destruction of physical media, transfer by physical means (guidelines for transferring information in paper and electronic format within BBVA), and measures for the protection and monitoring of information.

However, despite the existence of several versions, only the latest is referenced, and therefore the previous ones are unknown. They basically include risks within the organization and technological risks, lacking a focus on risks related to the rights and freedoms concerning the protection of customer data. The text classifies information and assets, which is the focus of the document, and not on the protection of personal data. This implies that, even if it could be considered that personal data is

indirectly protected, since it is included in the information and assets, the approach is not correct. In this sense, the risk assessment and the measures to be adopted may be erroneous precisely due to this approach.

It should be noted that risks do not only arise in relation to the security of the entity's information systems, but there may also be risks in the virtual environment related to the rights and freedoms of individuals, particularly in cases where the data subject has lost control over information that can be used to impersonate their identity.

At the end of the text, three annexes are mentioned: ANNEX I - Protection and Monitoring Measures. ANNEX II - Special Information. ANNEX III - Exceptions. These annexes cannot be analyzed as their text is not provided.

- Document No. 4: Under the title "Agile Risk Assessment" (unofficial translation, "Evaluación ágil de riesgos"), "Security Alerts for User Lockout," the
C/ Jorge Juan, 6
www.aepd.es 28001 – Madrid
sedeagpd.gob.es
56/110

The document conducts a risk assessment regarding security alerts related to user blocking. The document does not make considerations about the level of risk, with the only associated risk being non-compliance with payment regulations, a risk of the organization. Furthermore, risks related to technological fraud are identified in these processes.

Additionally, this document mixes organizational risks with those of stakeholders (referring to technological risk) and only mentions the establishment of a security alert regarding user blocking before it occurs due to failed session retries and after the event.

- Document No. 5: Under the title "Agile Risk Assessment" (unofficial translation, "Evaluación ágil de riesgos"), "Hard Fraud Blocking," the objective of the initiative is to implement a series of modifications in the blocking and unblocking processes for BBVA customers, which the defendant divides into two types: soft and hard. In both cases, the operational blocking for the customer is the same, meaning they will not be able to operate with their multichannel profile.

It seems that there is a defect in the design of the procedures that must be followed in cases of fraud and impersonation risk. This was highlighted in a case where the account blocking was requested, and the impersonators of the claimant's identity continued to operate with it. The defendant has not provided any document that outlines the procedures implemented by the entity to proceed with blocking in cases where unauthorized third parties have access to the first factor authentication keys or to personal information that allows for the impersonation of the customer's identity, once BBVA is aware of it.

Moreover, in this document, it is indicated on page five regarding privacy and data integrity risks that no risks are contemplated, despite the existence of risks being evident in the case referred to in this file, indicating that there was indeed a certain risk that materialized and that BBVA has been unable to identify.

- Document No. 6: Under the title "Report on Technical Security Measures and Fraud Forgotten/Unblocking of Multichannel User Password without Card," the objective of this document is to define the security requirements associated with the initiative "Forgotten/unblocking of multichannel user password without card" and describes the tasks to be carried out, as well as the costs associated with the project, by the Data Protection and IT Risk Fraud & Security areas.

Regarding this document, it should be noted that its date is prior to the entry into force of the GDPR. It is the initial version, and we do not know if there are later versions that, in any case, have not been provided by the defendant. Furthermore, risks regarding the protection of personal data are not categorized, so the document is aimed at preventing economic fraud and not at protecting the entity's customers regarding the processing of their personal data.

- Document No. 7: Under the title "Fraud Limits for Operations < 20 of Bizum without OTP," the objective of this initiative consists of an application that only affects BIZUM,
C/ Jorge Juan, 6

used to expedite the payment process by eliminating the second factor for transactions of €20 or less, with a maximum of 3 such transactions per day. Regarding this document, it should be noted that the date is prior to the entry into force of the GDPR and at the time the events occurred, it was therefore outdated. Furthermore, in this case, there was no notice alerting BBVA that unauthorized third parties were conducting transactions through Bizum using the claimant's data.

- Document No. 8: From the audit report issued by Deloitte Advisory, S.L., it should be noted that the investigated events occurred throughout the year 2020 and this audit is from the end of 2022, two years later. This report includes the methodology, model, and fraud indices reported under Delegated Regulation 2018/389, not compliance with the GDPR.

- Document No. 9: In the "Multichannel Contract," the general conditions for all channels and services associated with those channels are established, specifically: Internet Banking, Mobile Phone, Self-Service Channel: ATMs and Terminals in Offices, and finally, Telephone Banking, which is based on a model from the version of November 27, 2016, and which only demonstrates that the claimant had a contract signed with the defendant for the contracting of banking products or services. The claimant duly complied, as stated in Proven Fact Five, with the obligation established in clause 8.3 of that contract, notifying BBVA of the theft of the mobile phone without undue delay as soon as they became aware of it.

Consequently, for the reasons stated above, BBVA's assertion that "it has carried out a relevant risk analysis regarding all its processing of personal data, and specifically regarding the use by its customers of online channels, determining the appropriate technical and organizational measures to ensure respect for the rights of the data subjects" has been discredited.

"2. On the scope of the data protection by design principle"

At this point, BBVA makes an interpretation regarding the scope of the DPPD, according to which it considers that it has fully analyzed and assessed all the measures that should have been adopted to ensure compliance with the principles established in Article 25 of the GDPR, without prejudice to whether it is deemed insufficient by the supervisory authority.

In response to this argument, from the documentation provided by BBVA, analyzed in detail previously, it is not evidenced that the risks of varying probability and severity to the rights and freedoms of its customers have been taken into account in the procedure established by the banking entity regarding the management of incidents related to fraud, given the lack of protection of the claimant's rights, which has been evident due to the constant neglect of the communications made by the claimant regarding the illegality of the processing of their personal data with the impersonation for access to their products.

C/ Jorge Juan, 6

carrying out operations and contracting new products with BBVA, especially through the channel "REMOTE BANKING MOBILE PHONE/CARD",

After analyzing all the documentation provided at the various stages of this procedure by BBVA, it is observed that this entity did not comply with the principle of privacy by design. Firstly, there was no adequate risk analysis. Not a single one of the documents submitted addressed the risk arising from the loss or theft of certain identifying documentation (or the methods or devices for accessing its online banking), as the personal data that allows for the remote contracting of financial products was left exposed.

The submitted documents do not contain any analysis of this risk and, consequently, did not establish technical or organizational measures that could prevent the infringement of the fundamental right to data protection and, indirectly, the assets and rights owned by the bank's clients. On the contrary, these documents focus on avoiding risks primarily for the entity itself. They address technological, organizational, or business risks that may result in financial harm to the bank.

In this regard, it should be noted that according to Article 25 of the GDPR:

"Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity posed to the rights and freedoms of natural persons, the controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of data subjects." (the underlining is ours)

That is to say, the protection of the fundamental right to data protection does not consist of a mere "reactive" waiting for a problem that may infringe it to occur, but rather that the data controllers must design ("data protection by design") appropriate policies for the protection of this fundamental right prior to the commencement of the processing. This includes all aspects regulated in the GDPR, starting with the obligations of transparency, respect for the exercise of the rights established in the Regulation, and the establishment of all necessary technical and organizational measures to ensure compliance with this regulation. Likewise, security measures must also be included. All of this must be planned and implemented prior to the commencement of processing by the controller.

As a result of the inspection actions carried out by this Agency, as well as the rest of the documentation and allegations presented by BBVA in this procedure, it has been confirmed that this principle (and consequently Article 25 of the GDPR) was not complied with by the banking entity.

There was no risk analysis that identified the risk of contracting through impersonation.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

59/110

when any client lost and had their identification documentation or mobile phone stolen.

In this regard, risk analysis is a key component of the principle of privacy by design, as it allows for the establishment of technical and organizational measures to prevent them or, in the event that they occur, to mitigate them. As noted, Article 25 makes special reference to "the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons," as a prerequisite for the establishment of such measures.

It has been verified that neither the risk was established nor the measures implemented. All of this is corroborated by the case that led to this file. Indeed, as has been extensively narrated in the proven facts of this proposal, since April 14, 2020, and on several occasions, BBVA had been notified of the theft of mobile phone number ***TELÉFONO.1 and the identification documentation of the claimant. However, BBVA maintained this personal data of the claimant as a means through which the authentication of the claimant's identity occurred, which evidences a lack of adequate measures applicable to these situations.

Furthermore, the application of the PDDD, contrary to the argument put forth by BBVA, is not limited to the adoption of certain measures, which may or may not be considered adequate by the supervisory authority, but these measures must be effective. That is to say, the GDPR does not establish specific measures regarding PDDD, as these depend on the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity; this does not mean that any measure adopted is appropriate.

It is worth mentioning the considerations made by the European Data Protection Board (EDPB), which, in compliance with the objective of ensuring the consistent application of the General Data Protection Regulation (as attributed to it by Article 70 of the GDPR), adopted on October 20, 2020, Guidelines 4/2019 on Article 25 Data Protection by Design and by Default

(https://edpb.europa.eu/system/files/2021-04/edpb_guidelines_201904_dataprotection_by_design_and_by_default_v2.0_es.pdf).

In sections 7 and following of these guidelines, it is established that:

"7. In a broad sense, it can be understood that technical and organizational measures and guarantees are any method or means that the controller may employ in the processing. For them to be adequate,

the necessary measures and guarantees must be suitable to achieve the intended purpose, that is, they must effectively apply the principles of data protection.

8...

13. Effectiveness is the basis of the concept of data protection by design. The requirement to apply the principles effectively implies that data controllers must implement the necessary measures and guarantees to protect these principles, in order to ensure the rights of the data subjects.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

60/110

14. First, it means that Article 25 does not require the application of any specific technical or organizational measures, except in the sense that the chosen measures and guarantees must be specific to the application of the principles of data protection in the processing in question. For this, the measures and guarantees must be designed to be robust, and the controller must be able to implement additional measures in order to adapt them to any increase in risk. The measures and guarantees applied must achieve the desired effect in terms of data protection, and the data controller must have documentation regarding the technical and organizational measures applied.

15. Second, data controllers must be able to demonstrate that these principles have been maintained.” (the underlining is added).

Therefore, the PDDD aims to ensure that the principles of data protection, such as lawfulness, fairness, transparency, accuracy, integrity, and confidentiality, are effectively applied, so its scope does not depend, contrary to the argument put forward by BBVA, on whether it is considered sufficient by this Agency. The Established Facts demonstrate that these principles are not guaranteed by the measures adopted by BBVA.

“3. On the additional security requirements established by the sectoral regulations applicable to BBVA and their implementation in the case that generates this procedure”

BBVA argues that “the PSD2 Directive itself and its implementing and transposing regulations determine the PbD criteria that must be taken into account to ensure not only the prevention of fraud and the security of online transactions but also the rights of data subjects and, in particular, their right to the protection of personal data.” Based on the measures adopted to comply with Directive (EU) 2015/2366 of the European Parliament and of the Council, of November 25, 2015, on payment services in the internal market and Royal Decree-Law 19/2018, of November 23, on payment services and other urgent financial measures (hereinafter, “RDL on payment services”), as well as those measures adopted in compliance with Delegated Regulation (EU) 2018/389 of the Commission of November 27, 2017, which complements Directive (EU) 2015/2366 of the European Parliament and of the Council regarding the technical regulatory standards for strong customer authentication and common and secure open communication standards (hereinafter, “Delegated Regulation”), BBVA understands that it has implemented the PDDD in the data processing of its clients.

However, the approach of such measures, adopted to comply with the RDL on payment services, while potentially related to the principles of the GDPR, does not constitute compliance with it, which is focused on the risk to the rights and freedoms of data subjects. We start from the premise that the Directive transposing the RDL on payment services, from 2015, predates the GDPR, which is from 2016, and that compliance with it does not exclude adherence to the principles enshrined in the GDPR. It is worth noting that in the PDDD, the risk analysis is continuous and compliance with the GDPR is not achieved if these risks are not reviewed.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

61/110

From the analysis of the documentation provided by BBVA, it is evident that BBVA does not have internal procedures to prevent risks that may arise in circumstances such as when the client reports the theft of their identity document or mobile phone. It should be noted that the protection of personal data in the use of information technology is a fundamental right recognized in Article 18 of the Spanish

Constitution of 1978.

In this regard, the lack of respect for the principle of Data Protection and Data Privacy (PDDD) is illustrated by the specific case that occurred, but especially in the procedure used, which is the same regardless of the number of people that may be affected, as can be inferred from the documentation provided by the respondent and indicated in the Proven Facts Forty-Third and Forty-Fifth.

Subsidiarily, it should be noted that section b) of Article 41 "Obligations of the user of payment services in relation to payment instruments and personalized security credentials," of the Royal Decree-Law on payment services, states that:

"The user of payment services authorized to use a payment instrument:

a...

b) in the event of loss, theft, or improper appropriation of the payment instrument or its unauthorized use, shall notify the payment service provider or the entity designated by it, without undue delay as soon as they become aware of it."

The Proven Facts include a series of communications, the first of which was sent on April 14, 2020 (Proven Fact Fifth), by the claimant and their representative, in which they informed BBVA of the theft of, among other items, a payment method (cards) and the authentication factor (mobile phone with phone number ***PHONE.1). In these communications, the suspension of operations carried out with the payment instruments whose theft had been reported, or that had been contracted illegally, was requested, thus the claimant fulfilled the obligation established by Article 41.b) of the Royal Decree-Law on payment services.

However, it cannot be said that BBVA, in light of the Proven Facts, has complied with the obligations of the payment service provider established in Article 42 of the Royal Decree-Law on payment services, specifically, in its section a) it is established that the payment service provider "shall ensure that the personalized security credentials of the payment instrument are only accessible to the authorized user of payment services to use such instrument, without prejudice to the obligations incumbent on the user of payment services in accordance with Article 41" and section e) of that article states that "it shall prevent any use of the payment instrument once notification has been made pursuant to Article 41.b)." In the present case, it is stated in the Proven Facts that, despite the communication made by the claimant regarding the theft of their ID, their card, and their mobile phone, which is an authentication factor for operating bank accounts,

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

62/110

credit cards and BIZUM transactions, there are multiple operations that those who impersonated the identity of the claimant were able to carry out using their personal data illegally. The documentation provided by BBVA does not include the possibility that a phone number ceases to be an authentication factor for operating in "REMOTE BANKING MOBILE PHONE/CARD" when its owner has reported the theft of the mobile phone.

It should be noted that the document "Fraud and Scam Prevention" provided by BBVA is from the year 2015, prior to the RDL on payment services from 2018, so it is not possible that it included the obligations of this regulation. There is also no risk assessment for the rights and freedoms of BBVA customers concerning fraud operations, once they have fulfilled the obligation established in Article 41.b) of the RDL on payment services.

For all the above reasons, this allegation is dismissed.

"SECOND. - ON THE IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD"

1. Violation of the principle of non bis in idem

BBVA makes an erroneous interpretation of the infringements attributed to it, by stating that: "...the AEPD considers that in this case, the alleged insufficiency of the security measures that, in its opinion, are required in this case implies a double violation of the GDPR: (i) on the one hand, it understands that my client has not adopted the appropriate technical and organizational measures required by

Article 32.1 of the GDPR in the identification procedure of its clients; and (ii) on the other hand, that the absence or insufficiency of those measures leads to the appreciation that my client has not complied with the requirements derived from compliance with Article 25.1 of the same legal text.

Firstly, the infringement of Article 32 of the GDPR does not refer to the failure to adopt appropriate technical and organizational measures in the client identification procedure. The facts constituting the infringement of Article 32 of the GDPR are defined in the initiation agreement as follows: "neither from the documentation or information provided by the respondent, nor much less from the results produced in this case can it be inferred that BBVA had an adequate procedure regarding the implementation and application of appropriate personal data security measures, technical or organizational, to prevent events like the one that occurred in a contracting nor for the inclusion or maintenance of customer data in credit information systems when the debt is disputed." (the underlining is ours)

Secondly, the infringement of Article 25 of the GDPR cannot be related as BBVA does, the security measures of Article 32 of the GDPR ("...the absence or insufficiency of those measures..."), with the measures referred to in Article 25 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

63/110

GDPR, as it encompasses the adoption of measures, not only of security, but of all kinds.

Article 25 of the GDPR regarding privacy by design states that, "Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects" (the underlining is ours).

We reiterate that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle.

However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk, solely related to security.

Now delving into the examination of non bis in idem, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) states that "(...) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same subject twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the accumulation of sanctions creates a sanction foreign to the proportionality assessment carried out by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

But for "bis in idem" to be applicable, there must be a triple identity among the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority that judges and independently of who the accuser or specific body that has resolved is, or whether it is judged alone or in conjunction with other affected parties.

b) The factual identity implies that the facts being judged must be the same, and excludes cases of real concurrence of infringements where there is not a single unlawful act but several.

c) The identity of grounds or causal identity implies that the sanctioning measures cannot coincide if they respond to the same nature, that is, if they share the same teleological foundation, which occurs between criminal and administrative sanctions.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid
sedeagpd.gob.es
64/110

administrative sanctioning, but not between punitive and merely coercive measures.”

Taking into account the aforementioned, the principle of non bis in idem has not been violated, since, broadly understood, the facts are detected as a consequence of the absence and deficiency of security measures (only security), which constitute a violation of Article 32 of the GDPR. Furthermore, both the facts and the documentation provided by BBVA have confirmed the non-compliance with Article 25 of the GDPR regarding the design and integration of data protection in the organization’s fraud detection system.

Regarding the application of identical aggravating factors in both violations, we must indicate that the circumstances provided in Article 83.2 of the GDPR and those stipulated in Article 76.2 of the LOPDGDD are the only ones that can be applied by the AEPD for any infringement.

Finally, in Article 73, “Serious Violations,” of the LOPDGDD, the difference in infringing behaviors is noted, when for the purposes of prescription, “the failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the non-integration of the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679” is included in section d) of the aforementioned article, while in section f) it stipulates “the failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.”

2. Subsidiarily, existence of medial concurrence between the two behaviors attributed to BBVA subject to the present allegations

According to BBVA, “...there would be no doubt that the Initiation Agreement identifies (and intends to sanction) a plurality of infringements that my client would allegedly have committed (which is again flatly denied) when, in reality, one of them would be subsumed and embedded in the other, resulting in medial concurrence in the terms provided in Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector...”

In response to this allegation, it should be noted, first of all, that at this point the claimant again confuses the typification of the infringements with their qualification solely for the purposes of prescription. Both infringements are typified in Article 83.5 of the GDPR; there is not one allegedly more serious and another allegedly less serious. Secondly, Article 29 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, LRJSP) is not applicable to the sanctioning regime imposed by the GDPR for the following reasons:

1. The GDPR is a closed and complete system.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid
sedeagpd.gob.es
65/110

The GDPR is a community regulation directly applicable in the Member States, which contains a new, closed, complete, and global system aimed at ensuring the protection of personal data uniformly across the European Union.

In relation, specifically and also, to the sanctioning regime provided therein, its provisions apply immediately, directly, and integrally, foreseeing a complete and gapless system that must be understood, interpreted, and integrated absolutely, fully, and integrally, thus leaving its ultimate purpose intact, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data. The contrary results in a reduction of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the absence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Art. 83.2 of the GDPR) or specifies the existing rule concerning a possible concurrent offense (Art. 83.3 of the GDPR).

To this, we must add that the GDPR does not allow the development or specification of its provisions

by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of Art. 83.7 of the GDPR). The LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the purpose intended by the European legislator is to implement a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this sense, Recital 2 of the GDPR states that “(2) The principles and rules regarding the protection of individuals with regard to the processing of their personal data must, regardless of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of individuals.” (the emphasis is ours)

Recital 13 of the GDPR further indicates that “(13) To ensure a consistent level of protection for individuals throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including micro-enterprises and small and medium-sized enterprises, and offers individuals from all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent sanctions across all Member States, as well as effective cooperation between supervisory authorities.”

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

66/110

of the different Member States. The proper functioning of the internal market requires that the free movement of personal data within the Union is not restricted or prohibited for reasons related to the protection of natural persons with regard to the processing of personal data.” (the underlining is ours) In this system, what is decisive in the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR, combined with the provisions of Article 83 of the GDPR, demonstrate the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures referred to in Article 58, paragraph 2, letters a) to h) and j).”

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed alongside the corrective measures or in substitution thereof.

And all this with the aim of enforcing compliance with the GDPR, preventing non-compliance, promoting compliance, and ensuring that the infringement is not more profitable than compliance. Therefore, Article 83.1 of the GDPR provides that “Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

Fines must be effective, proportionate, and dissuasive to achieve the purpose intended by the GDPR. For this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case - or due to the application of a different mediating competition than that provided for in the GDPR, would undermine the effectiveness of the system, losing its meaning and teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate,

and dissuasive. And in this way, the interested parties would also be deprived of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms.

2. As there is no legal gap, there is no supplementary application of Article 29 of the LRJSP.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

67/110

In addition to the above, it should be noted that there is no legal gap regarding the application of concurrent offenses. Neither the GDPR nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in case of possible violation of data protection regulations," Article 63, which opens the Title, states that "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no provision for subsidiary application regarding the LRJSP, which does not contain any provisions related to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap or subsidiary application of the same, nor can the section relating to concurrent offenses be applied for the same reasons.

Article 29.5 of the LRJSP states that "When the commission of an infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

Well, concurrent offenses occur when, in a specific case, the commission of one infringement is a necessary means to commit another different one. The established facts determine the commission of two distinct infringements, without the violation of Article 32 of the GDPR, as BBVA asserts, being the necessary means by which the infringement of Article 25 of the GDPR (protection by design and by default) occurs.

For all the above reasons, this allegation is dismissed.

"THIRD. - ON THE ALLEGED VIOLATION BY BBVA OF ARTICLE 32 OF THE GDPR"

1. On the content of the Initiation Agreement

The first reason for BBVA's opposition to the infringement of Article 32 of the GDPR is that "the Sanctioning Body errs in interpreting the scope of the document provided, since, without prejudice to the fact that the measures contained therein, as analyzed, positively contribute to the protection of the rights of BBVA's clients, this document does not aim to establish BBVA's Policy regarding the adoption of security measures required by data protection regulations, but rather is an internal Action Guide used in cases where situations may arise that could indicate or provide evidence of fraud. In this sense, it is worth reiterating what has already been indicated regarding the fact that at no time has my client been required to provide documents evidencing the security measures adopted in relation to the processing of..."

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

68/110

the personal data of its clients, nor was it requested to analyze the risks related to such processing activities." (emphasis added)

This document was submitted by BBVA on July 23, 2022, in response to the information request made by this Agency, in which it was asked, among other documentation, in its second point, for the

"Procedure established by the entity to prevent identity theft when a person reports having lost control of their possessions (identity document, mobile phone, bank cards)." Therefore, it cannot be asserted,

as BBVA does, that it was not asked for the relevant security measures, at least in that regard, concerning identity theft. Subsequently, as stated in Background Tenth, the instructor of the procedure requested various documentation from BBVA related to technical and organizational measures to prevent fraud by identity theft in operations through "REMOTE BANKING MOBILE PHONE/CARD," when the identity document, mobile phone (where BBVA sends the authentication factor), or credit cards have been stolen, and this circumstance has been communicated by the client, as well as the technical and organizational measures that BBVA had implemented as of April 14, 2020, so that communications made to the entity by its clients regarding the loss, misplacement, or theft of the identity document, mobile phone (where BBVA sends the authentication factor), or credit cards, would take effect in its various customer relationship channels related to the operations that the client may carry out, without any response from BBVA.

The second reason for opposing the infringement of Article 32 of the GDPR is that, according to BBVA, "it cannot be held responsible for access to devices in cases where a certain person accesses this service having verified their identity through the reinforced authentication procedure provided for in the current PSD2 payment services legislation and using the Claimant's credentials."

It is the responsibility of BBVA that the constant communications recorded in the Established Facts, from the claimant to BBVA, informing through the various customer relationship channels (via email sent to the branch manager and a letter sent to customer service) about the theft suffered and the various fraudulent operations carried out by unauthorized third parties did not prevent, repeatedly, the continuation of illegal operations with the personal data of its clients, which highlights the absence of implemented security measures that prevent illegal processing of their personal data when a client reports the theft of information, such as a user authentication procedure for these cases.

BBVA asserts that "the AEPD errs in considering that the current Data Protection regulations impose, regarding the adoption of security measures, an obligation of result, understanding that this party believes that the evident spirit of the legislator, in establishing the Principle of Proactive Responsibility, is to enact an obligation of means." In the present case, as previously noted, BBVA has not even proven that the means exist, despite the documentation requested both in the information request and at the opening of the period.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

69/110

evidence to which we referred in the response to the first section of this allegation.

Finally, BBVA considers it contradictory that the initiation agreement states that "it does not have security measures and that the measures it has are insufficient due to being outdated," when both statements are, in the opinion of this party, contradictory. From the documentation provided by BBVA, the existence of various measures is confirmed, generally adopted in application of regulations other than the GDPR (Royal Decree-Law on payment services and Delegated Regulation), but the existence of security measures as required by Article 32 of the GDPR has not been proven. Furthermore, these measures, as reflected in the analysis of the documents provided by BBVA, are outdated (prior to the GDPR) and do not foresee measures that guarantee data security in cases of fraud risk and impersonation, thus failing to demonstrate the existence of true security measures. What is indeed contradictory is that BBVA claims it has not provided security measures because they have not been requested ("at no time has my client been required to provide the documents evidencing the security measures adopted in relation to the processing of personal data of its clients"), but at the same time, it wants to assert that such security measures are established.

2. On the security measures applied by BBVA during financial contracting processes through online banking

Regarding the existence of security measures in online banking contracting processes, BBVA alleges that "reference must be made to Documents 1 to 8 submitted along with this writing, from which it can be inferred that my represented party has provided guidelines to be followed by the different business areas for the implementation of security measures on the Information Systems owned by BBVA." This is documentation of various content, which aims to justify the existence of security measures, but

without specifying at what point these security measures are related to the facts subject to this procedure, and guarantee an adequate level of security to the risk in question.

At this point, none of the documents provided by BBVA detail the specific security measures that the banking entity had implemented in anticipation of the risk of loss or theft of identifying documentation or devices that allowed access to online or remote banking.

Subsequently, BBVA lists a series of websites where information is provided to its clients about security in the use of online banking and credit cards. BBVA considers that "access by the client to BBVA's online banking requires the use of a first factor of authentication, the custody and control of which does not correspond to BBVA, falling on the client." It is then worth questioning what type of solution BBVA offers to the client in the event that a third party gains access to the first factor of authentication, when it is evident that this has occurred, and the client notifies BBVA in advance that they have lost control over their personal data. In this procedure, it has been established that BBVA does not have any password management, authentication, or other types of security measures in cases of

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

70/110

high risk of fraud, for the protection of users and to prevent, among other things, the recurrent use of the first authentication factor by a person other than the account holder. It is not, as BBVA claims, the "imposition on my client of a responsibility that it lacks, since it cannot in any way control the prevention of all its online banking users' credentials being stolen from their clients by third parties." As stated, the responsibility lies from the moment that BBVA lacks any security measures for password management, user authentication, blocking, or any other type, to prevent unauthorized access in cases of loss or theft of data that can be used to commit fraud, nor even to prevent the fraud from continuing once the loss or theft has been reported to them.

For all the above reasons, this allegation is dismissed.

"FOURTH. - ON THE VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY TO THE DETRIMENT OF BBVA'S RIGHTS"

The proportionality of the proposed sanctions has been substantiated in the initiation agreement, having taken into account all the concurrent circumstances to calibrate said sanctions, just as BBVA's responsibility in the facts constituting the violations has been motivated. That the initiation of this procedure originates from a single complaint and affects two individuals does not prevent understanding that the facts are of lesser severity.

According to Article 83.4 of the GDPR, in the case of companies, violations will be sanctioned with an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, which means that the amount of the proposed sanctions is far from the maximum amount allowed by that article.

Unlike what BBVA has expressed, that the cause of the processing of this procedure is "an isolated event, beyond BBVA's control, namely the theft of the claimant's belongings," the non-application of the PDDD in the processing of personal data of clients in situations like the one that occurred in this case, as well as the absence of security measures, represent a vulnerability for all BBVA clients, in a situation as commonplace as the theft of identity documentation and mobile phones.

The aggravating factors applied to the violations correspond to the circumstances outlined in the GDPR and in the LOPDGDD for the purpose of calibrating the sanction, according to the criteria not only of this Agency but also those expressed by the European Data Protection Committee in Guidelines 04/2022 on the calculation of fines under the GDPR, adopted on May 24, 2023, and by the Courts of Justice.

The proportionality of the proposed sanctions has been motivated both in the Initiation Agreement and in this proposal for resolution.

For all the above reasons, this allegation is dismissed.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

Article 25.1 GDPR

Principle of data protection by design

Article 25.1 of the GDPR states the following:

“Data protection by design and by default

1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity posed to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing to meet the requirements of this Regulation and protect the rights of data subjects.”

In line with these provisions, Recital 78 of the GDPR states:

“The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation. In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that specifically comply with the principles of data protection by design and by default. Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements. When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection. The principles of data protection by design and by default must also be taken into account in the context of public contracts.

In particular, in light of Recital 78 of the GDPR, the principle of data protection by design is the key to be followed by the data controller to demonstrate compliance with the GDPR, as “the data controller must adopt internal policies and implement measures that specifically comply with the principles of data protection by design and by default.”

The principle of privacy by design is a demonstration of the shift from reactivity to

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

72/110

the proactivity and direct manifestation of the risk-based approach imposed by the GDPR.

Part of the proactive responsibility requires that, from the earliest stages of planning a processing operation, this principle must be considered: the data controller, from the moment an eventual processing of personal data is designed and planned, must determine all the elements that make up the processing, in order to effectively apply the principles of data protection, integrating the necessary safeguards in the processing with the ultimate goal of, in compliance with the provisions of the GDPR, protecting the rights of the data subjects.

Thus, regarding the risks that may be present in the processing, the data controller shall carry out an exercise of analysis and detection of risks throughout the entire data processing cycle, with the primary and ultimate purpose of protecting the rights and freedoms of the data subjects, and not only when the processing actually takes place. This is expressed in the Guidelines 4/2019 of the EDPB regarding Article 25 Data Protection by Design and by Default, adopted on October 20, 2020.

In the aforementioned Guidelines, it is indicated that:

“35. The ‘moment of determining the means of processing’ refers to the period of time in which the

controller is deciding how the processing will be carried out and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must evaluate the appropriate measures and safeguards to effectively apply the principles and rights of the data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing the software and hardware and data processing services.

36. Taking into account Data Protection by Design and by Default from the outset is crucial for the correct application of the principles and for the protection of the rights of the data subjects. Furthermore, from a cost-effectiveness perspective, it is also in the interest of data controllers to consider Data Protection by Design and by Default as early as possible, as it may later become difficult and costly to introduce changes to already formulated plans and designed processing operations.” To this end, the data controller must refer to the principles set out in Article 5 of the GDPR when designing the processing, which will serve to assess the effective compliance with the GDPR. Thus, the aforementioned Guidelines 4/2019 of the EDPB state that “61. To make Data Protection by Design and by Default effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive responsibility. These principles are set out in Article 5 and Recital 39 of the GDPR.”

The Privacy by Design Guide of the AEPD states that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive responsibility-oriented approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, hardware or software product, service, or process). By lifecycle

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

73/110

The object encompasses all the stages it goes through, from its conception to its withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.”

The Guide states that “Privacy must be an integral and indissoluble part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module added to something pre-existing, but must be integrated into the set of non-functional requirements from the moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire data lifecycle.”

Therefore, privacy by design, an obligation of the data controller that arises before the system is operational, is not a patch that is applied to a system built in disregard of the GDPR. Linked to the establishment of a true culture of data protection within the organization, it also implies, due to proactive responsibility, the ability to document all decisions made with a “privacy design thinking” approach, demonstrating compliance with the GDPR in this aspect as well.

The risk-based approach refers directly and immediately to a preventive system aimed at visualizing, regarding the processing of personal data, the risks to the rights and freedoms of natural persons.

Therefore, other risks to which the organization may be subjected and that affect its business scope must be excluded from the data protection risk-based approach.

In relation to the risks to the rights and freedoms of natural persons, risks must be identified, their impact evaluated, and the probability of their occurrence assessed. Thus, it is not the data that is protected, but the individuals behind it.

The risks to the rights and freedoms of natural persons arising from the processing of personal data can vary in severity and probability and can cause physical, material, or immaterial harm, tangible or intangible consequences, to the rights and freedoms of natural persons. Recital 75 of the GDPR and Article 28.2 of the LOPDGDD exemplarily compile some of those considered by the legislator, but they are not the only ones. It will depend on the processing and the context in which it is carried out, the personal data processed, the individuals involved, the means used, etc.

In this regard, the respondent has provided, for the management of incidents such as the one referred

to in this file, a document titled "Fraud and Scam Prevention." This document is dated 01/06/2015, clearly indicating that it was prepared before the approval of the GDPR. And we have already mentioned that the principle of privacy by design is a demonstration of the shift from reactivity to proactivity and is a reflection of the risk-based approach imposed by the GDPR. This aside from the outdated nature of the document in the face of a continuously evolving environment of fraud mechanisms, as acknowledged by the document itself in its section on "General Considerations":

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

74/110

"This effectiveness is conditioned by an undeniable fact: the world of fraud is in constant change and the procedures are constantly perfected by criminals, which means that information must be updated permanently."

Upon examining the document, it is observed that it has an eminently business-oriented or "commercial" approach. Its purpose is to try to prevent fraudulent practices that could cause harm to the entity. Indirectly, this may prevent financial harm to the user, but it does not protect their Fundamental Right to Personal Data Protection; their rights and freedoms are not safeguarded, which is the ultimate goal pursued by the GDPR through data protection by design. Therefore, it is not a document conceived for compliance with the principle of proactive responsibility (Article 5.2 GDPR), as it should have started from the aforementioned risk analysis that would lead to the adoption of measures for the protection of rights and freedoms, always based on the design of the processing. From this perspective, the already mentioned Privacy by Design Guide from the AEPD establishes various guidelines, which are not fulfilled in the case at hand:

"Any system, process, or infrastructure that will use personal data must be conceived and designed from scratch by identifying, a priori, the possible risks to the rights and freedoms of the data subjects and minimizing them so that they do not materialize into harm. A Privacy by Design (PbD) policy is characterized by the adoption of proactive measures that anticipate threats, identifying the weaknesses of the systems to neutralize or minimize risks instead of applying corrective measures to resolve security incidents once they have occurred. That is to say, PbD avoids the 'remedial policy' and anticipates the materialization of the risk event."

Privacy as the default setting:

"PbD aims to provide the user with the maximum level of privacy given the state of the art and, in particular, that personal data is automatically protected in any system, application, product, or service. The default setting must be established from the design at the level that is as respectful as possible in terms of privacy. In the event that the subject does not take any configuration action, their privacy must be guaranteed and remain intact, as it is integrated into the system and configured by default."

Privacy embedded in the design phase:

"Privacy must be an integral and inseparable part of the systems, applications, products, and services, as well as the business practices and processes of the organization. It is not an additional layer or module that is added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed. To ensure that privacy is taken into account from the earliest stages of design, it must:

- Be considered a necessary requirement in the life cycle of systems and services, as well as in the design of the organization's processes.
- Conduct a risk analysis for the rights and freedoms of individuals and, where appropriate, impact assessments related to data protection, as part of...

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

75/110

integral to the design of any new treatment initiative.

- Document all decisions made within the organization with a "privacy design thinking" approach.
- Respect for user privacy, maintaining a user-centered approach:

“Without overlooking the legitimate interests pursued by the organization with the data processing it carries out, the ultimate goal must be to guarantee the rights and freedoms of the users whose data is subject to processing, so any measures adopted must aim to ensure their privacy. This implies designing processes, applications, products, and services ‘with the user in mind,’ anticipating their needs. The user must have an active role in managing their own data and in controlling how others manage it. Their inaction must not undermine privacy, reiterating one of the principles already mentioned which advocates for a privacy-by-default configuration that offers the highest level of protection.”

Thus, the procedures for contracting banking products of the respondent require, in terms of data protection, a proper analysis of the risks to the rights and freedoms of customers, adequate planning, the establishment of security measures to prevent risks, maintenance, updating, and control of those measures through continuous risk review, including the demonstration of compliance (observance of the principle of proactive responsibility), especially, in the case at hand, concerning appropriate security measures. This is to ensure the Fundamental Right to Data Protection of customers, which includes the effective provision of personal data by the data subjects, as well as ensuring the security of customers' personal data effectively and, in particular, its custody, to prevent unauthorized contracting of products and services by their holders. Compliance with this obligation imposed by the GDPR on the data controller is achieved through privacy by design.

In this procedure, prior investigative actions have been carried out to analyze the complaint filed with the Agency as a result of a theft, and as a consequence, the procedure that BBVA has established for the contracting of financial products and the guarantees set forth in those procedures to prevent situations like the one that occurred has been analyzed. Thus, upon examining the procedure established by the banking entity regarding the management of incidents related to fraud, it is observed that it is completely outdated, not adapted to the GDPR, and not focused on the risks to the rights and freedoms of customers, nor for their protection, which shows that the obligation set forth in Article 25 of the GDPR regarding the design and integration of data protection into the organization's fraud detection system has not been fulfilled.

From the documentation provided by BBVA in the instruction of this procedure, the non-compliance with the obligation imposed by Article 25 of the GDPR is confirmed, and the measures adopted by this entity to comply with other regulations (Royal Decree-Law on payment services and the Delegated Regulation) cannot substitute for what is provided in

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

76/110

Article 25 of the GDPR, which urges the protection of the rights and freedoms of citizens in the processing of their data, not merely the management of information or the effectiveness of payment methods.

Indeed, upon analyzing all the documentation provided at various stages of this procedure by BBVA, it is observed that this entity did not comply with the principle of privacy by design. First of all, there was no adequate risk analysis. Not a single one of the documents submitted addressed the risk that when a customer loses or has certain identifying documents stolen (or the methods or devices for accessing their online banking), their personal data that allows for the remote contracting of financial products is exposed. The documents provided do not contain any analysis of this risk and, consequently, do not establish technical or organizational measures that could prevent the infringement of the fundamental right to data protection, along with the property rights and interests of which the customers of the banking entity are holders. On the contrary, these documents focus on avoiding risks essentially for the entity itself. They address technological or business risks that may result in financial harm to the bank.

In this regard, it should be recalled that according to Article 25 of the GDPR:

“Taking into account the state of the art, the cost of application, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the

time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of the data subjects.”

That is to say, the protection of the fundamental right to data protection does not consist of a mere “reactive” waiting for a problem that may infringe it to occur, but rather that data controllers must design (“data protection by design”) appropriate policies for the protection of this fundamental right prior to the commencement of processing. This includes all aspects regulated in the GDPR, starting with the obligations of transparency, respect for the exercise of the rights established in the Regulation, and the establishment of all necessary technical and organizational measures to ensure compliance with this regulation. All of this must be planned and implemented prior to the commencement of processing by the controller.

As a result of the inspection actions carried out by this Agency, as well as the rest of the documentation and allegations presented by BBVA in this procedure, it has been confirmed that this principle (and consequently Article 25 of the GDPR) was not complied with by the banking entity. There was no risk analysis that identified the risk of contracting through impersonation when a customer lost or had their identifying documents or mobile phone stolen.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

77/110

In this regard, the risk analysis is a key component of the principle of privacy by design, as it enables the establishment of technical and organizational measures to prevent them or, in the event they occur, to mitigate them. As noted, Article 25 makes special reference to “the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons,” as a prerequisite for the establishment of such measures.

It has been verified that neither the risk was established nor were the measures implemented as a result. All of this is corroborated through the documentation of the procedure provided by the respondent. Indeed, as has been extensively narrated in the proven facts of this proposal, since April 14, 2020, and on several occasions, BBVA had been notified of the theft of mobile phone number ***TELÉFONO.1 and the identification documentation of the claimant. However, BBVA retained this personal data of the claimant as a means through which the authentication of the claimant's identity was carried out.

At this procedural moment of the proposal for the resolution of the sanctioning procedure, there is evidence that the principle of data protection by design (Article 25 of the GDPR) has been violated in relation to the fraud management system of the respondent.

V

Classification and qualification of the possible infringement of Article 25 GDPR

If confirmed, the aforementioned infringement of Article 25 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”
The LOPDGD, for the purposes of the prescription of the infringement, qualifies in its Article 73.d) as a serious infringement, with a prescription period of two years in this case, “d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the non-integration of the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679.”

VI

78/110

Article 32 of the GDPR

Lack of security measures

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;
b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

Upon examining the security measures that the respondent generally had in place for cases of fraud and identity theft, there is evidence that BBVA did not have a procedure for security measures for the protection of personal data appropriate to the estimated possible risks.

This is evident in the documentation submitted by the financial entity, as the security measures contained in the document titled "FRAUD AND SCAM PREVENTION" and in the other documentation.

79/110

submitted by BBVA, do not comply with the GDPR nor its risk-based approach nor the protection of personal data, being clearly outdated. The procedure established for these purposes is manifestly insufficient. Furthermore, even examining the procedures set by the entity regarding the establishment and application of security measures, we must emphasize that in the specific case claimed, which was the origin of the investigation, the measures outlined in the document titled "Fraud and Scam Prevention" from BBVA were not even correctly applied; as detailed in previous grounds, on dates subsequent to the communication of the theft of the mobile phone and cards, as well as possible identification documents, on 14/04/2020, the responding party processed the contracting of various financial products, detailed above. The responding party even replied to that email acknowledging having detected various charges through online banking that it assumed had not been made by the claiming party. It attached a list of charges for the claiming party's review. However, there is no record that the financial entity had implemented measures to prevent repeated access.

According to the responding party, all those products were contracted electronically through the channel "REMOTE BANKING MOBILE PHONE/CARD." This despite the fact that the responding party

was aware of the theft of personal effects (mobile phone, wallet, etc.) that could enable fraudsters to access the claiming party's online banking, which they did.

In the explanation provided by the responding party, it is limited to detailing how the contracting would have been carried out, indicating that the remote banking system would have been used. This was likely prompted by the fact that, with the theft of their personal effects, the fraudsters would have had access to identification documents of the claiming party, and possibly to the online banking application on their mobile.

But the truth is that the responding party received an alert on 14/04/2020, regarding the theft of the mobile phone and other possible documents, which meant that it should have had security measures in place that ensured not only that already contracted products, such as the credit card, were not used, but also that new products were not contracted that would allow the fraudsters to access the claiming party's monetary assets, and even request credits.

In its response during the preliminary investigation phase, the responding party limits itself to providing documentation that is not directly related to the security measures it would have implemented for the protection of users in case of fraud. It states the following:

"In the event that the client reports the theft or loss of their identification document, it is mandatory to add that information in the teleprocessing (system used by cashiers) by blocking the account (free text) including the message 'USE OF STOLEN ID. UNDER NO CIRCUMSTANCES LIFT BLOCK. NOTIFY OFFICE XXXX AND RETAIN ID' and, at the client's discretion, if they also wish us to impose block 007 for charges: 'transfers', since these can also be made at the counter with C/ Jorge Juan, 6
www.aepd.es 28001 – Madrid

sedeagpd.gob.es

80/110

your ID number. In order to serve as an alert for the Network.

Also, ensure that the mobile phone number and email are validated and correct for the client, and that they have not been modified. If this is not the case, for security reasons, the client must change their NET passwords.

It is recommended that the block remain in place for at least until the stolen/lost document is no longer valid. However, as long as it does not affect the client's operations, it is recommended to maintain it indefinitely.

It is advisable to obtain the client's instruction regarding the loss of documentation, as well as the request for blocking and/or unblocking the account.

INTERNAL REGULATION 94.30.005 is accompanied by Document No. 3."

Upon consulting the aforementioned Document 3, although it contains some sections related to fraudulent practices similar to those adjudicated in this file ("How to identify" or "Identity theft"), it does not contain any specific provisions regarding the possible alerts that should be triggered within the entity when it becomes aware of certain events that jeopardize the rights and freedoms of citizens. In particular, the loss or theft of documentation that enables the contracting of financial products. In that case, no matter how adequate the remote identity authentication process may be, it is clear that the fraudster could overcome it by being in possession of the documentation or electronic devices such as a mobile phone, and for this case, the financial entity does not have any measures in place that guarantee the authenticity of the user.

Based on the above, and following the investigation carried out by this Agency, and the analysis of the documentation provided by BBVA in this sanctioning procedure, the procedure established by BBVA to identify the individuals who may request the contracting of banking products in cases where the client reports illegal access by third parties to their data is called into question. Furthermore, the responding party would not have implemented adequate security measures concerning the theft of identifying documentation.

Thus, neither the documentation or information provided by the respondent, nor the results produced in this case, can lead to the conclusion that BBVA had an adequate procedure regarding the implementation and application of appropriate personal data security measures, whether technical or organizational, to prevent online contracts from being made in the name of the data subject.

In accordance with the evidence available at this time in the proposed resolution, it is estimated that

the conduct of the responding party could violate Article 32 of the GDPR concerning personal data security procedures in the two referenced treatments, both in the contracting of financial products.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

81/110

VII

Classification and qualification of the possible infringement of Article 32 of the GDPR

If confirmed, the aforementioned infringement of Article 32 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and will prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein, and in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

VIII

Criteria for determining the amount

- For the infringement of Article 25 (principle of data protection by design):

Confirming Article 83.4 of the GDPR “Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount.

The following circumstances are considered as aggravating factors:

- The nature, severity, or duration of the infringement, taking into account the

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

82/110

nature, scope, or purpose of the data processing operation in question, as well as the number of affected parties and the level of damages and losses they have suffered.

In this regard, it should be noted that the lack of an adequate design for personal data processing affects personal data processing related to the contracting of financial products, which may be subject to various significant risks, such as fraud and identity theft, leading not only to the loss of availability of personal data for the data subject but also to the risk of suffering potential financial damages.

The infringement extends over time, as at least since the entry into force of the GDPR, the principle of data protection by design has not been applied to the referenced processing.

Furthermore, the number of potentially affected data subjects must be considered in determining the sanction, especially when what is examined in this case is the fraud management procedure implemented by the banking entity that affects all BBVA customers and the failure to comply with the principle of data protection by design.

In this sense, the Guidelines 04/2022 of the European Data Protection Board on the calculation of administrative fines under the GDPR, in their version of May 12, 2022, submitted for public consultation, indicate “as one of the circumstances to be assessed in the graduation of the sanction: ‘The number of specifically, but also potentially affected data subjects,’ and clarifies regarding that criterion: ‘The higher the number of involved data subjects, the greater weight the supervisory authority may attribute to this factor. In many cases, it may also be considered that the infringement assumes “systematic” connotations and, therefore, may affect, even at different times, additional data subjects who have not lodged complaints or reports with the supervisory authority. The supervisory authority may, depending on the circumstances of the case, consider the relationship between the number of affected data subjects and the total number of data subjects in that context (for example, the number of citizens, clients, or employees) in order to assess whether the infringement is of a systemic nature.’ (Article 83.2.a GDPR)

-

Severe negligence in the infringement. It should be taken into account that compliance with the principle of data protection by design is especially important in a financial entity, whose personal data processing resulting from continuous commercial legal transactions entails multiple risks to the rights and freedoms of individuals, such as identity theft or the evident risk of financial loss for the client who suffers the consequences.

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in the assessment

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

83/110

The degree of diligence must be particularly weighed against the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when BBVA's activity involves constant and abundant handling of personal data, it is essential to emphasize the rigor and exquisite care required to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006). Article 83.2.d) GDPR]

-

The link between the infringer's activity and the processing of personal data (art. 76.2.b) LOPDGDD) is evident, given that it is a financial entity that bases its business on the use of its clients' personal data.

□

For the infringement of Article 32 GDPR

According to Article 83.4 GDPR: “Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:”

The following circumstances are taken into account as aggravating factors for each of the two infringements of Article 32 of the GDPR:

-

The nature, gravity, or duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered.

In this regard, it should be noted that the lack of an implemented procedure that ensures the security of personal data appropriate to the risk affects the processing of personal data related to the contracting of financial products, which may be subject to various risks of significant severity, such as fraud and identity theft, which entails not only the loss of access to personal data by the interested party but also the risk of suffering potential financial damages. Similarly, the infringement affects the lack of appropriate security measures concerning the improper communication of a disputed debt to credit information systems, with the emergence of various risks such as potential financial or reputational

damages.

Furthermore, the number of potentially affected parties must be considered in determining the sanction, especially when what is examined in this case is the fraud management procedure implemented by the banking entity or the procedure for communicating debts to credit information systems concerning appropriate security measures, which affects all BBVA clients.

In this sense, the Guidelines 04/2022 of the European Data Protection Board on the calculation of administrative fines under the GDPR, at C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

84/110

In its version of May 12, 2022, submitted for public consultation, it indicates "as one of the circumstances to be considered in the assessment of the sanction: 'The number of interested parties specifically, but also potentially affected,'" and clarifies regarding this criterion: "The higher the number of interested parties involved, the greater weight the supervisory authority may attribute to this factor. In many cases, it may also be considered that the infringement assumes 'systematic' connotations and, therefore, may affect, even at different times, additional data subjects who have not filed complaints or reports with the supervisory authority. The supervisory authority may, depending on the circumstances of the case, consider the relationship between the number of affected interested parties and the total number of interested parties in that context (for example, the number of citizens, clients, or employees) in order to assess whether the infringement is of a systemic nature." (Article 83.2.a) GDPR)

-

Severe negligence in the infringement. It must be taken into account that in respect of the principle of proactive responsibility and the establishment of appropriate security measures in light of the risks to the rights and freedoms of natural persons identified, it is especially important in a financial entity. The processing of personal data arising from the continuous commercial legal traffic of a financial entity entails multiple risks to the rights and freedoms of natural persons, such as the risk of identity theft or the evident risk of a financial loss for the client who suffers the consequences or the improper communication of a disputed debt to credit information systems.

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when BBVA's activity involves constant and abundant handling of personal data, it must insist on the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 10/17/2007 (rec. 63/2006)]. Article 83.2.b) GDPR)

-

Any previous infringement committed by the data controller. This Agency has two sanctioning files against the respondent for insufficient appropriate security measures to guarantee the rights and freedoms of natural persons: PS/00419/2022 and PS/00429/2022. (Article 83.2.e) GDPR)

-

The link between the infringer's activity and the processing of personal data (art. 76.2.b) LOPDGDD)

IX

Proposals for Sanction

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

85/110

Based on the factors to be considered in the assessment of the amount of the sanction, as detailed in the previous sections, the possible sanction to be imposed, without prejudice to what results from the instruction of this file, would be as follows:

a) For the infringement of Article 25 of the GDPR in relation to the principle of data protection by

design and by default: FIVE HUNDRED THOUSAND EUROS (€500,000)

b) For the infringement of Article 32 of the GDPR due to lack of security measures in relation to the procedures for contracting financial products: FIVE HUNDRED THOUSAND EUROS (€500,000)

This amounts to a total of ONE MILLION EUROS (€1,000,000)

X

Adoption of Measures

If the infringement is confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, complying with data protection by design and by default in the organization's fraud detection system, and the adoption of personal data security procedures both in the contracting of financial products and in the inclusion and maintenance of customer data in credit information systems, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

In this regard, the respondent must analyze the risks, as well as establish the necessary technical, organizational, and security measures to prevent that, in cases of theft or loss of identifying documentation or access devices to online banking, banking and financial services can be contracted without the consent of the holder of the documentation and devices.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to open an additional sanctioning administrative procedure.

In light of the above, the following

PROPOSAL FOR RESOLUTION

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

86/110

That the Director of the Spanish Agency for Data Protection sanctions

BANCO BILBAO VIZCAYA ARGENTARIA, S.A., with NIF A48265169:

- For an infringement of Article 25 of the GDPR, classified under Article 83.4 of the GDPR, with a fine of €500,000 (five hundred thousand euros).
- For an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, with a fine of €500,000 (five hundred thousand euros).

That the Director of the Spanish Agency for Data Protection declares the termination of the procedure for acknowledgment of responsibility and voluntary payment by BANCO BILBAO VIZCAYA

ARGENTARIA, S.A., with NIF A48265169, regarding the following infringements:

- The infringement of Article 6.1 of the GDPR classified under Article 83.5 of the GDPR, concerning the unauthorized contracting of products.
- The infringement of Article 32 of the GDPR classified under Article 83.4 of the same Regulation, due to the lack of security measures regarding the communication, inclusion, and maintenance in credit information systems of personal data.
- The infringement of Article 6.1 of the GDPR classified under Article 83.5 of the same Regulation, concerning the incorporation of personal data into credit information systems.

Furthermore, in accordance with the provisions of Article 85.2 of the LPACAP, you are informed that you may, at any time prior to the resolution of this procedure, make a voluntary payment of the proposed fine, which will entail a reduction of 20% of its amount. With the application of this reduction, the fine would be set at eight hundred thousand euros, and its payment will imply the termination of the procedure. The effectiveness of this reduction will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the fine.

In the event that you choose to proceed with the voluntary payment of the amount specified above, in accordance with the provisions of the aforementioned Article 85.2, you must make it effective by depositing it into the restricted account No. ES00 0000 0000 0000 0000 0000 opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason, for voluntary payment, for the reduction of the amount of the fine. You must also send the proof of payment to the General Subdirectorate of Inspection to proceed to close the file.

By virtue of this, you are notified of the above, and the procedure is made known to you so that within TEN DAYS you may allege whatever you deem appropriate in your defense and present the documents and information you consider pertinent, in accordance with Article 89.2 of the LPACAP.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

87/110

926-170223

H.H.H.

INSTRUCTOR

Annex

Index of File PS/00677/2022

12-10-2021 Complaint from A.A.A.....	1
09-12-2021 Transfer of complaint to BANCO BILBAO VIZCAYA ARGEN	48
12-01-2022 Communication to C.C.C.	101
18-01-2022 Document from A.A.A.....	104
28-01-2022 Document from BANCO BILBAO VIZCAYA ARGENTARIA, S.A.	112
28-01-2022 Document from BANCO BILBAO VIZCAYA ARGENTARIA, S.A. 1	125
28-01-2022 Document from BANCO BILBAO VIZCAYA ARGENTARIA, S.A. 2	134
13-06-2022 Request for information from Claimant to A.A.A	142
13-06-2022 Request for information from Claimant to C.C.C.	145
13-06-2022 Request for information from Experian to EXPERIAN BUREAU DE	148
13-06-2022 Request for information from Equifax to EQUIFAX IBÉRICA, S.L	151
13-06-2022 Request for information from AXACTOR to AXACTOR ESPAÑA PLATF	154
13-06-2022 Request for information from BBVA to BANCO BILBAO VIZCAYA AR	158
14-06-2022 Response to request from EQUIFAX IBERICA SL	161
14-06-2022 Document from AXACTOR ESPAÑA PLATAFORM SA	176
26-06-2022 Response to request from A.A.A.	177
26-06-2022 Response to request from A.A.A. 1	288
26-06-2022 Response to request from C.C.C.....	329
11-07-2022 Complaint from A.A.A.....	386
23-07-2022 Allegations from BANCO BILBAO VIZCAYA ARGENTARIA	405
23-07-2022 Allegations from BANCO BILBAO VIZCAYA ARGENTARIA SA ...	437
23-07-2022 Allegations from BANCO BILBAO VIZCAYA ARGENTARIA SA 1	462
23-07-2022 Allegations from BANCO BILBAO VIZCAYA ARGENTARIA SA 2	495
03-08-2022 Response to request from EXPERIAN BUREAU DE	505
27-09-2022 Request for information from Claimant 2 to A.A.A.	513
27-09-2022 Request for information from Claimant 2 to C.C.C.....	520
27-09-2022 Request for information from BBVA 2 to BANCO BILBAO VIZCAYA	527
02-10-2022 Response to request from A.A.A.	530
02-10-2022 Response to request from A.A.A. 1	572
04-11-2022 Information on previous actions	600
12-01-2023 A. opening to BANCO BILBAO VIZCAYA ARGENTARIA, S.	624
13-01-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA SA	670

13-01-2023 Information from Claimant to C.C.C.....	673
C/ Jorge Juan, 6	
www.aepd.es 28001 – Madrid	
sedeagpd.gob.es	
88/110	
26-01-2023 Rectification Agreement BBVA to BANCO BILBAO VIZCAYA	677
26-01-2023 Communication to BANCO BILBAO VIZCAYA ARGENTARIA, S	682
27-01-2023 Communication 2 to BANCO BILBAO VIZCAYA ARGENTARIA,	692
09-02-2023 Request for a copy of the file of BANCO BILBAO	695
10-02-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA, S.A.....	698
10-02-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA SA	725
10-02-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA SA 1	790
10-02-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA	830
10-02-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA SA 2 890	
10-02-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA SA 3	928
10-02-2023 Document from BANCO BILBAO VIZCAYA ARGENTARIA SA 4	993
14-02-2023 Acknowledgment and/or voluntary payment from BANCO BILBA	1000
10-05-2023 Document from A.A.A.....	1003
13-07-2023 Notification for evidence to BANCO BILBAO VIZCAYA ARGENTAR	1035

>>

SIXTH: On September 27, 2023, a document from BBVA was received by this Agency, in due time and form, in which it presents allegations against the proposed resolution.

SEVENTH: On October 3, 2023, the respondent party proceeded to pay the fine in the amount of 800,000 euros, making use of the reduction provided for in the partially transcribed proposed resolution above.

EIGHTH: The payment made entails the waiver of any action or appeal in the administrative route against the fine, in relation to the facts referred to in the proposed resolution.

NINTH: In the previously transcribed proposed resolution, the constitutive facts of the infringement were established, and it was proposed that the Director impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations, in accordance with the provisions of the aforementioned article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified period...”.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading “Termination in sanctioning procedures” provides as follows:

- “1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.
2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary

sanction and another of a non-pecuniary nature but the imposition of the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent body to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or waiver of any action or appeal in the administrative route against the sanction. The percentage of reduction provided in this section may be increased by regulation.”

III

Response to the allegations made against the proposed resolution

Regarding the allegations made against the proposed resolution of this sanctioning procedure, a response is provided according to the order presented by BBVA:

“PRELIMINARY.- RATIFICATION AND REITERATION OF THE CONTENT OF THE WRITTEN ALLEGATIONS TO THE INITIATION AGREEMENT”

Prior to this, BBVA reiterates what was stated in its allegations to the initiation agreement and considers that the response to its allegations made in the Legal Ground III of the proposed resolution does not address what BBVA has alleged, but rather constitutes a reiteration of what this Agency argued in the initiation agreement.

In response to these arguments, it should be noted that the proposed resolution does not constitute a reiteration of the initiation agreement, but rather in its Legal Ground

90/110

III. A proper response was given to the allegations put forth by BBVA in its written submissions. In Legal Basis III, the argumentative structure of the document submitted by BBVA is followed.

Furthermore, in order to provide a pertinent response to the reasoning in the written allegations, some parts of it are transcribed, and finally, a detailed analysis of the documents provided by BBVA along with the written allegations is carried out.

Consequently, it can be easily verified that the proposed resolution of the present procedure does indeed adequately address the arguments put forth by BBVA regarding the initiation agreement.

For all the reasons stated, this allegation is dismissed.

“FIRST.- ON THE SCOPE OF THE ISSUES CLARIFIED IN THE PRESENT SANCTIONING PROCEDURE

In this allegation, BBVA again attributes to “a series of unfortunate circumstances” (an “unfortunate incident,” as stated in the written allegations regarding the initiation agreement) the facts that led to the initiation of the present procedure. BBVA considers that from a completely unfortunate particular situation, for which BBVA has had no objection in assuming its responsibility, the conclusion is drawn that there is a “systematic” violation, thus turning the resolution of a specific case into a sort of “general cause” against BBVA. According to the respondent, it had developed actions aimed at compliance with Data Protection by Design and by Default (hereinafter, PDDD) and precisely as a result of the analysis derived from compliance with that principle, it had implemented adequate measures from a security standpoint to prevent the risk, even though, unfortunately, those measures failed in the present case.

Two issues are raised in this allegation made by the respondent:

1. The AEPD is turning the resolution of a specific case into a sort of “general cause” against BBVA.
2. BBVA considers that it has developed actions aimed at compliance with data protection by design and by default, and precisely as a result of the analysis derived from compliance with that principle, it had implemented adequate measures from a security standpoint to prevent the risk.

We will examine them separately.

1. The AEPD is not turning the resolution of a specific case into a sort of “general cause” against BBVA.

Article 57.1 of the GDPR grants the AEPD, among other functions, the authority to monitor the application of the GDPR and to enforce it, as well as to handle complaints.

C/ Jorge Juan, 6
www.aepd.es 28001 – Madrid
sedeagpd.gob.es
91/110

submitted by a data subject or by an agency, organization, or association in accordance with Article 80, and to investigate, in a timely manner, the reason for the complaint and inform the complainant about the course and outcome of the investigation within a reasonable timeframe, particularly if further investigations or closer coordination with another supervisory authority are necessary, and to carry out investigations regarding the application of this Regulation, particularly based on information received from another supervisory authority or another public authority.

The CJEU has already had the opportunity to establish that the scope of the powers of supervisory authorities must be understood broadly and extends to any circumstances revealed during the investigation referred to in Article 57.1.f) GDPR following a complaint submitted by a data subject, if such investigation determines an insufficiency in the protection of the data subject's right to personal data protection, "regardless of the origin or nature of such insufficiency," without being limited to the original reason for the complaint in order to avoid leaving data subjects unprotected. For all, CJEU judgment of July 16, 2020, C-311/18, Data Protection Commissioner Schrems 2.

The investigations of the AEPD in relation to the complaints submitted always aim to adequately determine what happened. This is because they cannot remain at the superficial level of a potential complaint, but must delve into the reasons behind the events that occurred and what the ultimate cause of the non-compliance is, thus controlling the application of the GDPR and ensuring its enforcement. The ultimate cause can range from a specific human error to an inadequate design of certain personal data processing activities.

Neither the GDPR nor the LOPDGDD stipulate that the actions of the supervisory authority are restricted to the specific and concrete complaint of the affected individuals. And where the law does not distinguish, no distinction can be made.

Otherwise, it would distort the role that the GDPR assigns to the AEPD in defending the fundamental right to personal data protection if the information and evidence that it might obtain through its investigations, as a consequence of a complaint—evidence that could be more than evident of the commission of an infringement affecting more data subjects than those who have actually complained (such as potentially the clients of an entity)—were overlooked on the grounds that they do not strictly respond to the facts referred to by the data subject. It would be as if the AEPD were compelled to look the other way upon detecting a potential non-compliance with the GDPR because the data subject did not complain about it in their complaint.

This interpretation would prevent any European supervisory authority, and therefore the AEPD, from being able to investigate or initiate proceedings for the purposes of not only imposing the corresponding fine if applicable but also or alternatively imposing corrective measures that restore the current legality. In this way, other data subjects who are not the complaining party could be left unprotected, effectively preventing the AEPD from exercising the functions conferred by the GDPR. To this, we must add that no regulation prevents the body exercising the

C/ Jorge Juan, 6
www.aepd.es 28001 – Madrid
sedeagpd.gob.es
92/110

Sanctioning authority, when determining the opening of a sanctioning procedure, always ex officio, shall determine its scope in accordance with the circumstances revealed in the complaints and in the information provided by the respondent or before the admission for processing of the complaints, even if they do not strictly conform to the claims of the complainant. And all of this without prejudice to the fact that the agreement to initiate the sanctioning procedure is not constrained by the complaint ("the claim") submitted by the individual, but rather, other facts may arise from requests for information, from prior investigative actions, and from the subsequent processing of the sanctioning procedure that must be indicated, if applicable, in the proposal for resolution and in the resolution itself. The contrary would establish that it is the complainant who can determine the object of the sanctioning procedure, which is

not only contrary to the intention of the law, as sanctioning procedures are always initiated ex officio, but could also lead to all kinds of fraud.

Having stated the above, and focusing on the object of the present procedure, it should be indicated that as a result of the examination and investigation of a complaint filed with the AEPD, the respondent itself submitted, within the framework of the prior investigative actions, a protocol "Normativa 94.30.005 PREVENTION OF FRAUD AND SCAM" (version 8 of June 1, 2015) that includes the instructions for the prevention of fraud established for the branches, which is recorded in the Proven Fact Forty-Third (document 3) and extensively examined in the Legal Basis VI of the proposal for resolution. This document was submitted by the respondent to justify the correctness of its actions regarding fraud detection in relation to the investigated complaint.

From the results of the prior investigative actions, clear evidence was inferred of the possible commission of a series of infringements of the GDPR, all related to the specific complaint filed: some in relation to the facts suffered by the complainant and others directly connected to the previous ones and related to the procedures implemented by the entity for the prevention of fraud (which obviously affected the complainant and any customer of the banking entity).

Thus, the latter respond to a breach of Articles 25 and 32 of the GDPR respectively, which affect the complainant and any customer of the banking entity, constituting infringements of the GDPR even if the complaint had not been received.

Furthermore, the request for the evidence practiced and its assessment is connected with the complaint that led to the initiation of the present procedure.

The instructor of the procedure agreed to open a period of evidence without BBVA, surprisingly, submitting a written response to the practice of evidence or any of the requested documents (Proven Fact Forty-Six), neither at the appropriate procedural moment, nor before the proposal for resolution was formulated, nor in the allegations to the proposal for resolution, in such a way that it has not demonstrated that such documentation exists.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

93/110

Let us remember that in this practice, BBVA was requested to provide an "impact assessment of data protection (hereinafter DPIA), dated and signed, regarding the processing of personal data of BBVA customers in relation to 'REMOTE BANKING MOBILE PHONE/CARD', 'technical and organizational measures that BBVA had planned on 14/04/2020 to prevent fraud by identity theft, specifically in operations through 'REMOTE BANKING MOBILE PHONE/CARD', and, thirdly, 'the technical and organizational measures that BBVA had implemented as of 14/04/2020, so that communications made to the entity by its customers regarding the loss, misplacement, or theft of the identity document, mobile phone (where BBVA sends the authentication factor) or credit cards, would take effect in its various customer relationship channels related to the operations that the customer may carry out.' From a mere reading of the Background of this document, one can verify the relationship of the agreed evidence with the facts subject to the complaint.

On the other hand, the documentation provided by BBVA in the prior investigation proceedings and in this procedure has been analyzed in detail to determine whether it complies with the data protection by design and by default (PDDD) of Article 25 of the GDPR concerning the processes for contracting banking products, and with the existence of security measures under Article 32 of the GDPR, having been justified in this procedure that the non-compliance with these two provisions by BBVA is closely connected with the facts subject to the complaint and the documentation provided by BBVA.

However, contrary to what was done by the AEPD, BBVA neither in its allegations to the initiation agreement nor in those submitted to the proposed resolution has analyzed how the measures in the documents provided are related to the facts subject to the complaint, and how they could have prevented the illegal processing of data; it merely states that "reference should be made to Documents 1 to 8 provided along with this writing, from which it can be inferred that my represented party has

provided the guidelines to be followed by the different business areas for the implementation of security measures on the Information Systems owned by BBVA."

The specific behaviors subject to the complaint and constitutive of the various infringements attributed to BBVA have been examined in the proceedings carried out in this procedure, as evidenced by the proven facts and the legal grounds of the proposed resolution, based on the facts subject to the complaint, as well as the instructional acts.

Finally, in response to this allegation, it should also be noted that the facts constituting the infringement of Article 25 of the GDPR and the commission of the infringement of Article 32 of the GDPR cannot be considered "a particular situation," but rather, from the analysis of the documentation provided by BBVA throughout this procedure and by virtue of the facts that occur in this procedure and the consequences they have had for the complainant, the commission of two infringements has been established:

A) The infringement of Article 25 of the GDPR, attributable to BBVA due to the fact that its procedures for contracting banking products lack, in terms of...

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

94/110

data protection, a proper identification and analysis of the risks to the rights and freedoms of clients (absence of a focus on the risks to the rights and freedoms of the data subjects), adequate planning, the establishment of appropriate technical and organizational measures of all kinds aimed at preventing the materialization of risks, maintenance, updating, and control of those measures through continuous risk review, including demonstration of compliance (observance of the principle of proactive responsibility), as required by Article 5.2 of the GDPR.

B) The infringement of Article 32 of the GDPR, attributable to BBVA, due to the absence of appropriate technical or organizational security measures concerning personal data security procedures in the contracting of financial products.

Therefore, in both infringements, there is a breach of the obligations of the GDPR whose consequences have been made evident, specifically, in the continued nature of the illegal processing of personal data of the claimant, exemplified by the various fraudulent banking operations carried out by third parties using the personal data of the claimant, with BBVA being responsible for the failure to comply with the provisions of Articles 25 and 32 of the GDPR.

It must be reiterated that both infringements of the GDPR exist, and this has been made evident during the processing of the procedure, regardless of what is indicated in the complaint.

We are not facing a potential infringement of the GDPR, but rather two existing infringements that materialize in a detriment to the rights and freedoms of a citizen. As an example, what occurred with the claimant in this case is sufficiently indicative, given the repeated violations of the GDPR that have occurred, and as a consequence of which the ineffectiveness or non-existence of effective compliance with the GDPR has been made evident. In this regard, it should be noted that Article 5.2 of that regulation imposes the obligation to be able to demonstrate that one has acted in accordance with the principle of proactive responsibility.

These infringements, being based on the instructions that determine the regime of the organization and operations of BBVA, have a systemic nature, and do not prevent processing by third parties unrelated to the legitimate data owner, as this is not contemplated in the documentation provided, as already indicated in the proven facts.

In conclusion, the AEPD is not turning the examination of a complaint into a sort of "general cause" against the banking entity, given that, throughout the procedure, and regardless of the documentation provided by the claimant, it has been the entity itself that has provided the information from which the identified infringements were deduced, as reflected in the proven facts.

2. BBVA considers that it has undertaken actions aimed at compliance with

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

principle of the PDDD and precisely as a consequence of the analysis derived from compliance with that principle, had implemented appropriate measures from the perspective of security to prevent the risk.

First, a conceptual issue must be clarified. The data controller is obliged to comply with the PDDD, not only to develop actions aimed at its compliance. And the appropriate technical and organizational measures to be implemented are not only security measures but any type of measures to effectively apply the principles of data protection in order to meet the requirements of the GDPR and protect the rights of the affected individuals.

The responding party seeks to consistently and interestedly link the security measures, and only the security measures, related to the infringement of Article 32 of the GDPR with the measures provided for in Article 25 of the GDPR, as if it were a totum revolutum, for the purpose of generating an association of ideas to favor their interpretation regarding the existence of medial concurrence.

However, throughout the procedure, the different typification of Articles 25 and 32 of the GDPR has been explained in detail. Additionally, it should be noted that if both infringements were closely related, it would be normal for them to be usually charged simultaneously, which is not the case here.

Second, in response to the claims made by the responding party that it has complied, the proven facts, which have not been contested or refuted by it, clearly show the opposite as evidenced in the legal grounds of the proposed resolution.

For all the above reasons, this allegation is dismissed.

“SECOND.- REGARDING THE CONCURRENCE OF MEDIAL CONCURRENCE BETWEEN THE TWO INFRINGEMENTS ATTRIBUTED TO BBVA”

According to BBVA, this Agency had made an erroneous interpretation of its allegations regarding the non-existence of medial concurrence, when what BBVA was stating was the following: “the failure to apply the measures referred to in Article 32.1 would necessarily and inseparably result from the lack of conception or design of the same at the time of determining the means and purposes of the processing. Thus, the AEPD would consider sanctionable the lack of design of a specific security measure and its failure to apply, which obviously could only arise from that lack of prior design, thus meeting the requirements for the appreciation of medial concurrence in the present case.”

Furthermore, it requests the application of medial concurrence as set forth in Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, “LRJSP”).

There are two issues to address regarding this allegation:

1. Erroneous interpretation of BBVA's allegations regarding medial concurrence.
2. The application of medial concurrence in the terms of Article 29 of the LRJSP.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

We will examine them in a differentiated manner.

1. Misinterpretation of BBVA's allegations regarding the medial competition.

In response to the first of the allegations, it should be clarified, first of all, that concepts and classifications are being confused again in order to support the idea of the existence of medial competition.

This allegation denotes a confusion of concept by considering that two infringements which, first, are perfectly defined in the GDPR, and which, as explained throughout the proceedings, are different, and second, are classified independently in the GDPR and also qualified differently in the LOPDGDD for the purposes of prescription, are consequences of one another.

In fact, the syllogisms used otherwise are not true in a correct understanding and interpretation of what compliance with the GDPR entails.

For example:

- The lack of security measures is not the same as the failure to implement security measures, nor is one inextricably linked to the other.
- Security measures may be implemented but not applied, or applied incorrectly.

- The failure to apply security measures may not stem from a prior design problem. It may be that the data controller has not given instructions regarding their application.
- Occasionally, some organizations do not have security measures specifically implemented in accordance with the GDPR, nor do they even communicate to their employees whether they need to apply security measures, yet these employees may perform or refrain from performing some action that prevents the materialization of the risk.
- There may be no implemented security measures, but there may be other appropriate technical or organizational measures of a different kind that prevent the materialization of the risk. For example, a measure consisting of employee awareness is not a security measure under Article 32 of the GDPR but one of the measures under Article 25 of the GDPR, which can prevent the materialization of an identity theft risk.
- There may be a few security measures that are applied correctly and prevent the materialization of the risk, without prejudice to the fact that, considering all identified risks, there is a flagrant lack of all the security measures that should be implemented.
- Security measures may have been designed and implemented correctly but applied incorrectly or simply not applied.

One could continue *ad infinitum* with examples in which the lack of security measures or their lack of application arises, as the responding party states, "obviously" from that prior design, which, by the way, is also not the case in the examined instance.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

97/110

Secondly, BBVA incorrectly interprets the behaviors that constitute violations of Articles 25 and 32 of the GDPR, as it considers that the non-compliance with Article 32 of the GDPR refers to the existence and application of "measures" (without specifying what type of measures), and the violation of Article 25 is determined by the absence of conception or design of such measures.

Indeed, the Data Protection by Design and by Default (PDDD) encompasses not only the design but also the determination of appropriate technical and organizational measures of all kinds. First, there must be an identification and assessment of the risks of varying probability and severity that the processing entails for the rights and freedoms of individuals, an identification and assessment of risks that has not yet been provided by BBVA, despite the fact that such documentation has been requested in the evidence presented in the proceedings; and subsequently, "appropriate technical and organizational measures will be applied, both at the time of determining the means of processing and at the time of the processing itself." (Article 25 of the GDPR).

By way of example, technical and organizational measures that are not security-related include measures related to the management of information to clients, the establishment of a channel or procedure that articulates the processing of documents submitted by BBVA clients that affect the protection of personal data, general training courses for BBVA staff, or the conduct of audits, which would be particularly appropriate in this case, considering the shortcomings of the measures that have been revealed in this case.

Although the violations of Article 25 and Article 32 of the GDPR refer to the procedures established by BBVA, the truth is that the lack of such procedures adequate to the GDPR affects BBVA's clients. This occurred, for example, in the case of the claimant who communicated through various means the theft of their documentation and mobile phone, events that can affect their personal data, their rights, and freedoms, which should have produced an effect, a resolute reaction regarding the reported situation, in the various channels of BBVA's relationship with its clients concerning the operations they may carry out; it makes no sense that the same phone number of the claimant (**PHONE.1) continued to be recorded in BBVA's files once its theft was communicated, and that it continued to be used as an authentication factor for the claimant, and this was due to the lack of an appropriate procedure from the perspective of the GDPR as has been established in the proven facts.

2. The application of the medial concurso in the terms of Article 29 of the LRJSP.

Contrary to what the claimant has asserted, the AEPD has not indicated at any time:

- That the application of the GDPR and the LOPDGDD excludes the application of the rest of the legal system.
- That the application of the GDPR and the LOPDGDD excludes in the sanctioning procedures processed by the AEPD the consideration of existing Jurisprudence.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

98/110

- That the application of the GDPR and the LOPDGDD excludes the application in sanctioning procedures processed by the AEPD of the principles of the sanctioning procedure.

- That the application of the GDPR and the LOPDGDD excludes the application in sanctioning procedures processed by the AEPD of the principle of proportionality.

- That there cannot be any occasion, always considering the circumstances of the specific case, of medial concurrence (even if this is not the case in the procedure now examined).

- That the LRJSP does not apply to the AEPD.

The AEPD, strictly complying with all applicable regulations, which include, as could not be otherwise, the Spanish Constitution and the Charter of Fundamental Rights of the European Union, and the principles of the sanctioning procedure, asserts that:

- The principle of proportionality is applicable to the sanctioning procedure.

- The European legislator has regulated the principle of proportionality in Article 83 of the GDPR.

- Given that the GDPR has a complete and specific regulation of the principle of proportionality, resulting in the absence of any legal gap, Article 29 of the LRJSP does not specifically and concretely apply.

In relation to the alleged confusion between subsidiarity and supplementary application, we will begin by literally repeating what was indicated in the resolution proposal:

“2. Since there is no legal gap, there is no supplementary application of Article 29 of the LRJSP.

In addition to the above, it should be noted that there is no legal gap regarding the application of medial concurrence. Neither the GDPR allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP, given that the GDPR is a closed and complete system, as clarified in the allegations to the initiation agreement.

In Title VIII of the LOPDGDD relating to “Procedures in case of possible violation of data protection regulations,” Article 63 that opens the Title states that “The procedures processed by the Spanish Data Protection Agency will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures.” While there is a clear reference to the LPACAP, there is absolutely no establishment of a subsidiary application regarding the LRJSP, which does not contain any provision in its articles relating to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided for in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap or subsidiary application of the same, nor is there room for the application of the section relating to medial concurrence for identical reasons.”

As we indicated earlier, the application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case - or due to the application of a medial concurrence different from that provided in the GDPR, would undermine the effectiveness of the system, which would lose its meaning, its teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and deterrent. And in this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, and it would be contrary to the spirit of the GDPR.

It should be clarified, beforehand, that subsidiarity refers to cases where a specific situation is not regulated in a certain norm, a legal gap, leading to the application of another legal norm that regulates

such a situation, provided that it does not conflict with the legal system.

While supplementary application refers to a concurrence of norms, which implies that for a certain case, two or more norms may be applicable, so that the subsidiary norm yields in favor of the principal one.

Well, given the literalness of what was indicated by the AEPD, both supplementary and subsidiary applications were examined to conclude the non-application of Article 29 of the LRJSP but rather of Article 83 of the GDPR in relation to the principle of proportionality.

It was indicated:

- That the principle of proportionality applies to the sanctioning procedure.
- That the principle of proportionality is fully regulated in Article 83 of the GDPR.
- That there is no legal gap.
- That neither the GDPR nor the LOPDGDD refer to the application, due to the existence of a legal gap, of Article 29 of the LRJSP.
- That in the procedures processed by the AEPD, we emphasize, for the administrative procedures processed, the subsidiary application of the general rules on administrative procedures is provided.
- That in the procedures processed by the AEPD, we emphasize, for the administrative procedures processed and not in relation to the principles of the sanctioning procedure, the LOPDGDD does not establish a subsidiary application of the LRJSP.
- It was concluded that there was neither supplementary nor subsidiary application that would make Article 29 of the LRJSP applicable.

In relation to the citation of the Guidelines 04/2022 of the EDPB on the calculation of administrative fines in accordance with the GDPR, in its version 2.1, adopted on May 24, 100/110

2023, in its section 22 refers to three types of concurrence, namely, of infringement, unit of action, and plurality of actions: "When examining the analysis of the traditions of the Member States regarding concurrency rules, as indicated in the jurisprudence of the CJEU⁵, and taking into account the different areas of application and legal consequences, these principles can be grouped approximately into the following three categories: - Concurrence of infringements (chapter 3.1.1), - Unit of action (chapter 3.1.2), - Plurality of actions (chapter 3.2).

In cases of concurrence of infringements, the provision established in this regard is contained in Article 83.3 of the GDPR, which establishes a quantitative limit in these cases of concurrence: "If a controller or a processor intentionally or negligently infringes various provisions of this Regulation for the same processing operations or linked operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements." (the underlining is ours).

If we were to accept the argument put forth by BBVA, it could be inferred that the "full applicability of medial concurrence" referred to the preferential application of Article 29 of the LRJSP, in its sole intention to pay a single fine instead of the two imposed, displaces or nullifies the validity of Article 83.3 GDPR, which is entirely contrary to the legal system.

Furthermore, at this point, we must remember that the severity of infringements of the GDPR is determined according to the rules established in it and not in the LOPDGDD. The classification of infringements is regulated in Article 83, paragraphs 4, 5, and 6 of the GDPR, while the qualification of infringements as very serious, serious, or minor solely for the purposes of prescription is provided for in Articles 72, 73, and 74 of the LOPDGDD. However, contrary to what the claiming party indicates, the severity of the infringements is not regulated in these provisions of the LOPDGDD.

Finally, and no less importantly, the AEPD does not sanction for the same offense, as claimed by the responding party, but it has been established through proven facts not rebutted by BBVA, the commission of two differentiated infringements, classified in a differentiated manner, and there is, moreover, in the specific case, no medial concurrence.

For all the above, this allegation is dismissed.

"THIRD.- ON THE NON-EXISTENT VIOLATION OF ARTICLE 25 OF THE GDPR"

First of all, and before examining the allegations made regarding the violation of Article 25 of the GDPR,

1. Article 25 of the GDPR starts from the need to take into account a series of elements:

- State of the art
- Cost of application
- Nature, scope, context, and purposes of the processing
- Risks posed by the processing to the rights and freedoms of natural persons.

2. It imposes an obligation on the controller, who determines the purposes and means of the processing, giving, in this case, special relevance to the means.

3. The controller must apply, both when determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures (for example, pseudonymization), designed to effectively implement the principles of data protection and integrate the necessary guarantees into the processing.

4. With this, a dual purpose is pursued:

- To comply with the requirements of the GDPR
- To protect the rights of the affected parties.

The GDPR aims to achieve the protection of the rights of the affected parties through the application of its provisions. Therefore, the focus must always be directed towards the identification and assessment of risks to the rights and freedoms of the affected parties, with the subsequent adoption of technical and organizational measures of all kinds aimed at preventing their materialization.

Thus, Article 25 of the GDPR refers to the “Risks posed by the processing to the rights and freedoms of natural persons.”

If the approach adopted by the company or organization is not oriented towards the risks to the rights and freedoms of the data subjects but rather to the risks for the company or organization itself, not only will effective protection for the data subjects not be sought (since where you do not look, you do not see), but Article 25 of the GDPR will be violated.

It may be the case that the measures adopted by the data controller to cover the risks of their organization may eventually prevent the materialization of risks to the rights and freedoms of their clients, but compliance with the PDDD cannot be assumed within the framework of proactive responsibility when the prescribed approach in Article 25 of the GDPR, which focuses on identifying the risks of varying probability and severity that processing poses to the rights and freedoms of natural persons, with the ultimate aim of protecting the rights of the data subjects, has not been applied.

While it is true that the concept of PDDD is not new, as BBVA claims, it is also true that, in the field of data protection, the configuration of PDDD as an obligation for the data controller with the characteristics and elements previously described is indeed a completely novel issue. And it cannot be considered that the obligation imposed by the EU legislator has been fulfilled if the principle of PDDD is not applied in the terms provided in the GDPR.

This cannot be the case if the documentation, for example, predates the GDPR (resulting in the PDDD in the field of data protection not being legally configured), if it does not identify and assess the risks in the...

102/110

rights and freedoms of the data subjects or if the approach is not centered on the data subjects but rather on the risks within the organization. This is exacerbated by the fact that we find ourselves in a changing society where continuously evolving fraud is ever-present and where technology has exponentially increased the means of deception. Furthermore, both the risk assessment and the measures adopted must be updated, in light of a continuously sophisticated environment of fraud mechanisms, as acknowledged by the document “FRAUD AND SCAM PREVENTION” in its section on “General Considerations”:

“This effectiveness is conditioned by an undeniable fact: the world of fraud is in constant change and procedures are constantly refined by criminals, which means that information must be updated on a permanent basis.”

It is inconceivable that a fraud and scam prevention document from 2015 not only anticipates all current risks, eight years later, but also remains fully valid in itself.

On this particular matter, we refer to the proven facts, in relation to the documents provided by the responding party and their content, and to their assessment as set forth in the legal grounds.

An example of the responding party's incorrect application of the Data Processing and Data Protection

Directive (PDDD) can be observed in the lack of risk identification.

We specifically refer to the constant reference made by the responding party that their clients are responsible for diligently safeguarding the keys or credentials provided to them, as they claim to repeatedly warn them about this.

The accidental loss, forgetfulness, or theft of a client's keys or credentials is more than common.

That another person may, fortuitously or otherwise, gain access to the keys or credentials of a different individual is also not unusual.

The probability of this occurring increases significantly when considering the number of clients of this banking entity.

In addition to the current level of fraud.

That a person may access a client's digital banking account for the reasons described is not unforeseeable.

If a client also reports access by a third party using their keys and credentials, the likelihood of risk materialization is further increased.

And all of this is without prejudice to the client's duty of custody.

It is simply something that happens.

Thus, we find ourselves with a palpable risk present in the processing, which even at this moment the banking entity continues to fail to identify, assess, and for which it has not established or foreseen any technical or organizational measures of any kind.

Shifting its responsibility as the data controller to its clients not only constitutes a lack of loyalty but also a flagrant breach of its obligations.

Regarding the custody of the access password, we reproduce here what has already been stated.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

103/110

responded to BBVA in its allegations regarding the initiation agreement:

“BBVA considers that ‘customer access to BBVA's online banking requires the use of a first factor of authentication whose custody and control does not correspond to it, falling on the customer.’ It is then worth questioning what type of solution BBVA provides to the customer in the event that a third party gains access to the first factor of authentication, when it is evident that this has occurred, and the customer informs BBVA in advance that they have lost control over their personal data. In this procedure, it has been established that BBVA does not have any security measures for password management, authentication, or any other type in cases of high fraud risk, for the protection of users and to prevent, among other things, the recurrent use of the first factor of authentication by someone other than the account holder. It is not, as BBVA states, the ‘imposition on my client of a responsibility that they lack, since in no way can they control the prevention of all their online banking users' credentials being stolen from their clients by third parties.’ As stated, the responsibility falls from the moment that BBVA lacks any security measures for password management, user authentication, blocking, or any other type, to prevent unauthorized access in cases of loss or theft of data that can be used to commit fraud, nor even to prevent the fraud from continuing once the loss or theft has been communicated to them.”

And all this because this notorious risk continues to go undetected by the entity. It neither anticipated it initially when it began designing the procedure nor afterwards, despite the high level of fraud that is significantly increasing with increasingly sophisticated techniques.

On the other hand, the mere allegation made by the defendant that it has complied with the PDDD is not sufficient if it does not timely prove its compliance, as is the case in the present procedure, having failed to provide the specific documentation that, among other issues, would demonstrate that an identification and evaluation of the risks regarding the rights and freedoms of the data subjects in relation to fraud had been carried out.

Especially when it was given the opportunity to prove it through the documentation specifically requested as evidence in the sanctioning procedure, related to the identification and assessment of risks (data protection impact assessment and, if applicable, risk analysis).

Documentation that, let us remember, has not been provided by BBVA.

BBVA continues in its allegations maintaining that “my represented party prepared various documents aimed at preventing the identity theft of customers in their dealings with the Bank.”

In response to this argument, it should be noted that BBVA does not specify which documents it is referring to. From the analysis carried out both in the initiation agreement and in the resolution proposal of the documentation provided by BBVA, it is determined that none of the documents provided (nor the document

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

104/110

entitled “Fraud and Scam Prevention”) addressed the risk related to the fact that when a client loses, or has stolen, certain identifying documentation, or the methods or devices for accessing their online banking, their personal data is exposed, allowing for the remote contracting of financial products.

According to BBVA, “the risk materialized in this file and which my client acknowledged at the outset by paying the sanctions directly related to it does not arise from the fact that the interested party had their national identity document, cards, and mobile phone stolen, but from the fact that the person who carried out that theft was able to access an authentication and verification element of the interested party, the access keys to their private banking.”

BBVA seeks to attribute to the claiming party, and not to the third parties who stole the documents and mobile phone, the responsibility for the fraudulent banking operations, due to the lack of care in safeguarding the access key to their private banking. In this regard, it should be noted that the conduct constituting the infringement in this case involves certain measures for managing fraud incidents when, once a BBVA client reports the theft of their documents, mobile phone, or authentication key, this communication does not prevent illegal processing of their data.

Once these initial arguments referred to by BBVA in this allegation have been addressed, the subsequent reasoning is not justified in any way. This Agency does not confuse risks with the causes generating the risks, and it is not required “the necessity to detect any causes that could motivate the same,” but, just as in the document “FRAUD AND SCAM PREVENTION,” a partial transcription of which is included in the Proven Fact Forty-Third (document No. 3), it is contemplated how to act in the event of Theft or Loss of the Identity Document, appropriate measures of all kinds must be considered to prevent impersonation when BBVA has been informed of the theft or loss of the access password to “REMOTE BANKING MOBILE PHONE/CARD,” or of the device through which the second factor of authentication is established.

BBVA considers that “In this case, a failure has occurred in a specific security measure, not a violation of the principle of privacy by design.”

Indeed, the GDPR not only encompasses the adoption of appropriate technical and organizational security measures but of all kinds. We refer to what has already been stated regarding the content and elements of the GDPR.

By way of example, technical and organizational measures that are not security-related include the establishment of a communication procedure with clients, awareness training for BBVA staff, or conducting audits, which would be particularly appropriate in this case, considering the circumstances.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

105/110

shortcomings that have been revealed in this case. Furthermore, measures that prevent the use of data that has been compromised (for example, in the event of loss or theft) for the contracting of banking products.

From the repeated breaches that have occurred on the part of BBVA, it is determined that the violation of Article 25 of the GDPR is systemic in nature. As has been established in the Proven Facts, based on the documentation provided by BBVA, there are no guidelines that allow for action in the face of this specific risk, which, as indicated, is becoming increasingly frequent and sophisticated. Moreover, as

also noted in the Proven Facts, the various communications made by the claimant to BBVA have not prevented the multiple and repeated illegal processing of their personal data, which means we are not dealing with an occasional or isolated failure. If the entire system fails continuously, it indicates that an adequate procedure has not been established from the Data Protection and Digital Rights Department (PDDD).

Finally, the GDPR establishes a protection of the rights and freedoms of natural persons, which cannot be equated with the interests of the entity that must safeguard its own interests. In the present case, it is evident how inadequate protection of the rights and freedoms of customers causes them harm, which, as can be observed, does not impact the financial entity itself.

BBVA does not consider that the entry into force of the GDPR represents a change in the obligations it entails regarding data protection: "...if the documents provided by my represented party outline the guidelines to be followed for the guarantee of the principle and the measures to be adopted in certain risk situations, such as the possible impersonation of its customers in their interactions with BBVA, as my represented party has demonstrated, the fact that these documents are prior to or subsequent to the GDPR is irrelevant, as long as they respond to a principle that has existed in data protection for more than twenty years before the GDPR was fully applicable or even came into force."

However, the GDPR, as we have made explicit, enshrines proactive responsibility, which involves the implementation of a compliance and management model for the GDPR that determines the widespread observance of obligations regarding data protection. It includes the establishment, maintenance, updating, and control of data protection policies within an organization, especially if it is a large company—understood as the set of guidelines that govern the actions of an organization, practices, procedures, and tools—from the PDDD and by default, which ensure compliance with the GDPR, prevent the materialization of risks, and allow it to demonstrate its compliance.

For all the above reasons, this allegation is dismissed.

"FOURTH.- ON THE NON-EXISTENT VIOLATION OF ARTICLE 32 OF THE GDPR"

BBVA begins this allegation by repeating its arguments regarding the existence of

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

106/110

****bis in idem**** or, failing that, a medial concurrence between the two infractions that are intended to be imposed on BBVA, matters to which responses have been provided in sections ****SECOND**** and ****THIRD**** of this response to the allegations regarding the proposed resolution.

It continues by stating that "BBVA has previously referred to how the documents submitted along with its written allegations to the Initiation Agreement demonstrate the existence of such measures"; these documents have already been analyzed both in the initiation agreement and in the Legal Basis III of the proposed resolution.

A series of informational links regarding security is transcribed in the written allegations, but they cannot be strictly considered security measures.

The document provides "relevant information about the user's credentials and their proper protection, it is necessary to remember that these credentials, which must be under the exclusive control of the client, constitute, according to the regulatory framework for payment methods, and as analyzed in detail in the allegations to the Initiation Agreement, the first factor for verifying identity."

Once again, BBVA wants to attribute to any client the responsibility for fraudulent banking operations due to a lack of care in safeguarding the access key to their private banking, without assuming its responsibility for not adopting appropriate technical and organizational security measures:

"[...] And in no way can the possible breach of security in accessing online banking be attributed to my represented party due to the insufficient or inadequate safeguarding of that first authentication factor."

This issue has already been addressed previously, "As stated, responsibility falls from the moment BBVA lacks any security measures for password management, user authentication, blocking, or any other type, to prevent unauthorized access in cases of loss or theft of data that can be used to commit fraud, nor even to prevent the fraud from continuing once the loss or theft has been communicated to them."

For all the above reasons, this allegation is dismissed.

****FIFTH: ON THE VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY IN THE IMPOSITION OF THE SANCTION****

In this section, BBVA considers that "it is necessary for the Sanctioning Body to meticulously evaluate the circumstances concurrent in this case in which only two individuals have been affected, in order to determine the amount of the punitive measure that may need to be adopted against my client in the denied case where it would be appropriate to do so, something that, in the opinion of this party, the AEPD has not carried out, as will be reasoned."

In contrast to the detailed analysis that BBVA demands in its written allegations to the

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

107/110

resolution proposal, it should be noted that the initiation agreement, in its Legal Basis X, includes from page 34 to 39 the criteria for the gradation of the amount of each of the sanctions with extensive reasoning, thus the circumstances provided for in Article 83.2 of the GDPR applicable to the case have been sufficiently justified.

Starting from this basis, in response to the meticulous evaluation referred to by BBVA in its allegations to the resolution proposal, the Constitutional Court stated in STC June 16, 1982 (RTC 1982, 36) "that brief or succinct reasoning, if sufficiently indicative, does not equate to a lack of reasoning nor does it lead to its nullity." In the same vein, the Supreme Court established (STS January 30, 2001 [RJ 2001, 1147]) that "The reasoning must be sufficiently indicative, which means that its extent will depend on the greater or lesser complexity of what is questioned or the greater or lesser difficulty of the reasoning required, which implies that it can be succinct or brief, without the need for extensive considerations, when they are not necessary given the simplicity of the issue raised and resolved."

Jurisprudence employs a very flexible criterion and allows this reasoning to be made, either directly or by reference to reports or opinions contained in the proceedings (STS January 21, 2003 [RJ 2003, 893]), through the incorporation of the resolution proposal (STS November 10, 1993 [RJ 1993, 8201]), or resulting from the same administrative file (STS July 29, 2002 [RJ 2002, 7385]). This is known as "in allunde" reasoning.

Providing a more extensive response according to the considerations made by BBVA, the lack of application of Data Protection by Design and by Default in the procedure established by the banking entity regarding incident management related to fraud has been evidenced in this procedure, on one hand, as well as the non-existence of appropriate technical and organizational security measures in fraud management, particularly regarding the management of the first authentication factor when it has been repeatedly communicated by the affected party (and this has been verified by BBVA) that third parties have had access to it, on the other hand.

Well, these two infringements do not only affect the claiming party but all those BBVA customers affected by the same risk, who have suffered or may suffer the consequences of the lack of an adequate fraud management procedure with measures that ensure Data Protection by Design and by Default (Article 25 of the GDPR), or the lack of security measures (Article 32 of the GDPR), in the face of a situation of impersonation or illegal use of the personal data concerning them.

Therefore, contrary to what BBVA has claimed, these infringements would indeed have a systemic character, as they do not pertain to conduct affecting a particular case.

Additionally, considering that according to the document "Press Presentation 4T2022" available on the public consultation website <https://www.bbva.com/es/resultados-4t22/>, the total volume of active customers of the BBVA Group exceeded 67 million by the end of 2022, with 55% of new customers acquired through digital channels, this reinforces the need for an incident management procedure that ensures the rights and freedoms of individuals with technical and organizational measures.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

108/110

appropriate of all kinds, that effectively applies the principles of data protection, and, on the other hand, that security measures are adopted to prevent illegal data processing such as that which occurred in this case.

The nature of a financial entity determines that the data processing of its clients carries risks of greater probability and severity than the data processing activities of companies engaged in other types of activities, which is a circumstance to be taken into account when determining the sanction, just as it is the case with the financial data of clients, as established in Guidelines 04/2022 of the European Data Protection Board, regarding the calculation of fines under the GDPR, adopted on May 23, 2023, in which section 57 states:

“Regarding the requirement to take into account the categories of personal data affected (Article 83, paragraph 2, letter g) of the GDPR), the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response in terms of fines. This refers, at a minimum, to the types of data covered by Articles 9 and 10 of the GDPR, and to data outside the scope of these articles whose dissemination causes immediate harm or difficulties to the data subject (for example, location data, data on private communication, national identification numbers, or financial data, such as transaction summaries or credit card numbers). In general, the more such categories of data are involved or the more sensitive the data is, the more weight the supervisory authority may attribute to this factor.” (the underlining is ours).

Finally, regarding the amount of the sanction, on the BBVA website

(<https://www.bbva.com/es/resultados-4t22/>), the document “Report 4T2022” is available, in which the amount of the gross margin of the income statement can be consulted, reaching 24.890 million euros, although it is not exactly “the total annual global turnover of the previous financial year” (Article 83.4 of the GDPR), it is a figure lower than the turnover and also for the year 2022, but it provides an accurate picture of the large size of the BBVA Group, and of the proportionality in the calculation of the amount of both sanctions in accordance with the provisions of Article 83.4 of the GDPR. Returning to Guidelines 04/2022 of the European Data Protection Board, in its interpretation of the GDPR, it states: “120. Therefore, in cases where the data controller or processor is (part of) a company in the sense of Articles 101 and 102 TFEU, the combined turnover of that company as a whole may be used to determine the dynamic maximum limit of the fine (see Chapter 6.2.2) and to ensure that the resulting fine is in line with the principles of effectiveness, proportionality, and deterrence (Article 83, paragraph 1, of the GDPR).

121. The CJEU has developed extensive case law on the concept of a company. The term “company” includes all entities that engage in an economic activity, regardless of the legal status of the entity and the manner in which it is financed. For the purposes of competition law, “companies” are therefore identified with economic units and not with legal units. Different companies belonging to the same group may constitute an economic unit and, therefore, a company in the sense of Articles 101 TFEU and 102 TFEU.”

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

109/110

[...]

51 See the Binding Decision 1/2021 of the EDPB, paragraphs 412 and 423, and also the cases C-286/13 P, Dole Food and Dole Fresh Fruit Europe/European Commission, paragraphs 149 and C-189/02 P, Dansk Rørindustri and others/Commission, paragraph 258.

52 Case C-41/90, Klaus Höfner and Fritz Elser v. Macrotron GmbH, paragraph 21. See also, for example, the joined cases C-159 and 160/91, Poucet and Pistre v. Assurances Générales de France, paragraph 17; case C-364/92, SAT Fluggesellschaft mbH v. Eurocontrol, paragraph 18; joined cases C-180 to 184/98, Pavlov and others, paragraph 74; and case C-138/11, Compass-Datenbank GmbH v. Republic of Austria, paragraph 35.

53 Case C-516/15 P, Akzo Nobel and others/Commission, paragraph 48.” (the underlining is ours)

For all the above reasons, this allegation is dismissed.

IV

Imposition of measures

In accordance with the provisions of the initiation agreement and the proposed resolution, BBVA is ordered to adapt its procedures to data protection regulations within a period of 9 months, complying with the principle of data protection by design in the organization's fraud detection system, and the adoption of personal data security procedures both in the contracting of financial products and in the inclusion and maintenance of customer data in credit information systems, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations are in compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

Regarding the infringement of Article 25 of the GDPR, the respondent must analyze the risks, as well as establish appropriate technical and organizational measures of all kinds necessary to prevent the contracting of banking and financial services without the consent of the holder of the identified documentation and access devices in cases of theft or loss of identification documentation or online banking access devices, including the necessary measures so that communications made to the entity by its customers regarding the loss, misplacement, or theft of identity documents, phones, or credit cards, take effect in its various customer relationship channels related to the operations that the customer may carry out.

Regarding the infringement of Article 32 of the GDPR, the respondent must analyze the risks, as well as establish the necessary security measures to ensure that no online contracts are made in the name of the data subject and, on the other hand, that customer data is included in credit information systems when the debt is disputed.

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es

110/110

Notwithstanding the above, the text of the resolution establishes what the facts are that determine the need for compliance with data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows their organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, and such conduct may lead to the initiation of further administrative sanctioning proceedings.

In accordance with the above, the Director of the Spanish Agency for Data Protection RESOLVES:
FIRST: TO DECLARE the termination of procedure PS/00677/2022, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO ORDER BANCO BILBAO VIZCAYA ARGENTARIA, S.A. to notify the Agency within nine months of the adoption of the measures described in the legal grounds of the proposed resolution transcribed in this resolution.

THIRD: TO NOTIFY this resolution to BANCO BILBAO VIZCAYA ARGENTARIA, S.A.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided for in Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided for in

Article 46.1 of the aforementioned Law.

1331-121222

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es 28001 – Madrid

sedeagpd.gob.es